



Microsoft Azure
Foundational
Privacy Impact Assessment
December 2025

Table of Contents

About The Assessor.....	3
Table of Acronyms	5
Executive Summary	7
Part 1: Context of Assessment.....	9
Part 2: Solution Description.....	16
Part 3: Personal Information (Elements & Flows)	39
Part 4: Microsoft & Customer Contractual Commitments	45
Part 5: Data Residency	50
A. Current American Law.....	50
B. Current Canadian Law	51
Part 6: Privacy Analysis.....	58
A. Privacy Act (Canada)	59
B. Provincial Public Sector Legislation - FIPPA (Ontario).....	60
C. Provincial Health Sector Legislation – PHIPA (Ontario).....	65
D. Necessity and Proportionality Test (Charter of Rights Analysis)	75
E. Private Sector Legislation – CSA Code	76
F. Québec Private Sector Law	81
Annex A – Microsoft Azure Services.....	88
Annex B – Cloud Computing Guidance	120
Annex C - Microsoft Security Controls	126
Annex D – Microsoft Entra Data Attributes.....	140
Annex E – DPA Mapping	148

About The Assessor

This report was written by Michael Power, who has written extensively on privacy and information security issues. He is the author of **The Law of Privacy** (2013, 2017, 2021 editions) as well as the **Access to Information and Privacy Title of Halsbury's Laws of Canada** (2005, 2011, 2016, 2020 and 2024 editions). He is also the co-author of the American Bar Association's **Sailing in Dangerous Waters: A Director's Guide to Data Governance** (2004).

As a practicing lawyer and consultant, Michael Power provides legal, strategic, and operational advice to private, public, and healthcare sector clients on issues related to privacy, information governance, artificial intelligence, and emerging technologies. He is a member of the Law Society of Upper Canada and the Canadian Bar Association and served as an adjunct professor at Osgoode Hall Law School, teaching privacy law, from 2012-2022.

December 2025

INDEX OF TABLES

TABLE 1: ACRONYMS	6
TABLE 2: DOMAINS WITHIN SCOPE	12
TABLE 3: PERSONAL INFORMATION PROTECTION REQUIREMENTS.....	58
TABLE 4: MICROSOFT TERMS CONCERNING SECURITY MEASURES	155

INDEX OF IMAGES

IMAGE 1: AZURE DIVISION OF RESPONSIBILITIES	14
IMAGE 2: AZURE VMWARE SOLUTION	90
IMAGE 3: AZURE APPLICATION GATEWAY.....	92
IMAGE 4: AZURE EXPRESSROUTE	93
IMAGE 5: AZURE ROUTE SERVER	95
IMAGE 6: AZURE SYNAPSE ANALYTICS.....	100
IMAGE 7: AZURE LOAD TESTING ARCHITECTURE	102
IMAGE 8: AZURE EVENT GRID	108
IMAGE 9: AZURE API MANAGEMENT	110
IMAGE 10: AZURE GLOBAL ACCESS.....	112
IMAGE 11: AZURE AUTOMATION	113
IMAGE 12: AZURE AD INTERNAL TOPOLOGY INDICATING TENANT ISOLATION	129
IMAGE 13: INCIDENT INVESTIGATION AND RESPONSE FLOW	137

Table of Acronyms

The following acronyms appear in this document:

Acronym	Term
ACL	Access Control List
AD	Active Directory
AES	Advanced Encryption Standard
API	Application Programming Interface
CAI	Commission d'accès à l'information (Québec)
CDN	Content Delivery Network
CO+I	Microsoft Cloud Operations + Innovation
DDoS	Distributed Denial of Service
DNS	Domain Name Services
DPA	Data Protection Addendum
FHIR	Fast Healthcare Interoperability Resources
FIPPA	Freedom of Information and Protection of Privacy Act (Ontario)
FOIPPA	Freedom of Information and Protection of Privacy Act (British Columbia)
FOIPPA-NS	Freedom of Information and Protection of Privacy Act (Nova Scotia)
FPIA	Foundational Privacy Impact Assessment
GC	Government of Canada
GDPR	General Data Protection Regulation
GRS	Geo-Redundant Storage
HIC	Health Information Custodian
HPC	High-Performance Computing
HSM	Hardware Security Module
IaaS	Infrastructure as a Service
IDS	Intrusion Detection System
IPC	Office of the Information and Privacy Commissioner of Ontario
IPS	Intrusion Protection System
ISMS	Information Security Management System
IT	Information Technology
LDAP	Lightweight Directory Access Protocol
MFA	Multi-factor Authentication
MNR	Ministry of Natural Resources
MQTT	Message Queuing Telemetry Transport
NFS	Network File System
NFV	Network Function Virtualization
NIST	National Institute of Standards and Technology
NRP	Network Resource Provider
NSG	Network Security Group
NTFS	New Technology File System

OIPC-BC	Office of the Information and Privacy Commissioner of British Columbia
OPC	Office of the Privacy Commissioner of Canada
OSA	Operational Security Assurance
PaaS	Platform as a Service
PHIPA	Personal Health Information Protection Act, 2004 (Ontario)
PIA	Privacy Impact Assessment
PIB	Personal Information Bank
PIPEDA	Personal Information Protection and Electronic Documents Act (Canada)
RBAC	Role-Based Access Control
REST	Representational State Transfer
RMS	Rights Management System
SaaS	Software-as-a-Service
SAN	Storage Area Network
SDL	Security Development Lifecycle
SIEM	Security Information and Event Management
SLA	Service Level Agreement
SMB	Server Message Block
SOC	Service Organization Control
SSE	Storage Service Encryption
SSL	Secure Sockets Layer
SSPA	Microsoft Supplier Security and Privacy Assurance Program
TBS	Treasury Board of Canada Secretariat
TLS	Transport Layer Security
UDR	User Data Repositories
VHD	Virtual Hard Disk
VPN	Virtual Private Network

Table 1: Acronyms

EXECUTIVE SUMMARY

Introduction. Beginning in 2016, Microsoft has offered cloud services to Canadian clients. The use of cloud-based, “on-demand” information technology (“IT”) resources involve a change in the provision and use of IT for both small and large organizations. The benefits inevitably revolve around flexibility and cost in that cloud services represent an elastic, “pay-as-you-go” approach to the consumption of information technology, which relieves organizations from significant capital expenditures as well as the management of complex IT infrastructure. The use of data centers located in multiple, redundant sites can also provide resiliency.

This document is a *foundational privacy impact assessment* – the purpose of which is to assist those who must complete a privacy impact assessment (“PIA”) in connection with the deployment of Microsoft Azure. It is not intended to serve as a substitute for an organizational PIA but rather help reduce the effort of preparing one by providing relevant information. This 2025 update of Microsoft’s Azure Foundational Privacy Impact Assessment (“FPIA”) reflects changes in privacy law/policy and changes in the scope of Microsoft Azure over the last five years.

Scope. The scope of this FPIA is centred on Microsoft Azure - a cloud computing platform and infrastructure for building, deploying, and managing applications and services as well as the use of compute resources and the storage of information through Microsoft-managed data centers. It provides SaaS, PaaS and IaaS services and supports a variety of programming languages, tools and frameworks.

Azure provides more than 200 cloud-based products and cloud services. The various offerings under the Azure “umbrella” allow applications to operate in their own “space” on the cloud but also, if necessary, to interact with other on-premises or cloud applications. The Azure services described in this document are as of December 2025, but one immediate qualification is that the list of Microsoft Azure services continually evolves.

Data Residency. Microsoft publishes and publicly maintains a detailed listing of regions, geographies and availability zones for Azure services. With two regions located in Canada – Canada Central and Canada East – clients have the option to store and process data at rest, including personal information in Canada. It is to be noted that while some Azure services use computing resources that are limited to Canada (i.e. the resources are hosted and used within Microsoft’s Canadian data centers), other resources are “global” in nature, indicating that resources outside of Canada in other Microsoft data centers may be used in the provision of the service.

Privacy Risks and Microsoft Responses. Privacy risks for organizations generally revolve around:

- Unauthorized use of information by authorized users.
- Unauthorized collection/use or disclosure of information by external parties.
- Unauthorized or inappropriate collection/use or disclosure by a contractor, service provider or partner organization.
- Loss, destruction or loss of use of information.
- Loss of integrity of information.
- “Function creep” or changes in use and/or disclosure.
- Non-compliance with legislative requirements (e.g. accuracy, access or correction).

Microsoft responds to these privacy risks by:

- Strictly limiting the use of personal information collected, principally user ID information, to identified, authorized users.
- Minimizing the amount of data elements collected for account administration purposes.
- Minimizing access to personal information by Microsoft employees and contractors.

- Embedding in contracts, the limited access to, and use of personal information and contractors and their employees.
- Employing robust technical, physical and procedural security measures to protect Azure services and client data holdings.
- Actively monitoring access to, and use of, client information, including personal information.
- Actively auditing the technical, physical and procedural controls established by Microsoft to protect client information, including personal information.
- Instituting a detailed law enforcement policy to address requests for access to client information, including personal information.
- Having corporate mechanisms to address accountability and privacy management responsibilities.
- Employing appropriate change management and data resiliency (e.g., backup/recovery) procedures.

Microsoft has a mature and robust privacy and security posture supporting its provision of Microsoft Azure service offerings.

Shared Responsibilities. It is important to emphasize that client organizations, whether government or in the private sector, are, first and foremost, accountable for their custodianship of business and personal information. Azure clients are responsible for:

- Compliance Requirements (i.e., internal policies for adherence to applicable laws and security standards).
- Risk Assessments, including privacy impact assessments, security risk assessments, and compliance/legal assessments.
- Implementation of technical and organizational measures, wholly managed by the organization.
- Periodic and/or regular verification of these responsibilities.

While services/tools may be provided by a technology provider, their deployment and configuration remain a client responsibility. There is – and always will be - a division of responsibilities between an organization and its cloud service provider. While using the underlying Azure infrastructure, the client is still responsible for securing and managing the operating system, network configuration, applications, user identity, and data. This extends to responsibilities for the configuration, operation and, in some respects, the security of their activities in using cloud-based services.

[Remainder of page left intentionally blank.]

PART 1: CONTEXT OF ASSESSMENT

Introduction. The use of cloud-based, “on-demand” information technology (“IT”) resources involves a change in the provision and use of IT for both small and large organizations. The benefits inevitably revolve around flexibility and cost in that it represents an elastic, “pay-as-you-go” approach to the consumption of information technology, which relieves organizations from significant capital expenditures as well as the management of complex IT infrastructure. The use of data centers located in multiple, redundant sites can also provide resiliency

Since 2016, Microsoft has offered cloud services to Canadian clients consisting of:

- Microsoft Azure
 - Infrastructure-as-a-Service.
 - Platform-as-a-Service.
 - Software-as-a-Service.
- Office 365
 - Email, Document Authoring & Collaboration, VOIP services.
- Dynamics 365 CRM Online
 - CRM/Case, HR and Financial Management Software as a Service.

This document is a *foundational privacy impact assessment* – the purpose of which is to assist those who must complete a PIA in connection with the deployment of **Microsoft Azure**. It is not intended to serve as a substitute for an organizational PIA but rather help reduce the effort of preparing one by providing relevant information. The first Azure Foundational Privacy Impact Assessment (“FPIA”) was completed in 2016 and later updated in 2020. This 2025 update, like it’s 2020 counterpart, reflects changes in privacy law/policy and changes in the scope of Microsoft Azure over the last five years.

Definition of Cloud Computing. The National Institute of Standards and Technology (“NIST”) formally defines “cloud computing” or the use of cloud-based services as:

“...a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.”¹

The use of cloud-based services is simply obtaining access to computing and storage resources. This not only involves a physical layer of server, storage and network components but an abstraction layer involving the software being deployed. In the context of this assessment, the software is a series of applications that support client activities and which use Azure IaaS and/or PaaS service offerings. There is great variety in how potential users can use these resources and even in how such services may be offered to users.

Characteristics of Cloud Computing. NIST further defines the cloud model of technology deployment as having “five essential characteristics”. These characteristics are:

- *On-demand self-service.* An organization can engage computing resources (e.g. server time or storage), automatically and as required.
- *Broad network access.* Computing resources are “device neutral”, regardless of platform or organization. Access to computing resources can be done using browsers or dedicated applications through mobile phones, tablets, laptops, and workstations.

¹ National Institute of Standards and Technology, *The NIST Definition of Cloud Computing*, SP 800-145, 2011. 800-145, 2011.

- **Resource pooling.** Providers can deploy commodity-like computing resources (e.g. storage, processing, memory, or network bandwidth) to serve multiple clients. Different physical and virtual resources can be allocated, released and re-allocated according to client demand. This is a “location neutral” aspect that requires further consideration because of potential sensitivity by organizations to data residency (i.e., the data center location(s) where client data will be stored).
- **Rapid elasticity.** Associated with the concept of pooling is elasticity in the supply of computing resources. This aspect allows an organization the ability to rapidly scale a service offering without possible operational or procurement delays in order to use as little or as much computing resources as required.
- **Measured service.** Elasticity is accompanied by a need to monitor and report on utilization of the measured unit of computing resources. These resources can vary but are usually associated with storage, processing, bandwidth or volume of user activity.

Cloud Deployment Modes. Even with different types of cloud services, there can also be different modes of deployment:

- **Public cloud.** The cloud infrastructure is used by the general public. It is owned by the cloud provider using servers located on its premises.
- **Private cloud.** The cloud infrastructure is exclusively used by one organization. Any combination of resources may be owned, managed and operated by either the organization or a cloud services provider. The cloud infrastructure may be “on” or “off” premises.
- **Community cloud.** The cloud infrastructure is exclusively used by a specific community (e.g. hospitals, healthcare providers). Any combination of resources may be owned, managed and operated by an organization, a stakeholder in the community or a cloud service provider. The cloud infrastructure may be “on” or “off” premises.
- **Hybrid cloud.** The cloud infrastructure consists of two or more separate and distinct cloud infrastructures (private, community, or public). They use the same technology to permit application and/or data portability between clouds. For example, web servers in a public cloud may display non-sensitive data, which interacts with sensitive data stored or processed in a private cloud.

Cloud Service Models. A cloud service model outlines how cloud services are delivered and consumed. Microsoft offers:

- **Infrastructure as a Service (“IaaS”).** This level of service allows an organization to control and deploy the operating system, storage, and applications as well as negotiate limited control of some network components (e.g., host firewalls). Microsoft Azure is an example of a cloud-based infrastructure-as-a-service provider.
- **Platform as a Service (“PaaS”).** This level of service allows an organization to control applications and possibly configuration settings but not manage or control the network, servers, operating systems, or storage. An organization would likely be able to build applications in the cloud using programming languages, libraries, services, and tools supported by the provider. Microsoft Azure is an example of a cloud-based platform-as-a-service provider.
- **Model as a service (“MaaS”).** provides machine learning models as serverless APIs for simplified app deployment. The cloud provider handles the setup, capacity planning, and server management for customers. Serverless architectures are highly scalable and event-driven, only using resources when a specific function or trigger occurs.

- *Software as a Service (“SaaS”)*. This level of service allows an organization to use the cloud provider’s applications in the cloud with no control over the network, servers, operating systems, storage or the applications themselves. The applications are accessible from various client devices through either a thin client interface, such as a web browser (e.g., web-based email), or a program interface. Microsoft’s Office 365 is an example of a cloud-based software-as-a-service.
- *Artificial intelligence as a service (“AlaaS”)* provides AI tools and services via the cloud. Microsoft Foundry is an example of an AlaaS.

Service Providers. Where a client chooses an Azure IaaS offering, the lower levels of the stack (physical hosts or servers) and host security are managed by Microsoft’s Cloud Operations & Infrastructure (“CO+I”). CO+I is responsible for building and operating the physical infrastructure—data centers, networking, and hardware—that operate Microsoft’s cloud services, including Azure.

The Azure product group, providing a PaaS service offering, is an organization within Microsoft that provides support services for Microsoft’s applications, including authentication, virtual server hosting, and system data storage. These Azure service offerings are extensive and varied and are described both in terms of an overview and in detail in [Part 2](#) and [Annex A](#) of this document. A current list of the services delivered in each region is readily available². Privacy practitioners and business leads should always consult the listing of available services because Azure services evolve on an ongoing basis.

Scope of Assessment. The scope of this FPIA is centred on Microsoft Azure. Azure is a cloud computing platform and infrastructure for building, deploying, and managing applications and services as well as the use of compute resources and the storage of information, through Microsoft-managed data centers. It provides both SaaS, PaaS and IaaS services and supports a variety of programming languages, tools and frameworks.

The following table encapsulates the domains that form the scope of this assessment.

Domain	Within Scope	Out of Scope
Data transactions	▪ Data flows between client and Microsoft data centers containing personal information. ▪ Personal information storage within Microsoft data centers.	▪ Any information that is not meet the definition of personal information found in Canadian statutes, excluding identifying information of client personnel (e.g. employees or contractors) required to access and use the service. This includes anonymized or de-identified information about individuals associated with the client.
Relevant Legislation	For the purposes of this assessment, the following statutes are considered: ▪ <i>Privacy Act</i> (Canada) ▪ <i>Freedom of Information and Protection of Privacy Act</i> (ON) and associated Regulations. ▪ <i>Personal Information Protection and Electronic Documents Act</i> (Canada) and associated regulations ▪ <i>An Act respecting the Protection of Personal Information in the Private Sector</i> (QC). ▪ <i>Personal Health Information Protection Act, 2004</i> (ON)	▪ Legislation that does not have as its principle purpose the protection of personal information. Some statutes contain provisions concerning the protection of personal information as part of a statutory scheme for a specific program or services.

² See <https://azure.microsoft.com/en-us/services/>.

Domain	Within Scope	Out of Scope
	Legislation within Canada that specifically address data residency.	
Privacy Posture	Microsoft privacy posture as it relates to provision of cloud services, compliance with applicable legislation and compliance with service agreements.	Client privacy posture as it relates to compliance with the applicable personal information protection legislation (e.g. Privacy Act, PIPEDA, FIPPA).
Security Posture	Microsoft security posture as it relates to data flows and hosting of Azure services and support services, including compliance with privacy and security standards.	- Service offerings considered as part of the Microsoft Security Services offering. (These are addressed in a separate FPIA.) - Client security posture as it relates to physical, procedural and technical security measures implemented by customers.
Technology and Environment	- Azure services at the platform and infrastructure level as described in this document. - Relevant CO+I services.	Client infrastructure and customer services.

Table 2: Domains Within Scope

Data Center Locations. Azure is “publicly available” in 70+ regions around the world, including two regions in Canada (Toronto and Québec City). A current list of Azure regions is readily available for download³.

Azure clients can specify where their data at rest will be stored and Microsoft indicates that it will not store that client data outside the “geo” (defined as a grouping of regions) specified by the client except in limited circumstances, when it is necessary for Microsoft to provide customer support, troubleshoot the service, or comply with legal requirements; or where the client configures the account to enable the transfer of data, including the use of features that do not enable geo selection or certain other features which may store data globally. A client is free to choose a service not in a specific “geo” and it is possible – depending on the service - that data may be processed outside a geo even if stored at rest within a specific geo.

Methodology. A PIA is an evaluation of a system, environment, or process in the context of privacy principles, best practices, codes of conduct, legislation, and directives. This type of assessment is intended to inform relevant stakeholders and decision-makers about the risks to privacy arising from the changes to the system, environment, process, or program under review. Such change might take the form of a revised policy or process, or the introduction of new technology.

In completing this Microsoft Azure (2025) FPIA, the following activities were undertaken:

- Information gathering from materials provided by Microsoft.
- Interpretation and documentation of the various components of the enumerated services, for subsequent analysis and assessment.
- Review with Microsoft of the solution descriptions, for accuracy and completeness prior to conducting a privacy analysis.
- Analysis of the different service offerings in the context of compliance with chosen statutory authorities, relevant policies, and public expectations.
- Identification of privacy considerations and, if required, possible mitigation strategies.
- Review of outcomes with Microsoft stakeholders.

³ See <https://azure.microsoft.com/en-us/regions/#overview>.

For the purposes of this FPIA, all client information is assumed to be either business confidential or personal information and assigns such information a high confidentiality and integrity value. Such a valuation assumes that any compromise or unauthorized disclosure of the information in question could cause social hardship, loss of privacy, or serious harm to business operations or relationships. For Canadian federal government entities, the confidentiality and integrity value would be sufficient for information classified up to a Protected B level.

Resources. Much of the information about the privacy and security posture of Microsoft Azure is available to users through the Microsoft Service Trust Portal.⁴ Azure provides most, if not all, of the security used to protect the sensitive information of customers in their use of these tools/services. Some documentation is restricted to users who are then required to sign a non-disclosure agreement. Similarly, access to some documentation depends on a particular organization's subscriptions and permissions. It is within the Trust Portal that the most current documentation pertaining to certifications, such as those under ISO (e.g. ISO 27017, ISO 27018, ISO 22301), can be found along with other relevant publications from Microsoft.

Why are PIAs Conducted?

To describe the privacy and security measures and controls associated with a particular project or initiative.

To assess the potential privacy risks and provide recommendations to mitigate those risks.

Certifications, Regulations and Standards

 ISO/IEC International Organization for Standardization (ISO) / International Electrotechnical Commission (IEC)	 SOC System and Organization Controls (SOC) 1, 2, and 3 Reports	 GDPR General Data Protection Regulation	 FedRAMP Federal Risk and Authorization Management Program	 PCI Payment Card Industry (PCI) Data Security Standards (DSS)
 CSA Star Cloud Security Alliance (CSA) Security, Trust and Assurance Registry (STAR)	 Australia IRAP Australia Information Security Registered Assessors Program (IRAP)	 Singapore MTCS Multi-Tier Cloud Security (MTCS) Singapore Standard	 Spain ENS Spain Esquema Nacional de Seguridad (ENS)	

Reports, Whitepapers and Artifacts

 BCP and DR Business Continuity and Disaster Recovery	 Pen Test and Security Assessments Attestation of Penetration tests and security assessments conducted by third parties	 Privacy and Data Protection Privacy and Data Protection Resources	 FAQ and Whitepapers Whitepapers and answers to frequently asked questions	 AI Resources Resources describing the approach to Compliance, Security and Privacy in the AI solutions such as Copilot and Azure Open AI
---	---	--	--	---

⁴ Available at <https://servicetrust.microsoft.com>.

For Canadian organizations, it should be noted that there are specific resources available for those interested in a Canadian assessment of Microsoft products⁵, including the summary of a 2025 security assessment for “Microsoft Azure, Dynamics and Power Platform” by the Canadian Centre for Cybersecurity.⁶

Shared Responsibilities. It is important to emphasize that government and private sector organizations are, first and foremost, accountable for their custodianship of business and personal information. Azure clients are responsible for:

- Compliance Requirements (i.e., internal policies for adherence to applicable laws and security standards).
- Risk Assessments, including privacy impact assessments, security risk assessments, and compliance/legal assessments.
- Implementation of technical and organizational measures, wholly managed by the organization.
- Periodic and/or regular verification of these responsibilities.

While services/tools may be provided by a technology provider, their deployment and configuration remain a client responsibility. There is – and always will be - a division of responsibilities between a client and its cloud service provider. While using the underlying Azure infrastructure, the client is still responsible for securing and managing the operating system, network configuration, applications, user identity, and data. While Microsoft has certain responsibilities, clients have responsibilities with respect to the configuration, operation and, in some respects, the security of their activities in using cloud-based services.

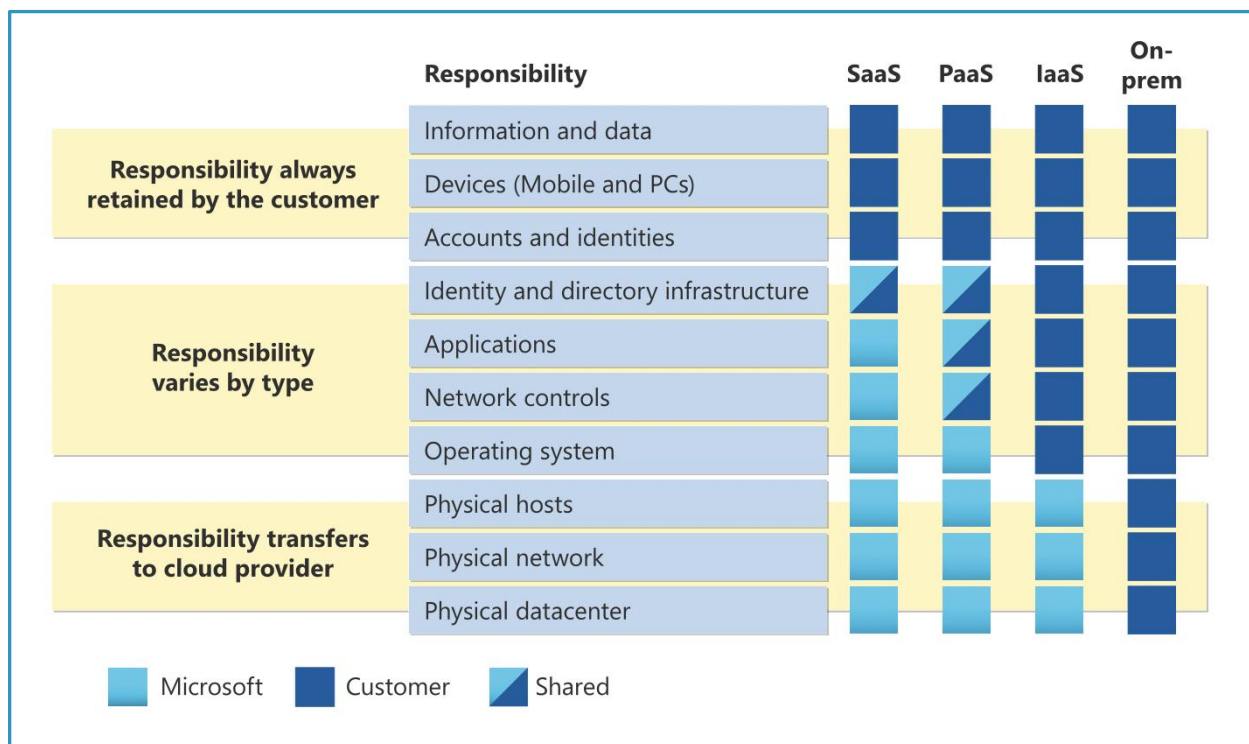


Image 1: Azure Division of Responsibilities

Disclaimer. This FPIA is not an audit of the privacy and security measures described in this document and implemented by Microsoft. Reliance is placed on the information, materials and responses provided

⁵ These Canadian assessments are available at: <https://servicetrust.microsoft.com/ViewPage/RegionalCanada>.

⁶ The specific Azure security assessment report is available at: <https://servicetrust.microsoft.com/DocumentPage/88ea41f3-30ad-4ccf-a1ef-d3734dcde472>.

by Microsoft, which have not been verified as to the actual operation of the controls in place. Unless otherwise indicated, the views and statements expressed in this assessment are those of the author and not Microsoft.

[Remainder of page left intentionally blank.]

PART 2: SOLUTION DESCRIPTION

Azure Services. Microsoft Azure is a public cloud computing platform offering a range of cloud services. Government institutions and business organizations can choose from a series of services to develop new, or run existing, applications, while using features and computing resources associated with cloud-based services.

The various offerings under the Azure “umbrella” allow client applications to operate in their own “space” on the cloud but also, if necessary, to interact with other on-premises or cloud applications. Supporting these offerings are what Microsoft characterizes as security and hybrid operations.

Azure provides more than 200 cloud-based products and cloud services. A description of services is provided in [Annex A](#) although one must immediately add a qualification in that the list of services continually evolves. Microsoft may retire or rebrand Azure service offerings or merge one or more services into other services.

To help understand the taxonomy and scope of Azure services, the Azure platforms and services are placed into a number of categories. These are:

1. Compute
2. Containers
3. Networking
4. Storage
5. Databases
6. Developer Tools
7. Analytics
8. AI & Machine Learning
9. Internet of Things
10. Integration
11. Identity
12. Management & Governance
13. Security
14. Media
15. Web
16. Mixed Reality
17. Hybrid & Multicloud

There are also a large number of internal services that support Azure platforms and services however, they are not available for customer purchase or use.⁷

In the previous 2020 Microsoft Azure FPIA, some security services were considered part of Azure. While they can still be characterized as being within Azure, these services have been addressed in a separate FPIA about Microsoft’s Managed Security services.

⁷ These internal services are: Access Monitoring, Asimov Event Forwarder, Atlas, Autopilot Security, AzCP Platform, Azure Diagnostic Services, Azure Notebooks Component, Azure Security Monitoring (ASM SLAM), Azure Service Health, Azure Stack Bridge, Azure Stack Diagnostics and Analytics Service, Azure Stack Edge Service, Azure Support Center, Azure System Lockdown, Azure Throttling Solutions, Azure Watson, CoreWAN, dSCM, dSMS, dSTS, Dynamics 365 Integrator App, Fabric Controller Fundamental Services, Fabric Network Devices, Falcon, Gateway Manager, Geneva Actions, Geneva Analytics Orchestration, Geneva Warm Path, Interflow, JIT, MDM, MEE Privacy Service, Microsoft Email Orchestrator, MSaaS File Management (DTM V2), MSFT.RR DNS, M365D Automated IR, M365D Investigation and Exploration, M365D Management Service, Network Billing, OneBranch Release, OneDeploy Deployment Infrastructure (DE), OneDS Collector, PF-FC, Pilotfish, PMI Foundation, Resource Provider Service as a Service, Unified Remote Scanning (URSA), Vulnerability Scanning & Analytics, WaNetMon, Windows Azure Jumpbox, Workflow, and Scuba Security Platform.

Guidance on the Use of Cloud Services. For organizations, guidance on the use of cloud services has been provided by a number of authoritative sources. While written for public sector entities, they are nonetheless useful for private sector organizations as well. Taken together, this guidance allows current and prospective Microsoft customers to better understand whether a custodian of personal information has taken reasonable steps to ensure the security of the information, including personal information, entrusted to a cloud-based service provider.

Canada (OPC). The Office of the Privacy Commissioner of Canada (“OPC”) has provided views for private sector organizations with respect to outsourcing of personal data processing across borders, *Guidelines for Processing Personal Data Across Borders*⁸ and these considerations would apply whether data in the cloud or otherwise.

Canada (TBS). The Treasury Board of Canada Secretariat (“TBS”) has issued guidance as it relates to federal departments adopting cloud-services, and storing information up to and including Protected B. While this guidance is largely a policy on the adoption and use of cloud-services, and places responsibilities on the Government of Canada’s departments, there are identified requirements that departments are to look for when procuring cloud services. The details of this guidance and how Microsoft meets them is described in [Annex B](#).

Ontario. Ontario’s Information and Privacy Commissioner (“IPC”) considered the use of external service providers by Ontario government agencies and departments in a special investigation report, *“Reviewing the Licensing Automation System of the Ministry of Natural Resources”*⁹ (MNR Report). This report formed the basis for later OPC guidance to Ontario’s public sector organizations entitled *“Thinking About Clouds? Privacy, security and compliance considerations for Ontario public sector institutions”*.¹⁰ (See [Part 4](#) for a mapping of recommended contractual requirements to Microsoft’s commitments.)

British Columbia. The Office of the Information and Privacy Commissioner of British Columbia (“IPC-BC”) has also offered guidance on the subject of using cloud-based service providers¹¹. Part of that guidance concerns “reasonable security arrangements” and requires the public body to review the cloud provider’s security after considering the sensitivity of the information to be stored or processed. For potential customers of any cloud-based service, including Microsoft Azure services, there are significant aspects of the privacy and security postures of any service provider to review. These include:

- **Governance** – corporate policies, procedures, and standards with respect to security and privacy.
- **Identity and Access Management** – the controls surrounding access whether by cloud provider employees or customer employees and users.
- **Infrastructure Security** – the management and ongoing maintenance of network, system and application security including layered security controls and patch management.
- **Encryption** – personal information in transit should be encrypted as well as while stored at the cloud provider’s facilities.
- **Contractual provisions** – contracts should include breach notification requirements (“as soon as possible”) in the event of an actual or suspected breach of personal information as well as Cloud facility visitation/audit rights.¹²

With respect to the use of cloud computing services, how Microsoft addresses security requirements are discussed in [Annex C](#). Contractual aspects are discussed in [Part 4](#).

⁸ Available at: https://www.priv.gc.ca/en/privacy-topics/airports-and-borders/gl_dab_090127/.

⁹ PC12-39 available at https://www.ipc.on.ca/images/Findings/2012-06-28-MNR_report.pdf.

¹⁰ Available at: <https://www.ipc.on.ca/wp-content/uploads/2016/08/thinking-about-clouds-1.pdf>.

¹¹ See OIPC-BC, “Cloud Computing Guidelines for Public Bodies”, June 2012.

¹² Note, however, the discussion in Part 2 concerning hyperscale cloud and the approach of using independent third-party auditors to assess Microsoft adherence to controls contained in standards documentation. This objective of “visitation/audit rights” may be achieved in other ways and may be viewed as less effective as cloud-based operations evolve.

Azure Services and Personal Information Processing. The nature of Azure services presents a variety of functionality for Microsoft Azure clients, regardless of the offering (SaaS, PaaS and IaaS). Depending on the organizational sophistication, clients may use a few, some or many of Azure services.

From a privacy perspective, a fundamental aspect is to understand where an Azure service processes personal information. In preparing this FPIA, such processing can be described as falling into four categories.

- A. The service or any associated service does not process personal information.
- B. The service does not process personal information, but associated services may.
- C. The service is an ephemeral service, where a function is performed but data containing personal information is never stored to disk.
- D. The service manages customer content data at rest and therefore processes personal information

These categories (A, B, C, D) align with Microsoft's internal privacy framework for Azure services. Where usage or configuration can affect placement in a category, especially for services that can operate in multiple modes, this has been noted. Each service is considered in terms of its typical or intended use.

A. The service or any associated service does not process personal information.

Azure Service	Category	Notes / Rationale
Azure Machine Configuration	A	<i>Applies desired configurations to VMs – no personal data.</i> It orchestrates VM configuration compliance. It processes machine settings/telemetry (not user data) and does not handle personal information (only technical metadata).
Azure Planned Maintenance	A	<i>Platform maintenance scheduling – no customer data.</i> This refers to Azure's system for coordinating host updates and reboots. It deals with infrastructure events and does not handle any personal or customer content.
Virtual Machines Licenses	A	<i>Licensing feature (e.g. Azure Hybrid Benefit) – no data processing.</i> This is a licensing construct for VMs. It does not involve processing of customer information – it's just a flag on a subscription/VM for billing, with no personal data involved.
Azure Container Registry	A	<i>Stores container images (usually no personal info).</i> This is a managed registry for container images and artifacts. These images typically contain application code and binaries, not personal data. ACR does store customer-provided images at rest , but those images should not contain personal info except possibly embedded in configuration. According to the Azure privacy categorization, services like ACR are considered not to process personal info themselves. (Customers are responsible to ensure secrets or personal data aren't baked into images.)
Azure DDoS Protection	A	<i>Network protection service – no customer content stored.</i> DDoS Protection monitors traffic patterns and mitigates attacks at the network level. It might collect telemetry like IP addresses and attack metrics, but that is considered service-generated diagnostic data. It doesn't handle customer-provided personal content. The service is focused on network traffic volumes and does not store payload data. (Attack logs are stored in Monitor, mostly containing IPs or IDs, which can be considered pseudonymous.)
Azure DNS	A	<i>DNS hosting – stores DNS zone records (usually not personal).</i> Azure DNS holds DNS records (domain names to IP mappings).

		These are typically technical configurations (hostnames, IP addresses). The service does not process personal data in providing name resolution. (DNS records could theoretically contain personal information if someone put a person's name or email in a text record, but that is at the discretion of the customer.)
Azure Firewall Manager	A	<i>Central management for firewalls – no personal data.</i> Firewall Manager stores policy definitions and deploys them to firewalls. The policies contain IP ranges, domain names, rule names – not personal info. It does not handle customer content , only security configs.
Azure Load Balancer	A	<i>Layer-4 load balancer – no content stored.</i> The Load Balancer distributes network packets (TCP/UDP) across VM instances. It operates at the transport level and does not inspect or persist packet contents. No personal data is stored; the service only keeps configuration (IP addresses, health probes). (Any session info is in memory only for the NAT/flow table.)
Azure NAT Gateway	A	<i>Outbound SNAT service – no personal info.</i> NAT Gateway translates private IPs to a public IP for egress traffic. It handles packets statelessly and does not store any user data . It does not have user-defined config beyond IPs and subnet association.
Azure Network Function Manager	A	<i>Manages deployment of virtual network functions – config only.</i> It helps deploy and lifecycle-manage virtual appliances (e.g., third-party firewalls). The service stores deployment metadata (e.g., which VNets and appliance images to use), but no customer application data. Any personal data would be in the network function itself (managed separately).
Azure Route Server	A	<i>Enables BGP route exchange – no personal info.</i> Route Server facilitates dynamic routing between Azure VNets and NVA (Network Virtual Appliance) or on-prem routers. The service processes routing data (BGP routes), containing IP prefixes and metrics – no personal data . It retains the network routes for the session, but not customer content.
Azure Virtual Network	A	<i>Virtual network layer – no inherent data processing.</i> An Azure VNet is a logical isolation of the network. It doesn't inspect or store the contents of traffic . It's just an environment for other resources. Any personal data is handled by the resources (VMs, etc.) in the VNet or by network services attached, not by the VNet fabric itself.
Azure Virtual Network IP Services (Azure IP Services)	A	<i>IP addressing services (like Azure-owned IP ranges, etc.) – no personal data.</i> This is essentially infrastructure providing IP addresses (perhaps the public IP service, or other IP management). It deals with allocation of IPs and related info. No personal user data is processed – just networking configuration.
Virtual Network Manager	A	<i>Central management of VNets – no personal data.</i> It allows you to group virtual networks and apply connectivity or security admin rules at scale. It stores topology and policy data (addresses, network IDs) but not customer personal info. It's configuration management for networking.
Network Security Perimeter 10	A	(This appears to be a reference to a network security model or an internal concept rather than a distinct Azure service product.) <i>No customer data is directly processed by this item.</i> It likely denotes a

		set of network security controls. As such, it doesn't store or process personal information on its own – it's an architecture guideline.
Azure Traffic Manager	A	<i>DNS-based global traffic routing – no data storage.</i> Traffic Manager uses DNS to direct clients to different service endpoints. It does not see or store the content of traffic – it only monitors endpoint health (via HTTP probe) and returns DNS responses. It may log endpoint health metrics, but these contain no personal info (just uptime, response time). Client requests beyond DNS are not processed by Traffic Manager.
Azure App Configuration	A	<i>Stores app configuration key-values – generally not personal data.</i> This service holds configuration settings (e.g., feature flags, connection strings) for applications. These are usually technical data. The service is not intended for personal/customer content. If used as designed, it contains no PII (and secret values should go to Key Vault). As a result, it doesn't process personal information itself.
Azure Deployment Environments	A	<i>Manages templates and sandboxes – no personal data.</i> Deployment Environments service helps deploy consistent dev/test environments via templates. It stores environment definitions and settings (like infra-as-code templates). Those might include things like names of resources but not end-user personal data. The deployed resources might handle data, but that is outside this service.
Azure for Education	A	<i>Program for credits and resources for education – not a technical service storing data.</i> "Azure for Education" provides Azure services to students/educators. This is a licensing/offer program and a set of learning tools. Students sign up with personal details, but registration is handled by Azure account management under the normal privacy terms.
Azure App Testing	A	The service primarily handles application telemetry or deploys test instances and concerns itself with app behavior. It would not process personal information unless the app being tested sends some. If that were to occur, this testing tool would not store such information except in logs.
Azure Managed Grafana	A	<i>Managed Grafana dashboards – stores visualization configs, but not the underlying data.</i> Azure Managed Grafana lets users visualize data from other sources (e.g., Log Analytics, Azure Monitor). The Grafana service stores dashboard definitions, panel configurations, and user access info (which may include user IDs). The actual metrics or logs being visualized are queried from their source (not stored permanently in Grafana). Grafana might cache query results in memory but does not persist customer data logs on disk; it's mainly a visualization layer.
Azure Service Connector	A	This service is to manage "wiring up" one service to another. It may hold connection configurations/credentials (which should be secrets in Key Vault) but not actual customer data.
Azure Chaos Studio	A	<i>Fault-injection service – no customer content involved.</i> Chaos Studio orchestrates test faults (restarts, latency injection) for client resources. It does not need to read or store any application data – it's focused on resource behavior. No personal

		information is processed ; it just triggers events (like shutting down a VM) and records the outcome (pass/fail) at a high level.
Azure AI Foundry Portal	A	The Foundry Portal organizes access to various Azure AI models and agents. It would store configuration about connections between services, prompts, etc., but not the actual business data unless explicitly provided for testing. On its own, it's more of a management interface, used as a tool to route data to the appropriate AI service. (Any personal data would be handled by the underlying AI services invoked, not by the portal layer itself.)
Azure AI Services	(Varies)	This is simply a broad category label for Azure's AI Services. Specific services are listed below.
Azure AI Services: Azure AI Containers	A	<i>Cognitive Services containers – no cloud processing (customer runs container).</i> Where customers run containerized versions of Cognitive Services in their environment, then Azure isn't processing data at all – the customer does on their own infrastructure.
Azure Open Datasets	A	<i>Public datasets provided for analytics – no customer personal data processed.</i> Azure Open Datasets are curated datasets (e.g., weather, census data) provided by Microsoft for anyone to use in Azure ML or analytics. They are typically anonymized or aggregate public data, with no personal identifiable info. The service is simply hosting static datasets; it's not processing customer data. It doesn't take input from the user – rather, it provides data. The datasets themselves contain no personal information by design.

B. The service does not process personal information, but associated services may.

Azure Service	Category	Notes / Rationale
Azure Arc	B	<i>Hybrid management service that holds no personal data, but associated resources might.</i> Azure Arc projects on-premises or multi-cloud resources into Azure for management. It stores minimal metadata (resource IDs, configuration) and does not store customer content. However, the servers or SQL instances onboarded via Arc may contain personal data, so associated services (e.g. Log Analytics, etc.) might process personal information.
Azure Large Instances	B	<i>Dedicated bare-metal servers for specialized workloads (e.g. SAP HANA).</i> The service provides isolated infrastructure but does not itself inspect or move the data on those instances. Customer data resides on the instances (which the customer controls) and any associated storage, not in the management service. Associated services like storage or backups could hold personal data.
Azure Service Fabric	B	<i>Platform for microservices – data depends on usage.</i> Service Fabric orchestrates applications which may store "state" (e.g. in Reliable Collections or external stores). The orchestration service itself does not persist customer content beyond necessary replication metadata. Personal data, if any, would reside in the stateful services or databases that the customer deploys (associated storage).
Azure Virtual Desktop	B	<i>Cloud platform stores minimal data itself.</i> Azure Virtual Desktop manages host pools and user session brokering. User profiles and session data are typically stored on attached storage (FSLogix containers on Azure Files, OneDrive, etc.), not within

		the “AVD” service. The service itself mainly holds configuration (host names, app groups). (Personal information like user files or profiles are handled by associated storage solutions, not by the control plane.)
Azure VM Image Builder	B	<i>Image creation service – ephemeral processing.</i> This service runs a temporary VM to build a custom image and then outputs an image to Azure Compute Gallery or Storage. The service itself does not retain personal data ; it orchestrates the process (the resulting image containing OS and software is stored in a client’s account). If the image or build artifacts contain personal info, that data rests in the output storage, not within the Image Builder service.
VMware Solution (Azure VMware)	B	<i>Managed VMware environment – data resides in VMs.</i> Azure VMware Solution provides hosts for running VMware VMs in Azure. Customer VMs in this environment store data at rest (on vSAN datastores) which may include personal information, but the management service doesn’t directly access or process the VM content. Microsoft’s service manages the infrastructure, while the customer controls any data inside the VMs (similar to Azure VMs).
Azure Arc Enabled Kubernetes	B	<i>Hybrid K8s management – metadata only.</i> Arc-enabled Kubernetes connects an outside K8s cluster to Azure for governance. Azure stores cluster metadata (like resource name, tags, configuration) but does not ingest the cluster’s application data . Any personal data in the Kubernetes workloads remains in the cluster (on-prem or in cloud) – not in Azure. (Arc may pull config information or metrics for monitoring, which could be sent to associated services like Monitor if enabled.)
Azure Kubernetes Service	B	<i>Managed Kubernetes – customer data in pods/persistent volumes.</i> This service orchestrates containers; the control plane stores cluster state (like deployments, secrets) which may include some sensitive config. Application data, however, resides in etcd (for K8s objects) and in attached persistent volumes or external services. Azure’s management of this service does not itself examine or use personal data – it deploys the cluster and keeps it running. Any personal information would be in the workloads that run on the service or in volumes (which are Azure Storage, category D).
Azure Red Hat OpenShift	B	<i>Managed OpenShift clusters – similar to Azure Kubernetes Service.</i> The service provides an OpenShift environment; Red Hat and Azure manage the underlying platform. Customer applications and data run within the cluster and are not accessed by Azure beyond hosting. Any persistent data (e.g., in databases) is stored on Azure storage or attached disks (See D category). The service itself handles infrastructure and metadata without directly processing personal content.
Azure Application Gateway	B	<i>Layer-7 load balancer – processes traffic flows, no long-term storage.</i> App Gateway may briefly buffer and inspect HTTP requests (for routing or Web Application Firewall checks), but it does not store request data to disk . The service might log access and diagnostics to Azure Log Analytics if enabled (personal data like client IP could appear in those logs, which are handled by an associated service). By itself, Azure Application Gateway just passes traffic through.
Azure Bastion	B	<i>Secure VM remote access – ephemeral session, minimal storage.</i> Azure Bastion provides web-based RDP/SSH into VMs. User

		keystrokes and screen data are streamed through but not saved by the Bastion service . The service does not record session content (no built-in session logging). Only configuration info (like Bastion host IP) is stored in Azure. Personal data might be seen on-screen during a session, but that remains on the VM; Bastion is essentially a transient conduit.
Azure Communications Gateway	B	<i>Telecom gateway bridging PSTN and Azure – primarily transient data.</i> This service connects telephony networks to Azure (for Teams calling, etc.). Call audio and signaling data pass through it. It does not permanently store call content. Some metadata like phone numbers, call duration or quality metrics may be logged to associated services (for analytics or billing). The gateway itself, however, functions in real-time and does not retain personal conversation data after routing.
Azure ExpressRoute	B	<i>Private circuit connectivity – no data stored but carries data that may be personal.</i> ExpressRoute provides a private network link between customer on-premises and Azure. It does not itself log or store the contents of network traffic. Any personal data travels through the circuit but is not processed or persisted by ExpressRoute. Associated network devices on either end might log connection stats, but ExpressRoute service mainly handles the pipe.
Azure Firewall	B	<i>Cloud network firewall – processes traffic, optional logging.</i> Azure Firewall inspects and filters network traffic in memory. By default, it does not store payload data . It can output logs of flows or threats to Log Analytics; those logs might include IP addresses or URLs (potentially personal if they contain identifiers). The firewall service itself just enforces rules on the fly – any retained data (logs) go to an associated storage or SIEM (if configured).
Azure Orbital Ground Station	B	<i>Satellite ground station as a service – passes data, minimal storage.</i> Orbital receives satellite signals and forwards them to customer endpoints in Azure. Any satellite data (which could include remote sensing data or communications) is streamed through and delivered to the customer's storage or VM. The service might buffer data during downlink windows but does not permanently retain it. Scheduling info and telemetry are stored (not personal). Personal data could be in the transmission content, but that content isn't stored by the service after relay.
Azure Peering Service	B	<i>Improves internet routing via ISPs – no customer content stored.</i> Peering Service provides optimized routing for customer traffic from an ISP to Azure. The service monitors telemetry like latency and prefixes. It does not itself process or store personal data from the traffic; but simply ensures a reliable path. Some data like IP address ranges and routing info is handled, but that is network infrastructure data.
Azure Private Link	B	<i>Private endpoint for PaaS – no data stored in service.</i> Private Link maps a private IP to an Azure service endpoint. It does not store customer payload data; it simply provides network connectivity. Any personal data flows through the private link directly to the service (e.g., to an Azure SQL instance), and would be stored on that target service, not in Private Link.
Azure ExpressRoute Traffic Collector	B	<i>Collects network flow logs on ExpressRoute circuits.</i> This service can mirror or gather traffic statistics for analysis. It forwards traffic data to an analysis or storage service; it does not permanently keep the data. If enabled, the service will send flow records or

		packet captures to a destination (e.g., Azure Storage or a Network Insights resource). Those records could include personal data (IP addresses, etc.), but that personal data is stored in the chosen analysis location (associated service) rather than in the Traffic Collector component itself.
Azure Web Application Firewall (WAF)	B	<i>Protects web apps by inspecting HTTP(S) traffic.</i> WAF is typically deployed with App Gateway or Front Door. It examines web requests (which might include personal data in headers or payload) to block attacks. However, it does not store those requests beyond transient inspection. It logs alerts (e.g., an attempted SQL injection) to Log Analytics or Storage if configured – those logs contain portions of the request (e.g., an IP or malicious snippet). The WAF itself is stateless filtering; any retained data goes to an associated log (which then becomes subject to retention at rest).
Azure Network Watcher	B	<i>Network diagnostics and monitoring.</i> Network Watcher can capture packets and collect NSG flow logs for a client's VNets. By default, the service only stores operational metrics (e.g., connection check results) which have no personal data . If packet capture or flow logs are used, those are sent to a client's Storage account or Log Analytics workspace . In that happens, personal data could be in those captures (e.g., IP addresses, payload) but it is stored in the associated storage (See Category D) not in the Network Watcher service itself.
Azure Virtual WAN	B	<i>Networking service (hub-and-spoke connectivity) – minimal data storage.</i> Virtual WAN connects sites and Azure via hubs. It carries VPN/ExpressRoute traffic but does not inspect or store user payloads . It keeps configuration about connections (which branch offices exist, etc.) and can log aggregate telemetry. Personal data may transit through the VPN tunnels, but that is not stored by Virtual WAN itself.
Azure Virtual Network Gateway	B	<i>VPN gateway for site-to-site or point-to-site VPN.</i> It terminates VPN sessions and forwards traffic to the VNet. It does not persist the contents of the VPN traffic . There are some user-related data intersects (e.g., for point-to-site, it authenticates users which could involve checking a certificate or Azure AD token), but it doesn't store those long-term. The gateway may output logs of connections (e.g., user IP, connect/disconnect times) to Azure Monitor if enabled. The VPN payload, which could contain personal info from user communications, is encrypted and not retained by the gateway.
Azure Site Recovery	B	<i>Disaster-recovery replication service – orchestrates data movement.</i> This service coordinates copying of VM disks or servers from a primary site to Azure Storage (or between regions). The service does not permanently store the VM data but, rather, moves data into a Recovery Services Vault (which uses Azure Storage) where the replicated disks are kept. The service does not process personal information itself because it's essentially an orchestrator. However, it triggers creation of copies of customer VMs that do reside in Azure (Recovery Vault), which contain personal data at rest.
Azure Database Migration Service	B	<i>Tool/service to migrate databases – ephemeral pipeline.</i> This service connects to source databases and migrates the schema and data to target databases in Azure (e.g., Azure SQL or PostgreSQL). While it moves potentially personal data (from the source to target), it typically does not store that data long-term

		itself. It uses memory or temporary buffers to transfer records. Once migration is complete, the data lives only in the source and target databases. The DMS service is not intended to retain personal information beyond the migration process.
SQL Server enabled by Azure Arc	B	<i>Azure Arc-managed SQL Server (on-premises SQL) – no customer data in Azure by default.</i> Arc-enabled SQL Server allows registering an on-prem SQL Server with Azure for inventory and assessment. The database files remain on-premises . Azure will collect metadata (e.g., SQL instance name, performance stats) and can use services like Azure Defender for SQL to analyze security, which may result in sending some query logs to Azure. Generally, Arc for SQL does not upload the actual data. It is mostly used for managing metadata and possibly vulnerability assessment results. However, if integrated with Defender or Log Analytics, those associated services could handle query info or logs, which might include personal data.
Azure DevTest Labs	B	<i>Manages VMs for dev/test – minimal data in service, but VMs may have data.</i> DevTest Labs orchestrates creating and resetting VMs for testing. The lab service stores configuration and schedules (e.g., VM images to use, auto-shutdown times, etc.) but not the content inside the VMs. Any personal data would be within a lab VM if a tester put it there, which is outside the Lab service (it's on the VM's disk). So DevTest Labs doesn't hold personal data itself – it only manages resources that might.
Azure Lab Services	B	<i>Managed virtual lab environments (often for education) – stores minimal data, VMs hold student data.</i> Azure Lab Services allows an educator to provide VMs to students. The service itself retains lab setup info (class roster, schedules, VM templates). Student usage data (files, etc.) resides on the VMs which are Azure compute instances. Lab Services will process student names/emails to assign VMs (i.e. directory info). The primary data generated (e.g. a student's work on the VM) is on the VM's disk. The service itself doesn't store this content, but it interacts with services (VMs, identity) that do.
Microsoft Bot Framework	B	<i>SDK and tools for bots – no data storage by itself.</i> The Bot Framework is a developer SDK/collection of libraries to build bots. It's not a running service. It does not itself process or store any user data. Any such processing occurs in the bot code and the channels the code connects to (e.g., Bot Service or self-hosted infrastructure). Any data handling is either in the Bot Service (See Category C) or in the developer's own infrastructure. The framework on its own does not process personal info.

C. The service is an ephemeral service, where a function is performed but data containing personal information is never stored to disk.

Azure Service	Category	Notes / Rationale
Azure Functions	C	<i>Stateless serverless compute (ephemeral by design).</i> Function executions run in ephemeral containers where input data is processed in memory and not written to durable storage by the platform. The function code and runtime state are stored on Azure Files (outside the function service itself) and any output data goes to other services (e.g., Storage, DB). If a function writes to an external storage, see Category D concerning various storage

		services. By itself, Azure Functions performs transient processing without persisting personal data to disk.
Azure Batch	C	<i>Batch computing service – ephemeral job processing.</i> Azure Batch runs tasks on a pool of compute nodes and only stores data temporarily during processing. Input and output files persist in user-provided storage (e.g., Azure Storage) rather than within Batch itself. The Batch service performs computations without permanently storing personal data – once a job completes, the data remains only in the linked storage or on nodes (which can be auto-deleted).
Azure Container Instances	C	<i>Ephemeral containers – no default persistence.</i> ACI runs containers on demand. By default, the service does not persist data in that containers have ephemeral scratch space and are deleted on completion. Data within the container exists in memory or temp storage only unless the user connects a volume or remote storage. If the container writes to an Azure File share or disk, then that associated storage would handle the data at rest.
Azure Data Factory	C	<i>Data integration service (ETL) – ephemeral data movement (by design, no storage of customer data within the service).</i> This service orchestrates data flows from source to destination. It may briefly stage data in memory or a compute cluster during copying/transformation, but it does not save that data long-term within the service. Data flows through this service but does not persist (other than possibly small overhead like metadata, and optional debug snapshots in user's storage). The personal data being processed goes from the source to the sink that the user configures. This service is stateless for the transferred data in that it relies on integration runtimes, which also use memory/disk buffers only transiently. Once the pipeline run is done, the data rests only in the source and target stores (which are classified as Category D).
Azure Stream Analytics	C	<i>Real-time stream processing – ephemeral query results.</i> Stream Analytics jobs take event streams (from IoT Hub, Event Hubs, etc.), perform in-memory analytics, and output results to a sink (e.g., a database or blob). The streaming data is processed in memory and not written to disk by the service. The input events could contain personal data (e.g., sensor IDs, user actions), but this service does not persist each event; it emits aggregate or transformed output to wherever a client directs. Only transient state or aggregate windows are stored during computation. It is classified here as Category C because the service transforms data on the fly without long-term storage (aside from the intended output which lands in an external store).
Azure AI Services	(Varies)	<i>This is a broad category label for Azure's Cognitive Services. Specific services are listed below.</i> (No single service "Azure AI Services" – it encompasses multiple endpoints like Language, Vision, etc. Each is categorized individually.)
Azure AI Anomaly Detector	C	<i>Cognitive Service – detects anomalies in time-series; no data stored long-term.</i> The Anomaly Detector is a stateless API. A user sends the service a series of numeric data points, which typically represent some metric (e.g. user login counts per hour). The service returns anomaly results. It does not retain the time-series data after analysis.
Azure AI Services: Azure Content	C	<i>Analyzes text/images for unsafe content – ephemeral processing.</i> Content Safety evaluates text for hate, sexual content, profanity,

Safety (successor to Content Moderator)		etc., and images for adult/racy content. It returns moderation labels. It does not store the text or images submitted beyond the request. An output might include flagged terms or a hashed form of content for transparency logs, but those would typically be stored by the customer or counted in metrics. Microsoft does not keep a copy of any content evaluated.
Azure AI Services: Azure AI Immersive Reader	C	<i>Reads text aloud and highlights – processing is transient.</i> Immersive Reader takes text (which may contain personal information in them) and reads it. This service is typically running client-side (in applications) or as an API where text is sent and tokens for highlighting and audio are returned. It does not store the text in that the service is meant to immediately return an experience to the user. No content is saved on the server beyond the session.
Azure AI Services: Azure AI Language	C	<i>Language Understanding (LUIS / CLU) and other language processing – mixed, but generally ephemeral unless custom-trained.</i> Azure Language includes various NLP capabilities (i.e., sentiment, entity recognition, conversational language understanding, etc.). For prebuilt models , a client sends text and get results, with no text stored by the service beyond processing time. For custom language understanding (CLU) , clients provide sample utterances to train an app – those utterances and the model are stored for re-use. This service is more a Category D service but if only using analyzers (e.g., like sentiment analysis, key phrase extraction), then it would be placed in Category C.
Azure AI Services: Azure AI Translator	C	<i>Text translation service – ephemeral processing.</i> The Translator service translates text from one language to another. Microsoft indicates that submitted text is not stored beyond the request fulfillment (it might be used briefly to improve models in aggregate if no opt out is chosen, but not in a way that is retrievable or identifiable). The API is stateless – a user send text and then receives translated text. No persistent storage of that text on the service side (and Microsoft indicates that it does not use it for training personalized models unless a client explicitly uses Custom Translator).
Azure AI Services: Azure AI Vision	C	<i>Computer Vision API (prebuilt not custom) – ephemeral analysis of images.</i> When this service is used with an image, the image is processed in memory and not stored . Microsoft indicates that it does not keep images submitted to Computer Vision beyond the operation. The service returns results like descriptions or extracted text. If a Custom Vision model or a “read OCR async” is used, then results may be kept for retrieval for a short time. The standard Vision operations are stateless.
Azure AI Bot Service	C	<i>Bot Framework on Azure (Bot Channels Registration / Azure Bot) – does not by itself store conversation data.</i> The Azure Bot Service registers a bot and connects it to channels (e.g., Teams, Web Chat, etc.). The conversations themselves are not stored by the Bot Service ; they are relayed to the bot’s application, which may run elsewhere (e.g., in Azure Functions or App Service). Essentially, Bot Service is a message relay. It may have transient logs or transcripts if enabled by the bot developer (e.g., storing in Azure Blob or Cosmos DB) but that’s under the developer’s control in their code). The Bot Service does not automatically persist chat content. It holds only configuration (i.e., the bot endpoints, keys, etc.) and perhaps some telemetry of message delivery (non-

		content). To be noted is the fact that if the bot implementation stores anything, it would be outside this service.)
Azure Health Bot	C	<i>Healthcare-oriented bot service – ephemeral conversation, optional logging.</i> Azure Health Bot is a specialized instance of Bot Service with medical content. By default, user chats with the Health Bot are not stored by the service. The service processes the input through predefined triage dialogs and returns answers. The bot can be configured to log conversations or integrate with systems, which then would store data in those systems, but the platform itself does not keep a transcript by default. The service primarily runs in-memory but if an organization using Health Bot chooses to log conversations for quality, those logs go to their own storage, not to Microsoft's service.
Seeing AI	C	<i>AI mobile app for the visually impaired – processes data on-device or ephemeral cloud calls.</i> Seeing AI is a smartphone app (not an Azure service) that uses AI (some on-device, some via Azure services like Computer Vision) to describe the user's surroundings. The analysis of images happens either on the device or via Cognitive Services calls; either way, no data is stored on Azure servers by this app's service. Images captured by the user are analyzed in real-time and then discarded. Any personal data in the scene – e.g. a person's face being described – is not saved beyond the immediate processing.

D. The service manages customer content data at rest and therefore processes personal information.

Azure Service	Category	Notes / Rationale
Azure App Service	D	<i>Manages customer web app content at rest.</i> Web apps can store files, databases, and user data on disk (e.g. in App Service storage or connected databases), so the service processes customer data at rest.
Azure Cloud Services (classic)	D	<i>Hosts customer applications and data at rest.</i> Cloud Services (web/worker roles) run customer VMs where data can be stored on disks or in Azure Storage. Thus, customer content (files, databases) has persisted (i.e., the service handles customer data at rest).
Azure Cloud Services (Extended Support)	D	<i>Same as above – manages customer VMs/content at rest.</i> This is the newer version of Cloud Services; it also runs customer code on VMs with persistent storage. As a result, it processes customer data at rest similar to the classic model.
Azure Virtual Machines	D	<i>Infrastructure as a Service – stores customer VHDs and data.</i> VMs inherently manage customer data at rest in OS and data disks (VHDs in Azure Storage). Anything a user places on the VM's disks (files, databases, personal info) remains persisted until deleted.
Azure Virtual Machine Scale Sets	D	<i>Scaled-out VM instances – stores customer VM data.</i> Each VM in a scale set has disks and persists data in a manner similar to a single Azure VM. The service manages customer OS/data disks at rest , just at scale. (Any personal data in those VMs is stored on those disks.)
Azure Container Apps	D	<i>Managed serverless containers – stores app state if not externalized.</i> While container apps are mostly stateless, the service may use storage for revision states, and apps can mount Azure Files or bind to storage for state. The platform

		manages container runtime and can scale to zero, but if an application writes data to attached storage or stateful bindings, that data is at rest. In general, container apps infrastructure persists configuration and container images (and any app state is in user-designated storages) so personal data could be stored at rest via those bindings. (Organizations may wish to consider using external DBs for state.)
Microsoft Artifact Registry	D	<i>Artifact storage (packages, binaries) – data at rest.</i> This registry stores package files, container images, or other artifacts on behalf of the customer. While these artifacts are typically code or binaries, they are still customer data stored at rest by the service. If any personal data were included in an artifact, it would be persisted in the registry.
Azure Content Delivery Network (CDN)	D	<i>Caches customer content at edge locations (data at rest).</i> Azure CDN stores copies of files (images, scripts, etc.) on servers worldwide. Those files are “customer data at rest” on the CDN until they expire or are purged. If that content includes personal information (e.g. a user’s photo or a document), such information is stored by the CDN service.
Azure Front Door (including Front Door Classic)	D	<i>Global edge proxy and CDN – caches and processes content.</i> Front Door routes and accelerates HTTP(s) requests. It terminates client connections at the edge, which means it has access to request headers and potentially cookies or other personal info in transit (like any reverse proxy). If caching is enabled, it stores responses (which could contain personal data) on edge nodes. Even without caching, it may log details (client IP, URL, etc.) for diagnostics. Thus, Front Door may be considered as processing customer data at rest (cached objects) and in transit.
Azure Archive Storage	D	<i>Long-term cold storage for customer data.</i> Archive tier of Azure Storage stores blob data at rest for extended periods. By definition, it holds whatever data the customer places in it – potentially personal or sensitive – until deletion. Data in Archive is encrypted but remains customer data in Microsoft’s custody at rest.
Azure Backup	D	<i>Backs up VMs, files, databases – customer data at rest.</i> Azure Backup stores backup copies of your data (VM disks, SQL DBs, files) in Recovery Services vaults. Those backups inherently contain customer content (which could include personal information from the source systems) and are retained at rest until the backup expires or is deleted. Thus, the service processes and manages personal data (encrypted but stored) on Microsoft’s infrastructure.
Azure Data Box	D	<i>Physical data transfer device – holds customer data during transit.</i> In using Data Box, a customer would load the device with customer data (which could include large datasets with personal information). That data remains on the device’s drives (at rest) until it is transferred to Azure, and the device is securely wiped. While the Data Box is in Microsoft’s custody (during shipping or at the datacenter for upload), it is storing customer data at rest (even if temporarily).
Azure File Sync	D	<i>Synchronizes files from on-prem to Azure Files – data at rest.</i> The File Sync service copies files from Windows Servers to Azure Files (and optionally caches them back on servers). The primary store is Azure Files, which keeps the file data at rest in

		Azure. Sync itself also retains a metadata database (on the server and in Azure) to track changes. As a result, customer files (including any personal data within them) are stored in Azure Files via this service. File Sync does process file data (reading and transmitting it to the cloud) and the cloud endpoint (Azure Files) persists it.
Azure Files	D	<i>Fully managed file share storage – obviously stores data at rest.</i> Azure Files holds files and directories in the cloud, essentially acting as a file server. Any personal data saved in these files persists in Azure until deleted. Azure Files manages customer data at rest - with encryption and controls - but the data is there on disk in Azure.
Azure HPC Cache	D	<i>High-performance cache for on-prem NAS – stores copies of data.</i> HPC Cache takes on-premises NFS data and caches active portions in Azure for fast access. Those cached files (which could contain personal or sensitive data from the NAS) are temporarily stored on Azure Cache disks. Even though it's a cache, the data is written to disk and persisted for a time. Thus, it processes and holds customer data at rest (encrypted) within the caching service.
Azure Managed Lustre	D	<i>Managed parallel file system for HPC – stores data.</i> Azure Managed Lustre provides a Lustre filesystem backed by Azure storage. Customers write datasets (often large research or simulation data) to this system. That data is stored persistently on Azure in a connected storage account, managed by the service. If any personal data is included in those datasets, it is being processed and stored by this service at rest.
Azure NetApp Files	D	<i>Managed NAS service – stores files and volumes.</i> Azure NetApp Files is an Azure service offering NFS/SMB volumes. It holds whatever data the customer writes to those volumes – databases, unstructured files, user directories, etc. It serves as enterprise storage for workloads, so it manages customer data at rest on the provided volumes. Personal information contained in files hosted on this service, if any, is therefore stored and processed by Microsoft's service (in partnership with NetApp).
Azure Storage (Blobs, Disks, Queues, Tables, Data Lake Storage)	D	<i>Core storage services – all store customer data at rest.</i> Azure Storage encapsulates several sub-services: Blob Storage for unstructured data (documents, media), Disk Storage for VM disk files, Queue Storage for messages, Table Storage for NoSQL data, and Data Lake Storage for big data files. In each case, the service is persisting the data provided by customers onto disk in Azure datacenters. If that data contains personal information, then Azure Storage is processing and storing personal data at rest on behalf of the customer.
Azure Storage Mover	D	<i>Data migration service to Azure Storage – handles customer files.</i> Storage Mover transfers files from on-prem or other sources into Azure storage containers. In doing so it reads and streams the file contents (which may include personal data) and writes them to Azure Storage. The data is then stored in Azure (Blobs/Files) . While migrating data, the service may keep state for some information (e.g., job progress, file lists) which includes file names/paths. This would include personal information if the file names contained such information. Because it facilitates moving and storing customer data in the

		cloud, with the data ultimately residing in Azure, it is categorized as managing customer data at rest.
Azure Managed Redis (Azure Cache for Redis)	D	<i>In-memory cache that can persist data or replicate it – potentially personal data.</i> Azure Managed Redis stores key-value data on behalf of the customer in memory and can persist snapshots to disk. Often used for caching web session data or user profiles, it can contain personal identifiers, session tokens, etc. Even though it's a cache, the service holds that data in memory and possibly backups to disk as long as it's in use. Thus, it processes and temporarily stores customer data (which may include personal information) as part of normal operation.
Azure Cosmos DB	D	<i>NoSQL database – stores structured/unstructured data provided by customers.</i> Cosmos DB keeps data in various models (e.g., documents, key-value, graph, etc.) on disk across replicas. Any personal data inserted into a Cosmos collection is persistently stored and processed by Azure. Such data remains until deleted by the customer and even then, may linger in backups or multi-region replication for some time. This constitutes managing customer data at rest.
Azure Database for MariaDB	D	<i>Managed MariaDB (MySQL variant) – stores DB data.</i> Customer databases in this service contain whatever data the customer's application inserts, which may include personal records when used for apps. The service stores this data on disk in Azure with automated backups. It's a stateful database, so it processes and retains personal data at rest (the rows of the database).
Azure Database for MySQL	D	<i>Managed MySQL – stores customer database data.</i> Same reasoning as above – it's a relational database; any personal or sensitive data the customer writes in their MySQL tables persists on Azure's infrastructure . The service continuously processes that data (queries, updates) and keeps it in storage.
Azure Database for PostgreSQL	D	<i>Managed Postgres – stores customer data at rest.</i> As with the other managed databases, Postgres will hold the customer's relational data on disk. If the database includes personal data (names, emails, etc.), that information resides within the Azure-managed service. It also takes backups and may replicate to standby servers, all of which involve processing the stored data.
Azure Health Data Services	D	<i>Healthcare data platform (FHIR, DICOM, etc.) – stores highly sensitive personal health data.</i> This service manages electronic health records (via FHIR API), medical images (DICOM), and device data. It stores patient-identifiable information (e.g. patient demographics, clinical observations) in FHIR format, and medical images which often contain PHI, on Azure. All such data is customer data at rest in the cloud, regulated as personal health information. The service is explicitly designed to handle and protect personal data in healthcare scenarios.
Azure SQL (Database)	D	<i>Managed Azure SQL databases – stores data at rest.</i> Azure SQL (PaaS) holds a customer's relational database tables and data. Any personal data inserted (customer names, account info, etc.) is persistently stored in the database . Microsoft manages the hosting, so that data is under Microsoft's custody during use. This covers Single databases and Elastic Pool databases – all are stored on disk with backups in Azure.

Azure SQL Managed Instance	D	<i>Managed SQL Server instances – stores data at rest.</i> An MI is essentially a customer's own instance of SQL Server in Azure, where the customer can have multiple databases. The service stores those databases on Azure storage with high availability. Personal data in those databases is thus processed and saved within Azure. Functionally, the same data handling occurs as with Azure SQL DB, just a different deployment model.
Synapse Analytics (formerly SQL Data Warehouse)	D	<i>Analytics platform – stores big data at rest.</i> Synapse may store data in various forms (tables in dedicated SQL pools, Spark data lakes, etc.). Typically, it hosts large datasets that may include personal or sensitive information (e.g. consumer data for analytics). Any data loaded into Synapse's storage or managed tables persists in Azure . Even when used for analytics (ETL, machine learning), intermediate data may be stored. As a result, Synapse manages customer data at rest throughout its pipelines.
Azure Managed Instance for Apache Cassandra	D	<i>Managed Cassandra database – stores data at rest.</i> This service hosts Cassandra keyspaces on Azure. The data (which could include user profiles, IoT readings, etc.) is stored on disk in Azure across replicas. Customer data is retained in the Cassandra cluster until deleted. The service handles backups and replication, all involving that data.
SQL Managed Instance enabled by Azure Arc	D	<i>Azure Arc-enabled SQL MI (on customer infrastructure) – customer data remains on-prem, but with Azure management.</i> The SQL MI runs outside Azure but is managed through Azure Arc. The data itself stays on the customer's infrastructure (or chosen environment), not in Azure's datacenters. Azure Arc for data services sends telemetry and status to Azure and allows management through Azure. It may also store backups to Azure if so configured. Since Arc-enabled SQL MI can be configured to use Azure storage for backups or analytics, Azure could handle some personal data (e.g., in a backup file) but primarily data at rest is outside Azure's boundary. The Azure Arc data controller can be also considered as processing some metadata/telemetry in Azure. To the extent it is configured to permit the Azure storage of backup data, the service can be considered as processing data, including personal data. If not so configured, then this may be categorized as a Category B service.
Azure SQL Server on Virtual Machines	D	<i>SQL Server running on Azure VMs – data at rest.</i> This is basically an Azure VM with SQL Server. The VM's disks store the SQL databases. Any data in the SQL is customer data at rest on Azure's infrastructure . Microsoft's role is the provision of the VM and storage management.
Microsoft DevBox	D	<i>Cloud-hosted developer workstations – stores data like a normal PC.</i> A DevBox is essentially a Windows VM. Users can store code, documents, or test data on these cloud devices. Anything saved on the DevBox's disk is customer data at rest in Azure and could include personal data if the test data includes customer info. The DevBox service manages the lifecycle of these VM images and may capture snapshots. Because it provides a persistent personal workstation environment, it may be considered as storing any data the user works with, including personal data.

Azure Analysis Services	D	<i>Enterprise BI semantic model – stores imported data.</i> Azure Analysis Services hosts tabular models. The service processes and holds customer data in the form of analytical models . Often data from various sources (which may include personal data) is imported into the model in memory and possibly persisted in backups or cache. While the service primarily keeps data in memory while running, the entire model is under Microsoft management and can be saved to disk (e.g., during scaling down or backup). As a result, it can be considered as handling customer data at rest.
Azure Data Explorer	D	<i>Big data analytics (Kusto service) – stores ingested data.</i> Azure Data Explorer clusters ingest large volumes of data (telemetry, logs, time-series) into an engine for fast querying. That ingested data persists on disk in the cluster . Logs/telemetry may contain personal data (userIDs, device IDs, etc.). Since the service stores and indexes that data it manages customer data at rest.
Azure Data Share	D	<i>Data sharing service – distributes customer data sets (stores snapshots).</i> Data Share allows an organization to share data with other tenants or receive shared data. When using Snapshot-based sharing, the service takes a snapshot of the data (from storage) and stores it for the recipient . This results in Azure essentially copying customer data and holding it (even if encrypted) until the recipient accesses it. For in-place sharing, the service manages access to data in storage but might not copy it. Given the capability to physically move data, it may be considered as managing customer data at rest (especially for snapshot shares). The content of those shares could be personal information (e.g., a dataset of customer information being shared with a partner).
Azure HDInsight	D	<i>Managed Hadoop/Spark clusters – stores and processes big data.</i> HDInsight is a hosting service for big data computation. HDInsight clusters typically process large datasets that are stored either in WASB/Data Lake Storage or on the cluster HDFS. Customer data (which may include personal data) is handled and can be stored on the cluster nodes (e.g., intermediate Hive table data, cached RDDs on disk) as well as in an Azure Storage account. Since the VMs are managed by Microsoft, any data on them is customer data being stored/processed by an Azure service.
Healthcare data solutions in Microsoft Fabric	D	<i>Industry accelerator (Fabric) – ultimately stores health data.</i> Microsoft Fabric is a unified analytics platform. “Healthcare data solutions in Fabric” refers to templates or vertical solutions that manage healthcare datasets (patient records, etc.) using Fabric’s data lake, warehouse, and analytics features. This involves uploading and storing healthcare datasets in Fabric’s OneLake or warehouses and analyzing them. Despite being an accelerator, customer data (likely personal health information) being managed at rest in Fabric .
Microsoft Fabric	D	<i>Unified Data Analytics SaaS – stores enterprise data across lakehouse, warehouse, etc.</i> Fabric includes OneLake (a data lake storage), data warehouses, Power BI datasets, etc. All of these store customer-provided data for analytics. Any data ingested into Fabric – whether files, database rows, or reports – persists in Microsoft’s cloud storage as part of the service. Therefore, Fabric processes and holds customer data at rest.

Power BI Embedded	D	<i>Analytic reports with embedded capacity – stores data models and possibly imported data.</i> Power BI Embedded allows running Power BI reports via an Azure resource. The Power BI workspace associated with this service stores any imported data models, report definitions, and caches . If the reports use DirectQuery only, data may stay in the source, but data can be imported into Power BI to optimize reports. If that occurs, that imported data (which may include personal information aggregated for reporting) is stored at rest in the Power BI service. Therefore, Power BI Embedded processes and holds customer data at rest , similar to what occurs in standard Power BI.
AI Builder	D	<i>Power Platform AI Builder – can store training data or results.</i> AI Builder lets users train AI models by uploading datasets (images, documents) and then use the models to analyze new data. When training a model, the training data, which may have personal data (e.g., forms with names) is uploaded and stored in the AI Builder service for model learning. The trained model parameters are stored, and when the model is used, the input might be stored temporarily for processing or auditing. For example, forms processed via AI Builder could be retained for a period. By keeping the model and possibly some data for re-training or verification, the service manages customer-provided content and model data at rest
Azure AI Services	(Varies)	<i>This is a broad category label for Azure’s Cognitive Services.</i> There is no single service “Azure AI Services” – it encompasses multiple endpoints like Language, Vision, etc.
Azure AI Services: Azure AI Custom Vision	D	<i>Custom Vision (trained vision models) – stores training images and model.</i> Custom Vision allows users to upload labeled images to train a classifier or object detector. Those training images, which may contain personal info (e.g., pictures of people) are stored on the service , and the trained model is also stored for deployment. When the model is used, the service may temporarily keep images for analysis, but the main storage is retention of the training dataset and model. Depending on what the images depict, this service may handle personal data at rest.
Azure AI Services: Azure Document Intelligence (formerly Form Recognizer)	D	<i>Processes documents (often with personal data) – stores data for training and may temporarily cache results.</i> Document Intelligence has two modes: prebuilt models (for receipts, invoices, etc.) which are stateless (C), and custom trained models which require the upload of example documents . For custom models, the service stores those documents and the extracted text during the training process, and the resulting model parameters, in order to permit re-use of the model. Those documents may contain personal data (e.g., names, addresses, etc.). Even for analysis with prebuilt models, the service may keep the result or input for audit for a short period, but not long-term. Given it involves storing training data and models for custom scenarios, one may consider the service as managing customer documents at rest . If prebuilt models without training are used, this service could be classified as being a Category C service.
Azure AI Services: Azure AI Face Service	D	<i>Facial recognition service – stores biometric templates if using identification, otherwise stateless.</i> The Face service can operate in two ways. One way is “detect/verify” mode where images are

		sent to obtain attributes or comparisons Microsoft does not save the images or the face data after responding. Another way is “Identify” mode where a “Person Group” is created persist face embeddings (templates) are stored for future identification of known individuals. In the latter case, the service stores personal data by holding biometric representations of individuals’ faces with, possibly, their names/IDs attached to the image. Since it manages a store of personal identifiers and if using personal identification, Face is a Category D service. If only using detection or verification without storing faces, this would be an ephemeral Category C service.
Azure AI Services: Azure AI Metrics Advisor	D	<i>Time-series monitoring (anomaly detection with feedback)</i> – stores data and training state. Metrics Advisor ingests telemetry (metrics data) to learn the normal patterns and detect anomalies. It stores the time-series data (or a substantial summary of it) to train and continuously improve the models. It also stores feedback from users (yes/no on anomalies) to improve accuracy. If the metrics relate to individual behavior or system usage, they could indirectly contain personal data (e.g. number of logins by user segment). Even if not obviously personal information, the metric data is customer-provided and persists. As a result, the service hosts customer data (the metrics) at rest in its database. It is essentially an application of Anomaly Detector that keeps history and, because of that storage of metric data, is a Category D service.
Azure AI Services: Azure AI Personalizer	D	<i>Personalization service</i> – stores behavior logs and a learning policy. Personalizer takes context/features of a user or scenario and ranks possible outcomes, using reinforcement learning. It retains logs of events, reward scores, and a learned model to improve recommendations. Those logs can include personal identifiers or demographic info if used as features (e.g. userID, age group). The service explicitly stores this interaction data to train its personalization model. Therefore, it processes personal data (even if pseudonymized) and keeps it to continuously learn.
Azure AI Services: Azure AI Search	D	<i>Cognitive Search (formerly Azure Search)</i> – stores indexed customer content. Azure Cognitive Search indexes documents or records provided by the customer to enable search. The index holds the text/content of those documents (or a searchable representation) on Azure disk. If those documents contain personal data, that data is now stored in the Search index, which means the service is managing customer data at rest. Any AI enrichment may produce additional stored data which is also derived from customer data.
Azure AI Services: Azure AI Video Indexer	D	<i>Video Indexer</i> – analyzes videos and stores extracted insights (with potential personal data). Video Indexer processes and retains customer data (e.g., videos, images, audio, extracted text) at rest for the user’s later use. If people appear in the video, the Indexer can identify faces (using Face API) and label them. The transcripts of speech, which may have personal names or other information, are stored.
Azure AI Services: Conversational Language Understanding	D	<i>Custom conversational AI model (CLU)</i> – stores example utterances and trained model. CLU is part of Azure Language for custom intent/entity recognition in conversations. The service stores these utterances and the machine learning model derived from them. Users upload example utterances

		(which may include parts of user queries that contain personal context) and annotate them for training purposes. It also stores any active learning improvements, so the service holds customer-provided language data at rest. Additionally, if CLU is used at runtime via an orchestration (like Bot Framework or Power Virtual Agents), conversation logs might be stored by those solutions.
Azure AI Services: Question Answering (QnA Maker)	D	<i>FAQ knowledge base service – stores the Q&A pairs (which may include customer data) and sometimes indexes documents.</i> The Question Answering service (formerly QnA Maker) stores the knowledge base of question-answer pairs that a customer provides or that it extracts from documents. These answers could contain product information, policies, or potentially personal data if someone made an FAQ containing personal information. The knowledge base is stored at rest in the service. User queries to the service are processed transiently, but the core content persists. Therefore, the service is handling customer data at rest.
Azure OpenAI Service	D	<i>Generative AI (GPT-3/4) with customer prompts – user data is temporarily stored for processing and logs.</i> The Azure OpenAI Service allows customers to submit prompts which can include personal data (e.g. ask the model questions about some internal document containing personal info). According to Microsoft, OpenAI does not use customer prompts/data to train models and retains such information only for 30 days for abuse monitoring . However, for these 30 days, the data is stored at rest (in encrypted logs) and therefore constitutes the processing and holding personal data, albeit temporarily. The content of prompts and completions can include personal data. Because it's not purely streaming, the result is that this service involves managing customer data at rest (with short retention) and therefore is a Category D service.
Azure Machine Learning Service	D	<i>Managed ML platform – stores datasets, models, experiments.</i> Azure ML persists customer-provided data (e.g., training datasets uploaded to storage, notebooks and scripts, trained model files, metrics and logs from runs) which may include data samples or derived values. Experiments and pipelines can use customer data which is stored in the Azure ML workspace's storage . Model artifacts are registered and kept for reuse. If any of that data includes personal information, Azure ML is storing and processing it. Thus, the service is classified as a Category D service.
Copilot for Service	D	<i>Dynamics 365 Customer Service Copilot – uses and stores customer service data.</i> This AI Copilot can access support tickets, knowledge base articles, and generate responses. It will process personal data present in those support records (e.g., customer names, issues) to formulate answers. The Service Copilot may also store conversation context temporarily to maintain continuity within a session. Since it's built on top of Dynamics 365 data (which contains Customer Data), it is considered as processing that data . Any intermediate analysis produced (e.g., summaries, suggestions) may be logged for quality. In handling Customer Data, at least in memory and likely logs interactions (e.g., for audit or future improvements), it is classified as a Category D service.

Copilot for Finance	D	<i>Dynamics 365 Finance Copilot – processes financial records which may include personal data.</i> This Copilot helps with finance insights (budget, forecasts) and may interact with financial documents. The Copilot will access and analyze data stored in Finance systems (ledgers, invoices) – which is customer’s business data stored at rest in the system to provide answers to queries. Financial data, in some instances, can include personal identifiers (e.g., employee names, etc.).
Microsoft 365 Copilot for Sales	D	<i>Generative AI that has access to CRM (Salesforce or Dynamics) and communication data – processes and potentially stores personal CRM data.</i> Copilot for Sales works with information such as emails, contacts, meeting transcripts and CRM records to help salespeople. Those sources may contain personal data (e.g., customer contact information, meeting notes with individuals’ names). The underlying data remains in Exchange/CRM, but Copilot is essentially an AI layer on top that actively processes that personal data to generate outputs. The Copilot will retrieve and synthesize that data to draft emails or summaries. It likely stores conversation context and user instructions transiently and may log prompts/outcomes for monitoring. To the extent that the service uses personal data within customer data at rest in M365/Dynamics, it is characterized as a Category D service.

Azure Service “Geography”. Currently, Azure global infrastructure is comprised of 400 datacenters across 70+ regions in over 140 countries. Microsoft divides its infrastructure into regions, geographies and availability zones. A **region** is a set of data centres deployed within a latency-defined perimeter and connected through a dedicated regional low-latency network. A **geography** is a discrete market, typically containing two or more regions, that preserves data residency and compliance boundaries. Geographies are fault-tolerant to withstand complete region failure through their connection to Microsoft’s dedicated high-capacity networking infrastructure. **Availability zones** are physically separate locations within an Azure region. Each Availability Zone is made up of one or more data centres equipped with independent power, cooling and networking.

Microsoft publishes and publicly maintains a detailed listing of regions, geographies and availability zones for Azure services.¹³

Some Azure services use computing resources that are limited to Canada (i.e. the resources are hosted and used within Microsoft’s Canadian Data Centers). Other resources are “global” in nature, indicating that resources outside of Canada in other Microsoft data centers may be used in the provision of the service.

In the two regions located in Canada – Canada Central and Canada East – data, including personal information, is stored at rest in Canada.

Azure Hosting. All Azure services are hosted within the CO+I environment:

- CO+I implements the network layer and network layer protections. Network access to the servers is controlled by CO+I-owned and managed network devices. The configuration of the network layer/protection is managed by CO+I, which is also responsible for physical and environmental security.
- Azure hosts the machines running Azure services within the CO+I environment. These services run on Azure virtual machines. Azure is responsible for host machine operating system

¹³ The most current listings can be found at: <https://learn.microsoft.com/en-us/azure/reliability/regions-list>.

protections. Network layer protections are implemented by CO+I and are managed in coordination with Azure.

Implementation of network layer security controls between the public Internet and Azure services is provided by CO+I and/or Azure. CO+I also implements network intrusion detection and denial-of-service protection.

Azure Security. Effective security for a cloud service demands a holistic approach, which, in turn, requires careful attention to the physical, logical, network and operational aspects of the service in question. Security for the use of Azure's IaaS, PaaS and SaaS offerings involves measures both at the service level and in the form of customer controls that allows Azure customers to customize their use of Azure's services according to specific organizational requirements.¹⁴ ***This aspect emphasizes a "shared responsibility" for the protection of personal information.***

With respect to the use of cloud computing services, how Microsoft addresses security requirements are discussed in [Annex C](#).

[Remainder of page left intentionally blank.]

¹⁴ Further information about security measures and technologies for Azure can be found at: <https://docs.microsoft.com/en-us/azure/security/fundamentals/services-technologies>.

PART 3: PERSONAL INFORMATION (ELEMENTS & FLOWS)

Microsoft Azure is an online cloud platform that is made up of a large number of distinct online services. Microsoft, in offering Microsoft Azure, to organizations, performs the following functions:

1. Hosting and operation of business applications.
2. Storage, retrieval, and management of business data.
3. Authentication and access management.
4. Monitoring, logging, and security of applications and infrastructure.
5. Backup, disaster recovery, and business continuity.
6. Technical support and incident resolution (where requested).

Data Flows. Organizations that subscribe to Azure services (“Customers”) are responsible for managing the information within their subscription environment. User identifiers (e.g., full names, work emails, IP addresses) are managed by Microsoft Entra ID (formerly Azure AD) to enforce tenant isolation and control access. Azure provides mechanisms for logging access to files, applications, and data (such as Azure Diagnostics Services).

Customer access to Microsoft’s Azure services begins and ends at Internet-enabled customer locations and Microsoft datacenter. The connections established between customers and Microsoft datacenters are encrypted using FIPS 140-2-compatible Transport Layer Security (“TLS”) /Secure Sockets Layer (“SSL”). Generally, data enters the Azure environment via Azure Front Door or Application Gateway, utilizing TLS 1.2+ encryption for all data in transit.

Interactions involving the Azure Portal is encrypted using TLS 1.2 256-bit encryption. SSL/TLS is mandatory in accessing the Azure Portal or System Management API. Microsoft indicates that critical communications such as calls to the API or intra-Azure communications are encrypted and authenticated.

Data stored in Azure is owned, controlled, and accessed by the Customer. Unstructured data is commonly stored in Azure Blob Storage, while structured metadata and history is stored in an Azure SQL Database.

Microsoft indicates that it uses industry standard encryption protocols (e.g. TLS) to protect data in transit, between devices and the datacenter. All data is encrypted at rest using 256-bit AES encryption.

It should be noted that Azure customers are entirely responsible for the protection and encryption of their workflow processes surrounding data uploaded and processed within their Azure environment. Within the data center, customers can enable encryption for traffic between their own virtual machines and their end users. Customer can utilize Customer-Managed Keys stored in either Azure Key Vault or Managed HSM to maintain exclusive control over data access.

Processing occurs within logically isolated virtual machines or containers, ensuring that data from different business units or tenants remains segregated at the hypervisor level. Data can be stored in a specific Azure Region (e.g., Canada Central). It should be noted that some services may involve processing outside of Canada, so, depending on the Azure service used, it is possible for data to be stored in Canada; processing outside of Canada and then returned for storage in Canada.

The information held within Azure is, for the purposes of this FPIA, assumed to include personal information. Such personal information may be about customers, employees, contractors, or other identifiable individuals (e.g., volunteers) and is collected for Customer uses. Privacy-related obligations fall on the Customer while Microsoft acts as a data processor.

Data Layers. Data stored and processed within Microsoft Azure can be viewed from different perspectives and characterized as existing in a number of layers. They are:

1. Customer Data Layer

This layer concerns the data the Customer uploads to, generates within, or derives from, Azure services in support of business operations. Examples of information in this layer would include:

- Application data stored in Azure SQL Database, Azure Cosmos DB, Azure Blob Storage.
- Files stored in Azure Files or Azure Data Lake.
- Messages and events in Azure Service Bus or Event Hubs.
- User-generated content processed by Azure App Services.

2. Identity and Access Data Layer

This layer concerns authentication, authorization, and identity governance for users, applications, and services interacting with Azure. Examples of information in this layer would include:

- Microsoft Entra ID (Azure AD) user profiles.
- Service principals and managed identities.
- Role assignments and access control lists.
- Authentication logs and sign-in records.

Microsoft Entra ID serves as the central identity provider to manage authentication and authorization. As of October 2025, Multi-Factor Authentication ("MFA") is mandatory and enforced for all administrative actions to block credential-based compromises. Resources are organized in a hierarchical manner through management groups, subscriptions, and resource groups, allowing for granular application of security policies and Role-Based Access Control ("RBAC").

3. Telemetry, Diagnostics, and Logging Data Layer

This layer concerns operational data generated automatically by Azure services to ensure service reliability, performance, and security. Examples of information in this layer would include:

- Azure Monitor metrics.
- Application Insights telemetry.
- Activity Logs and Resource Logs.
- Crash dumps and performance traces.

4. Platform Operations and Support Data Layer

This layer concerns data processed by Microsoft for platform management, maintenance, capacity planning, and customer support. Examples of information in this layer would include:

- Support tickets and support case attachments.
- Service health incident data.
- Administrative metadata related to subscriptions and resources.

5. Management and Control Plane Data Layer

This layer concerns data required to provision, configure, and manage Azure resources through the Azure Resource Manager. Examples of information in this layer would include:

- Subscription identifiers.
- Resource names and configurations.

- Deployment templates and parameters.
- Policy assignments and compliance data.

6. Backup, Recovery, and Replication Data Layer

This layer concerns copies of customer data created for resilience, disaster recovery, and business continuity. Examples of information in this layer would include:

- Azure Backup snapshots.
- Geo-redundant storage replicas.
- Disaster recovery images.

Although not within the scope of this FPIA, another layer is the Security and Threat Intelligence Data Layer. This layer supports detection, prevention, and response to security threats affecting Azure workloads. Examples of information in this layer would include:

- Microsoft Defender for Cloud alerts.
- Security incident logs.
- Threat indicators and behavioral analytics.

When looking at Microsoft Azure from a privacy perspective, key concepts to note are:

- A Customer retains primary control over personal information within its tenant(s).
- Multiple data categories exist simultaneously (identity, content, telemetry).
- There is a clear separation between customer data and Microsoft platform data.
- Configurable controls significantly influence privacy risks.
- Cross-border data flows may occur depending on the service used, the region where the data is stored and where the data is processed by a particular service and any redundancy settings.

Data Elements within Flows. One of the constituent elements of any privacy impact assessment is a listing of the data elements to ascertain whether “personal information” is impacted by the program, service, activity or application and, if yes, what specific type of “personal information”. Note that “personal information” in Canada has generally been interpreted as being any information associated with an identifiable individual so the term may capture a large range of information.

The different types of data held within or in connection with Microsoft Azure can be characterized as:

Category	Definition	Data Types	Examples of Location(s)
Customer Data	Customer-managed storage and databases	Personal information. Business records. Files and structured data.	Azure SQL Database. Azure Cosmos DB. Azure Blob / Data Lake Storage. Managed disks.
Identity Data	Centralized identity and access management.	User profiles. Authentication credentials (hashed). Group memberships. Access roles.	Microsoft Entra ID (formerly Azure AD).
Logs and Telemetry	Operational and diagnostic data.	IP addresses. User IDs. Event timestamps. Performance metrics.	Azure Monitor. Log Analytics. Application Insights.
Backup and Recovery Stores	Secondary storage for resilience.	Encrypted replicas of customer data	Azure Backup. Geo-replicated storage.

Microsoft's Data Protection Addendum states:

"All Personal Data processed by Microsoft in connection with providing the Products and Services is obtained as part of either (a) Customer Data, (b) Professional Services Data, or (c) data generated, derived or collected by Microsoft, including data sent to Microsoft as a result of a Customer's use of service-based capabilities or obtained by Microsoft from locally installed software. Personal Data provided to Microsoft by, or on behalf of, Customer through use of the Online Service is also Customer Data. Personal Data provided to Microsoft by, or on behalf of, Customer through use of the Professional Services is also Professional Services Data. Pseudonymized identifiers may be included in data processed by Microsoft in connection with providing the Products and are also Personal Data. Any Personal Data pseudonymized, or de-identified but not anonymized, or Personal Data derived from Personal Data is also Personal Data."

"Personal Data" is defined as:

"...any information relating to an identified or identifiable natural person. An identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person."

"Customer Data" is defined as:

"...all data, including all text, sound, video, or image files, and software, that are provided to Microsoft by, or on behalf of, Customer through use of the Online Service. Customer Data does not include Professional Services Data."

"Professional Services Data" is defined as:

"...all data, including all text, sound, video, image files or software, that are provided to Microsoft, by or on behalf of a Customer (or that Customer authorizes Microsoft to obtain from a Product) or otherwise obtained or processed by or on behalf of Microsoft through an engagement with Microsoft to obtain Professional Services."

When providing Online Services, Microsoft indicates that will not use or otherwise process Customer Data or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) market research aimed at creating new functionalities, services, or products or any other purpose, unless such use or processing is in accordance with a Customer's documented instructions. Generally, the uses for which Microsoft uses such data is to provide a customer with the Products and Services and business operations incidental to such provision.

Data Elements Within Microsoft Entra ID. [Annex C](#) contains an extensive list of the attributes that would be "synced" from the on-premises Active Directory Domain Services to Microsoft Entra ID (formerly known as Azure Active Directory) if used by a Customer. These attributes form the Employee Contact Data collected by Microsoft for the provisioning of Azure services.

At a minimum, the following attributes are required for sync:

- Common name.
- member (applies only to groups).
- samAccountName (applies only to users).
- alias (applies only to groups and contacts).
- displayName (for groups with any mail or proxyAddresses attribute populated).

Most of the attributes described in [Annex C](#) are not considered “personal information” under Canadian data protection laws. However, some elements (e.g., home telephone number), if used, do constitute personal information.

Microsoft indicates that it considers the information in the table is as “business contact information” and, as such, excluded from the scope of the statutes at the federal level (PIPEDA¹⁵ and the Privacy Act¹⁶) and statutes applicable to “private sector organizations” in Alberta¹⁷, British Columbia¹⁸ and Manitoba¹⁹ as well as laws applicable to public sector organizations in British Columbia²⁰, Alberta²¹, Saskatchewan²² and Ontario²³. Any final determination of whether the data elements held within Entra ID constitutes “personal information” depends on the choices made by the Customer for the identification of employees. Customers have full control over which attributes are synchronized with Entra ID and may choose to minimize information placed in the directory. It is to be noted that Entra ID does not expose this information publicly, rather it remains accessible only to the authorized user’s community in the same customer tenant.

Data Elements Within Diagnostic Data. Microsoft collects required diagnostic data for the purpose of keeping Azure services operating. Diagnostic data contains system metadata and generally no personal information. This usually occurs in support situations. Optional diagnostic data, which can include personal information, is only collected with explicit consent and provides more detailed information for product improvement and enhanced troubleshooting.

Basic diagnostic information, used for all support cases, includes diagnostic and service-generated data. Examples of basic diagnostic information include:

- Problem description, questions, and file attachments.
- Resource health and outage events.
- Resource names and configurations.
- Service advisories related to your resources.
- Resource change history.
- Network topology.

Advanced diagnostic information, which does include Customer Data, as that term is defined in the Microsoft Data Protection Addendum (“DPA”), and may contain personal information (e.g., sign-in data from Microsoft Entra ID Directory logs or virtual machine logs). It is disabled by default and requires consent to be provided for its collection. Examples of advanced diagnostic information include:

- Logs from a virtual machine.
- Sign-in information from Azure Active Directory logs.
- Reader access for portal-based troubleshooting.
- Virtual machine console screenshots.
- Azure policy settings.
- Access control information (excluding secrets).

When a user creates a support request, the “Allow collection of advanced diagnostic information” option provides the consent to allow a Microsoft Support engineer to remotely collect data from the Azure subscription(s) associated with the request. This read-only access allows Microsoft support personnel to collect advanced diagnostic information. User can grant or revoke access at any time, and it is removed

¹⁵ See *Personal Information Protection and Electronic Documents Act*, SC 2000, c 5, s. 4.01.

¹⁶ See *Privacy Act*, RSC 1985, c P-21 s. 3(f).

¹⁷ See *Personal Information Protection Act*, SA 2003, c P-6.5, s. 1(1)(a).

¹⁸ See *Personal Information Protection Act*, SBC 2003, c 63, s. 1.

¹⁹ See *The Personal Information Protection and Identity Theft Prevention Act*, CCSM c P33.7, s. 1(1) [Not yet in force]

²⁰ See *Freedom of Information and Protection of Privacy Act*, RSBC 1996, c 165, Sch. 1.

²¹ See *Freedom of Information and Protection of Privacy Act*, s.40(1)(bb.1), RSA 2000, c F-25, s. 40(1)(bb.1)

²² See *Freedom of Information and Protection of Privacy Act*, SS 1990-91, c F-22.01, s. 24(1)(k).

²³ See *Freedom of Information and Protection of Privacy Act*, RSO 1990, c F.31, s. 2(1)(h).

automatically when a case is closed. Data provided to Microsoft during technical support for an online service is considered Professional Services Data – as that term is defined in the Microsoft DPA.

Microsoft does publicly make available (for free) a Diagnostic Data Viewer, which is a tool that allows users and administrators to see exactly what diagnostic data is being collected from their Windows devices and Microsoft 365 apps. This tool is designed for the diagnostic data from the *host operating system*. For a cloud-based system such as Azure, administrators generally use Azure Monitor Agent to collect data (e.g., performance counters and event logs), which is stored to a specified Azure Storage account or an Azure Log Analytics workspace.

[Remainder of page left intentionally blank.]

PART 4: MICROSOFT & CUSTOMER CONTRACTUAL COMMITMENTS

To meet their accountability obligations under applicable laws and/or government policies, organizations must ensure that such agreements have provisions pertaining to the protection of personal information. This is addressed in “the agreement(s)” between Microsoft and an organization²⁴ using Microsoft Azure services.

Microsoft Agreement Framework. With respect to the agreements that govern the use of Microsoft Azure, there is a conglomeration of agreements and finding which terms apply to any given Microsoft product can be challenging. Generally, a good starting point are the Product Terms which detail the availability, use terms, and privacy/security commitments for Microsoft Products and Services.²⁵

For specific service offerings, one should generally start at Product Offerings²⁶, then navigate to one of the listed Products or Online Services to view the terms that apply to its use. Generally, the most current published terms are presented, but prior versions are also available using a date selector.

Customer use of Azure services is governed by the terms and conditions under which the Client obtained those services. To get a comprehensive picture one has to consider:

- Product Terms that describe the license terms & Use Rights of Products and Services available through Microsoft Volume Licensing Programs.
- Related legal materials referenced within the Product Terms. These documents are important for Azure users and consist of a:
 - Data Protection Addendum.
 - Service Level Agreement.
 - Universal License Terms.
 - Microsoft Enterprise AI Services Code of Conduct.

Data Protection Addendum. The Data Protection Addendum²⁷ (“DPA”) sets forth the obligations of both the Customer and Microsoft with respect to the processing and security of Customer Data and Personal Data in connection with the use of Microsoft Azure offerings. The latest version considered for this FPIA is dated September 2025. The interaction between specific Product Terms and the DPA is delineated in the Privacy and Security Terms section of the Product Terms, which sets out exclusions from the DPA as well as additional commitments for Core Online Services and EU Data Boundary Services.

The DPA, which applies to Microsoft Azure services, outlines each party’s obligations with respect to the processing and security of “Customer Data”, “Professional Services Data”, and “Personal Data” by the Products. In the event of any conflict or inconsistency between the DPA and any other terms in Customer’s licensing agreement, the DPA shall prevail.

It is important to note there are exceptions to the DPA, described in the Microsoft Privacy and Security Terms²⁸, that may modify the DPA for each identified Azure service offering. For any given Azure service, one should check to see if there is any DPA exception that applies.

²⁴ In this section of the FPIA, an organization is referred to as “Customer” to be consistent with the terms used in the Microsoft agreements.

²⁵ The Product Terms are available at: <https://www.microsoft.com/licensing/terms/welcome/welcomepage>.

²⁶ Available at: <https://www.microsoft.com/licensing/terms/productoffering>.

²⁷ Available at: <https://www.microsoft.com/licensing/docs/view/Microsoft-Products-and-Services-Data-Protection-Addendum-DPA>. The Microsoft Trust Center provides more information on security, privacy, and compliance topics for customers of Azure and other Microsoft Online Services. The Service Trust Portal is a companion feature to the Trust Center that provides access to audit reports, GDPR documentation, compliance guides, and related documents.

²⁸ Available at: <https://www.microsoft.com/licensing/terms/product/PrivacyandSecurityTerms/EAEAS>.

Organizational Requirements. Given personal information protection obligations, what should customers look for in a service agreement? While acknowledging that different jurisdictions in Canada may have specific contractual requirements, a useful guide to requirements is a special investigation report, “*Reviewing the Licensing Automation System of the Ministry of Natural Resources*”²⁹ issued by the Office of the Information and Privacy Commissioner of Ontario (“IPC”). This special report considered the use of service providers and was prepared in response to a complaint about the Ministry outsourcing the issuance of hunting and fishing licenses to an American company and the associated consequence of personal information being in the United States.

The IPC considered that outsourcing was not problematic if reasonable contractual measures were taken to protect the data. The IPC noted provisions in the agreement between the Ministry of Natural Resources (“MNR”) and the service provider/agent with respect to:

- **Ownership** – Under the agreement, the Ministry confirmed that it is to be considered as the owner of all data provided by MNR to the service provider.
- **Collection, Use and Disclosure** – Pursuant to the contract, the Agent was prohibited from directly or indirectly using, collecting, or disclosing any personal information for any purposes not authorized by the Ministry.
- **Confidential Information** – Specific contractual obligations were imposed on the Agent. These obligations required the Agent to:
 - Keep the information confidential and secure.
 - Limit the disclosure of confidential information to only those who have a “need to know”.
 - Not to directly or indirectly disclose, destroy, exploit, or use any confidential information (except for the purpose of the contract, or except if required by order of a court or tribunal), without the written consent of the Ministry.
- **Notice of Compelled Disclosure** – If legally compelled to disclose any of the Ministry’s confidential information, the Agent was required to provide the MNR with prompt notice to allow it to seek a protective order or other appropriate remedy to prevent or limit such disclosure.
- **Subcontracting** – The Agent was prohibited from subcontracting all or any part of the contract without the prior written consent of the Ministry.
- **Security** – The Agent was required to:
 - Ensure the security and integrity of all personal information and records in its possession.
 - Implement, use, and maintain the most appropriate products, tools, measures, and procedures to do so.
- **Retention and Destruction** – The Agent was contractually required to return all confidential information to the Ministry before the end of the term of the contract, with no copy or portion kept by the Agent.
- **Audits** – During the life of the contract, the Agent was required to comply with annual audits for privacy and security compliance.
- **Governing law** – The governing law of the contract was required to be that of Ontario and the federal laws of Canada.

The IPC has also issued guidance to Ontario public sector entities entitled “*Thinking About Clouds? Privacy, security and compliance considerations for Ontario public sector institutions*”.³⁰ This document, in discussing required contractual terms, relied extensively on the MNR Report. While dating from 2016, its contents are still relevant and state in part:

²⁹ PC12-39 available at <https://www.ipc.on.ca/en/resources-and-decisions/reviewing-licensing-automation-system-ministry-natural-resources-special-investigation-report-pc12>.

³⁰ Available at: <https://www.ipc.on.ca/wp-content/uploads/2016/08/thinking-about-clouds-1.pdf>.

“Contract provisions are critical for ensuring the cloud service provider’s compliance with an institution’s privacy, security and access obligations. Contracts should have provisions that address:

- *Information ownership.*
- *Limits on information collection, use and disclosure.*
- *Limits on the jurisdictions in which the information may be stored.*
- *Treatment of confidential information (including personal information).*
- *Employee awareness and training.*
- *Limits on subcontracting.*
- *Security management including logging and auditing.*
- *Breach incident response, management and notification.*
- *Information retention and destruction.*
- *Periodic vulnerability assessments.*
- *The availability of audit results.*
- *Governing law and jurisdiction.*
- *Enforceable remedies for non-compliance.*

Contractual terms should include specific measurable criteria for judging whether privacy and security standards are being met. Industry standards, corporate guidelines or any other information management obligations should be reflected in contracts and SLAs to ensure that cloud providers adhere to business requirements. Cloud services should be regularly monitored and evaluated to determine whether they should be continued. Cloud service providers should also be able to supply the appropriate documentation to validate that their infrastructure and service models meet your institution’s requirements.”

Almost all of these aforementioned requirements can be seen in the contractual documentation found in Microsoft’s agreement framework, mostly in the Data Protection Addendum. [Annex D](#) provides a mapping between the DPA’s language and relevant aspects of the above list of contractual requirements.

In terms of *notice of compelled disclosure*, Microsoft contractually agrees to provide such notice if not prevented by law from doing so. For *retention and destruction*, Microsoft’s position is that Microsoft provides an “envelope” in which the customer controls retention. The customer adheres to its own retention schedules for all data within that envelope. Microsoft commits to maintaining the ability to retrieve data for 90 days following contract termination. Customers may be able to retrieve data up to 180 days following termination since the deletion process is a batch process. (See the DPA’s provisions concerning – data retention and destruction). There is no “return” of data. If a customer wants the “return” of data, or a copy of its data, it should download such information prior to service termination.

When a customer renews or purchases a new subscription to a Product or enters into a work order for a Professional Service, the then-current DPA Terms will apply and will not change during customer’s subscription for that Product or term for that Professional Service. Should a customer obtain a perpetual license to software, the then-current DPA Terms will apply (following the same provision for determining the applicable then-current Product Terms for that software in the customer’s volume licensing) and will not change during Customer’s license for that software.

Compliance with Laws. Microsoft states that it will comply with all laws and regulations applicable to its provision of the Online Services³¹ and that are applicable to information technology service providers, including security breach notification laws. Microsoft further indicates that is not responsible for

³¹ “**Online Service** means a Microsoft-hosted service to which Customer subscribes under a Microsoft volume licensing agreement, including any service identified in the Online Services section of the Product Terms. It does not include software and services provided under separate license terms (such as via gallery, marketplace, console, or dialog).”

compliance with any laws or regulations applicable to customer or customer's industry that are not generally applicable to information technology service providers.

Conversely, customers are required to comply with all laws and regulations applicable to their use of Online Services, including laws related to privacy, data protection and confidentiality of communications. **Customers are responsible for implementing and maintaining privacy protections and security measures for components that Customer provides or controls**, and for determining whether the Online Services are appropriate for storage and processing of information subject to any specific law or regulation. Customers are also responsible for responding to any request from a third-party regarding Customer's use of an Online Service, such as a request to take down content under applicable intellectual property laws.

Customer Obligations: General. Customers also have an express obligation in the DPA, which states:

"Customer is solely responsible for making an independent determination as to whether the technical and organizational measures for Products and Services meet Customer's requirements, including any of its security obligations under applicable Data Protection Requirements. Customer acknowledges and agrees that (taking into account the state of the art, the costs of implementation, and the nature, scope, context and purposes of the processing of its Personal Data as well as the risks to individuals) the security practices and policies implemented and maintained by Microsoft provide a level of security appropriate to the risk with respect to its Personal Data. Customer is responsible for implementing and maintaining privacy protections and security measures for components that Customer provides or controls (such as devices enrolled with Microsoft Intune or within a Microsoft Azure customer's virtual machine or application)."

Customer Obligations: Responsible Use of AI. To the extent Azure users employ services that have AI components, it is to be noted that there are separate contractual obligations dealing with this aspect, specifically a requirement to adhere to an Acceptable Use Policy³² and the Microsoft Enterprise AI Services Code of Conduct³³. The Universal License Terms, which apply to Azure users, states:

"Responsible Use of Microsoft AI Services

Customer must use Microsoft AI Services in accordance with the Acceptable Use Policy and the Microsoft Enterprise AI Services Code of Conduct. Without limiting its other remedies, Microsoft may limit Customer's access to or use of a Microsoft AI Service if Microsoft has a reasonable basis to believe that Customer's use of a Microsoft AI Service or Output Content violates the Acceptable Use Policy or the Microsoft Enterprise AI Services Code of Conduct.

Starter templates, instructions, and code samples that Microsoft makes available for use with Microsoft AI Services are designed to assist Customers in accelerating their development or applications and/or AI agents for specific scenarios. Customer is solely responsible for any application or AI agent it creates using or for use with Microsoft AI Services, including complying with any legal, regulatory, or licensing requirements applicable to the resulting application of AI agent or its use.

Third-party agent templates, instructions, and code samples that Microsoft makes available for use with Microsoft AI Services are Non-Microsoft Products and subject to the terms of Non-Microsoft Products."

Limited Access Services. It should also be noted that access is expressly limited to some Azure AI services.

³² The Acceptable Use Policy is part of the Universal License Terms and are available at: <https://www.microsoft.com/licensing/terms/product/ForOnlineServices/EAEAS>.

³³ Available at: <https://learn.microsoft.com/en-ca/legal/ai-code-of-conduct>.

“Limited Access Services

Certain Services (or versions thereof) require registration and are subject to limitations on access and use based on Microsoft’s eligibility and use criteria, as updated by Microsoft from time to time (“Limited Access Services”). The following Azure AI Services are Limited Access Services:

- *Azure Speech TTS custom neural voice*
- *Azure Speech custom TTS avatar*
- *Azure Vision Face*
- *Azure Vision celebrity recognition*
- *Azure Video Indexer Applied AI Service*
- *Azure Direct Models designated as Limited Access*
- *Azure Direct Models (Modified Content Filtering/Abuse Monitoring)*

NOTE: In addition to the services listed here, (i) Azure AI Services Previews may be designated, in applicable preview terms, as subject to Limited Access Services terms; and (ii) certain versions of Azure AI Services, such as versions in containers, may be designated, in product documentation or otherwise, as subject to Limited Access Services terms.

Customer may only use Limited Access Services (including when used in a Customer Solution) in accordance with the applicable Product Terms, product documentation, and these Limited Access Services terms; solely for the permitted uses specified in its registration form; and in accordance with any commitments and/or representations made in its Limited Access Services registration form. Customer will provide current, complete, and accurate information in all registration forms and other materials provided to Microsoft pursuant to these Limited Access Service terms. Microsoft may require Customer from time to time to re-verify that all information submitted to Microsoft regarding Customer and Customer’s use of the Limited Access Services remains accurate, complete, and up to date, and that Customer is using the Limited Access Services in accordance with the information submitted and these terms. Customer must respond to requests for re-verification from Microsoft within ten (10) business days of receiving a request (requests may be provided via self-certification Azure tools). If Microsoft needs additional information to assure compliance with these terms or eligibility for access to Limited Access Services, Customer will reasonably cooperate with Microsoft to provide such information within thirty (30) business days of request.

Microsoft may re-assess Customer’s eligibility to access and use Limited Access Services from time to time. If Microsoft determines that Customer no longer meets Microsoft’s eligibility and use criteria for a Limited Access Service (or that Customer does not meet eligibility and use criteria for a Service that has become a Limited Access Service), Microsoft will provide Customer with 12 months’ notice before discontinuing Customer’s access to and use of that Limited Access Service, unless security, legal, or system performance considerations require an expedited discontinuation of access. This does not apply to Previews and does not affect any other rights and remedies available to Microsoft with respect to Customer’s use of Services.

In addition to Microsoft’s right to discontinue access to and use of a Limited Access Service when Customer no longer meets Microsoft’s eligibility and use criteria (or Customer does not meet eligibility and use criteria for a Service that has become a Limited Access Service), Microsoft may limit, suspend or terminate Customer’s access to a Limited Access Services for non-compliance with any of the terms in this section (including without limitation Customer’s use of a Limited Access Service in a manner that is inconsistent with the Customer’s Limited Access Service registration form or with requirements in applicable product documentation), without advance notice but only to the extent reasonably necessary under the circumstances.”³⁴

³⁴ See the Specific Service Terms tab of the Microsoft Product Terms, available at: <https://www.microsoft.com/licensing/terms/productoffering/MicrosoftAzure/EAEAS>.

PART 5: DATA RESIDENCY

Cloud-based services and the location of data centres have raised concerns of unauthorized access to personal information by governments in other countries. The response to these concerns has centered on “data residency” – the storage of personal information within the country of origin. The EU’s data residency requirements may be considered the most prominent example of such requirements.

One important aspect to consider is what Microsoft considers to be Azure Core Services. These services are broadly classified into four categories (compute, networking, storage, and database) and are listed. Microsoft indicates that it does provision the vast majority of services from a Canadian Data Centre, however the company only commits to maintaining data at rest in Canada for “Azure Core Services.”

Because a large concern exists in Canada about potential law enforcement/national security access to personal information (arguably, in one form or another, this concern has existed since the turn of the century), some consideration is given here to American law in Section A below. Section B examines existing Canadian legal requirements about data residency.

A. Current American Law

From 2001 until 2020, the main instrument for access to business records by the American authorities was the *Uniting and Strengthening America by Providing Appropriate Tools Required to Intercept and Obstruct Terrorism Act (USA PATRIOT ACT) of 2001*³⁵, specifically section 215 of that statute which authorized access to information held by businesses pursuant to orders issued by US Foreign Intelligence Surveillance Court.

Even with the expiration of the PATRIOT Act, other provisions in U.S law – still in force - may be viewed as concerning from a privacy perspective. These are:

- FISA Section 702 (“FISA 702”) which allows US government authorities to compel disclosure of information about non-US persons located outside the US, for a period of up to one year, for the purposes of foreign intelligence information gathering. This information gathering must be approved by the U.S. Foreign Intelligence Surveillance Court. This statute is focused on communications data of targeted individuals, using specific targeting criteria, and the entities subject to FISA 702 are electronic communication service providers³⁶, which can include remote computing service providers³⁷. In the event of any for violations of FISA section 702, Canadians may seek legal redress through American legislation allowing private actions for compensatory and punitive damages.³⁸
- Executive Order 12333 (“EO 12333”), which authorizes intelligence agencies (e.g., the National Security Agency) to conduct surveillance outside of the US. EO 12333 is a general organizing directive that (i) assigns the different U.S. intelligence agencies responsibility for different types of overt and clandestine intelligence collection and counterintelligence activities, and (ii) places

³⁵ Pub. L. No. 107-56, 115 Stat. 272 (October 26, 2001) (“PATRIOT Act”). The *USA Freedom Act*, Pub. L. No. 114-23, 129 Stat. 268 (June 2, 2015), re-enacted parts of the PATRIOT Act until 2019, which were further extended until 15 March 2020, at which point they expired. With that expiration, section 215 of the PATRIOT Act no longer exists.

³⁶ As defined under 50 U.S.C § 1881(b)(4). As used in Section 702, the term “electronic communication service provider” includes communications providers (such as telephone, email, or internet service providers (ISPs)) as well as remote computing service providers that provide “computer storage or processing services” to the public. “Communications data”, as used in this document, may be generally considered the contents and associated data transacted by telephone, email and Internet service providers.

³⁷ As defined under 18 U.S.C. § 2510 and 18 U.S.C. § 2711. This arguably would include SaaS providers.

³⁸ Separate civil causes of action exist in *The Electronic Communications Privacy Act*, 18 U.S.C. § 2712 (2018), for willful violations of various FISA provisions, and the *Administrative Procedure Act*, 5 U.S.C. § 702 (2018), for unlawful government access to personal data.

restrictions on certain agencies' activities.³⁹ In particular, it provides authority for US intelligence agencies to collect foreign "signals intelligence" information, being information collected from communications and other data passed or accessible by radio, wire and other electromagnetic means. This may include accessing underwater cables carrying internet data in transit to the US. This order does not - on its own - authorize the U.S. government to require any company or person to disclose data. Instead, EO 12333 must rely on an existing statute to collect data.

- The CLOUD Act, which governs how law enforcement agencies may obtain information held by certain technology companies, including Software-as-a-Service ("SaaS") service providers.⁴⁰ This statute only permits U.S. government agencies access to data in criminal investigations after obtaining a warrant approved by a court, said warrant being based on probable cause of a specific criminal act. The CLOUD Act does not allow U.S. government agencies access in national security investigations, nor does it not permit bulk surveillance.

It is to be emphasized that the CLOUD Act does not provide any new authority for law enforcement or national security agencies to obtain data but, instead, simply applies existing U.S. requirements to cloud services providers under the jurisdiction of U.S. courts. Service providers are required to comply with warrants for information stored outside the U.S. if the information is within the custody, control, or possession of the provider. These requirements, however, are also subject to comity protections that exist under the common law. These protections permit providers to challenge law enforcement/national security demands for data under the CLOUD Act if doing so would violate another country's laws.

Microsoft Position. Microsoft indicates⁴¹ that it is sensitive to these types of concerns. It has stated that:

- Microsoft reviews every legal demand to ensure it is valid and complies with applicable laws. A subpoena or its local equivalent is required to request non-content data, and a warrant or its local equivalent is required for content data.
- Microsoft discloses customer data only when legally compelled to do so.
- Microsoft does not provide any government with direct or unfettered access to customer data.
- Microsoft does not provide any government with its encryption keys or the ability to break its encryption.

Microsoft publishes, twice a year, a report on the number of legal demands for customer data that it receives from governments around the world.

B. Current Canadian Law

Introduction. As a starting point, it is important to note that storage and processing can be separate and distinct functions performed by a cloud-based service provider. In this FPIA, "storage" refers to the holding of data at rest by Microsoft in one or more specific geographical locations. "Processing" refers the act of processing or analyzing data for particular purposes.

Certain – but not all - Canadian jurisdictions have specific legislation provisions concerning access by non-Canadian authorities to organizational data that (i) contains personal information and (ii) is held by

³⁹ As an example of restrictions, the CIA is permitted to collect foreign intelligence but prohibited from performing internal security functions or engaging in electronic surveillance (with limited exceptions) within the United States. See EO 12333 §§ 1.7(a)(1)-(2), 2.4(a).

⁴⁰ Enacted on 23 March 2018, the *Clarifying Lawful Overseas Use of Data ("CLOUD") Act* amended the Electronic Communications Privacy Act. See the *Consolidated Appropriations Act, 2018*, Pub. L. No. 115-141 (March 23, 2018), Division V, CLOUD Act (amending the Electronic Communications Privacy Act, 18 U.S.C. 2701 et seq.).

⁴¹ See <https://www.microsoft.com/en-us/corporate-responsibility/reports/government-requests/customer-data> for an extensive FAQ on American law and how Microsoft responds to such request.

cloud-based service providers. For ease of reference, because of their scope, these statutes are classified in three categories:

- *Public sector*, where the legislation is applicable to government institutions (e.g., government departments or agencies) or institutions that receive significant government funding (e.g., post-secondary educational institutions).
- *Private sector*, where the legislation is applicable to non-government entities engaged in the processing of personal information for commercial purposes.
- *Health sector*, where the legislation is applicable to healthcare providers and healthcare institutions or other entities processing personal health information.

Because of its impact on many organizations in Canada, also included is a section pertaining the interpretation of PIPEDA with respect to “access” by service providers based outside of Canada.

Public Sector

Public Sector - British Columbia. Public bodies in British Columbia must complete an assessment when sensitive personal information is disclosed and/or stored outside of Canada⁴². The level of sensitivity will depend on the type of personal information involved, the context as to why it is stored or processed outside of Canada and how it is handled. Sensitive personal information is not defined in the province’s *Freedom of Information and Protection of Privacy Act*⁴³ (“FOIPPA”), but provincial guidance indicates that such information includes, but is not limited to:

- Personal health information.
- Genetic and biometric data.
- Personal financial information.
- Geolocation data.
- Criminal records.
- Racial or ethnic origin.
- Sexual orientation.
- Religious, philosophical, or political beliefs.

As an additional aspect to consider, information not normally considered sensitive may be found to be sensitive, depending on the factual context.

The result of any such assessment will be a risk-based decision made by the head of the public body on whether to proceed with the project, taking the following into account (i) the nature and degree of risk to an individual’s privacy; (ii) the mitigation of any identified privacy risks and (iii) the nature of any identified residual risk.

Public Sector - Alberta. Under Alberta’s *Protection of Privacy Act*⁴⁴ disclosure by public bodies is permitted only “for the purpose of complying with a subpoena, warrant or order issued or made by a court, person or body having jurisdiction in Alberta to compel the production of information or with a rule of court binding in Alberta that relates to the production of information”⁴⁵.

Coupled with this restriction is a provision in the statute that makes it an offence for a person to “willfully disclose personal information pursuant to a subpoena, warrant or order issued or made by a court, person or body having no jurisdiction in Alberta to compel the production of information or pursuant to a rule of court that is not binding in Alberta.”

⁴² An assessment is not required if FOIPPA section 33(2)(f) applies. This section authorizes a public body to disclose personal information if the information is made available to the public under an enactment that authorizes or requires the information to be made public.

⁴³ RSBC 1996, c 165.

⁴⁴ SA 2024, c P-28.5.

⁴⁵ See s. 60(3) of POPA.

Public Sector - Ontario. Public sector institutions are not subject to specific legislation concerning foreign access to personal information in their custody or control. However, significant guidance is provided in the IPC special investigation report, “*Reviewing the Licensing Automation System of the Ministry of Natural Resources*”, discussed in [Part 4](#). With respect to personal information being stored in the United States, the IPC considered that the storage of personal information outside Canada was permissible provided that reasonable contractual measures were taken to protect the data.

Public Sector – Québec. Québec institutions are subject to *An Act Respecting Access To Documents Held By Public Bodies And The Protection Of Personal Information*⁴⁶. This statute contains a similar provision to that found in the Private Sector Law (see below).

Public Sector – Nova Scotia. Nova Scotia made major changes to its public sector access and privacy legislation in 2025. Relevant to data residency is the fact that the *Personal Information International Disclosure Protection Act*⁴⁷ was repealed with aspects of the legislation folded into the revamped *Freedom of Information and Protection of Privacy Act*⁴⁸ (“FOIPPA-NS”) that came into force in October 2025.

Under the 2025 legislation, a public body may not disclose or store personal information in its custody or under its control outside of Canada or permit such information to be accessed from outside of Canada, unless the disclosure, storage or access is in accordance with the regulations.⁴⁹

Public Sector – Canada. The *Privacy Act*⁵⁰ applies to federal institutions or other entities listed in a schedule to the Act. The statute does not contain any formal provisions that require personal information holdings, held by federal institutions, to be retained in Canada. However, it is to be noted that the federal government’s Directive on Service and Digital⁵¹ states that the Departmental CIO is responsible for:

“Ensuring computing facilities located within the geographic boundaries of Canada or within the premises of a Government of Canada department located abroad, such as a diplomatic or consular mission, be identified and evaluated as a principal delivery option for all sensitive electronic information and data under government control that has been categorized as Protected B, Protected C or is Classified.”

Private Sector

Private Sector - Alberta. Alberta’s *Personal Information Protection Act*⁵² was amended in 2009⁵³ to require an organization - using a service provider outside Canada to collect, use, disclose or store personal information for or on its behalf - to publish, in its policy or practice statement, information as to which countries outside Canada this activity occurs and what purposes the service provider is allowed to use the information.⁵⁴

Notice must be made before or at the time of collection or transfer, in writing or orally, and indicate how an individual may obtain access to written information about the organization’s policies and practices with respect to service providers outside Canada and who within the organization can answer questions about the service provider’s activities.⁵⁵ This requirements concern only those situations where the subject individual has provided consent for the initial collection and use of his or her personal information.

⁴⁶ RSQ, c A-2.1. See s. 70.1.

⁴⁷ SNS 2006, c. 3.

⁴⁸ SNS 2025, c 13

⁴⁹ See s. 76 of FOIPPA-NS.

⁵⁰ RSC 1985, c P-21.

⁵¹ Located at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32601>. See Section 4.4.3.14.

⁵² SA 2003 c P-6.5.

⁵³ See *Personal Information Protection Amendment Act, 2009*, S.A, 2009 c. 50.

⁵⁴ S. 6(2).

⁵⁵ S. 13.1.

Private Sector - Manitoba. Manitoba has enacted the *Personal Information Protection and Identity Theft Prevention Act*⁵⁶. As of December 2025, the statute is not yet in force and does not contain any provisions concerning the retention of personal information in Canada.

Private Sector - Québec. A private sector organization must inform individuals, from whom personal information has been collected, of the possibility that this information may be disclosed outside Québec. This notice must be provided at the time of collection and upon request⁵⁷

An organization, if it wants to transfer personal information outside Québec, “must conduct an assessment of privacy-related factors”. Such an assessment is to consider the:

- Sensitivity of the information.
- Purposes for which it is to be used.
- Protection measures that would apply to the information.
- Legal framework applicable in the State to which the information would be communicated, including the legal framework’s degree of equivalency with the personal information protection principles applicable in Québec.⁵⁸

The personal information may be communicated outside of Québec if the assessment determines that said information would receive adequate protection.

In connection with any such transfer, the organization must enter into a written agreement with the third party that considers the results of the assessment and any terms and conditions to mitigate the risks identified in the assessment⁵⁹. Provisions of such service agreements are to, at a minimum, must:

- Specify the measures to protect the confidentiality of the personal information.
- Ensure use is limited to the performance of services.
Ensure destruction or return following the end of the contract.
- Require prompt notification in the event of an actual or suspected data incident or breach.
- Permit any verification relating to confidentiality requirements.⁶⁰

If it is determined that information processed outside of Canada by a service provider will be sufficiently protected with a contract that incorporates the requirements of section 18.3 of the Act, no further action will be necessary. If this is not the case, then the parties are required to agree on measures to reduce that risk.

Private Sector - Canada. While under active consideration by the federal government for substantial revision, the *Personal Information Protection and Electronic Documents Act*⁶¹ (“PIPEDA”), as of December 2025, remains in force. The statute applies to the “federal private sector” (i.e. works, understandings or businesses) as well as other private sector entities engaged in commercial activities but only in jurisdictions in Canada that do not have legislation that has been designated “substantially similar”.

“Substantially similar” statutes concerning the private sector has been recognized by the federal government to exist in British Columbia, Alberta, and Québec. Also, personal health information protection statutes in Ontario, New Brunswick, Nova Scotia and Newfoundland & Labrador have received similar recognition.

PIPEDA does not contain any provisions that place restrictions on the location of personal information

⁵⁶ CCSM c P33.7. Not in force at the time of this assessment.

⁵⁷ Act respecting the protection of personal information in the private sector, CQLR c P-39.1, s 8, para 2.

⁵⁸ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 17.

⁵⁹ Act respecting the protection of personal information in the private sector, CQLR c P-39.1, s 17, para 2.

⁶⁰ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s 18.3.

⁶¹ SC 2000, c 5.

held by private sector organizations. However, Schedule 1 of PIPEDA and, in particular, Principle 4.1.3 provides:

“An organization is responsible for personal information in its possession or custody, including information that has been transferred to a third party for processing. The organization shall use contractual or other means to provide a comparable level of protection while the information is being processed by a third party.”

In considering the interpretation and application of Principle 4.1.3 in the context of cross-border data flows, the OPC has issued three findings. While not binding precedents, they nonetheless reflect the Office's views on the subject and are influential with respect to how private sector entities act with respect to the use of service providers outside of Canada.

Case 2005-313⁶² concerned a bank sending a notification to its VISA customers amending the credit cardholder agreement. The notification referred to the use of a service provider located in the United States and the possibility that American law enforcement or regulatory agencies being able to obtain access to cardholders' personal information under U.S. law.

The OPC determined that PIPEDA does not prohibit the use of foreign-based third-party service providers and the bank, in keeping with its obligations under Principle 4.1.3, had imposed contractual requirements concerning confidentiality and security with its third-party service providers. Any transfer to a service provider is a management exercise requiring an assessment of security risks. The Privacy Commissioner's finding noted that the personal information of Canadians in the possession of a service provider outside of Canada is subject to the laws of the country in which it is located.

The Privacy Commissioner's position was that transparency was required: any organization having personal information processed outside of Canada should notify its customers that the information may be available to government authorities under a lawful order made in that country. Because the bank in question provided such notification, indicating to customers that their personal information might be accessed under the provisions of applicable legislation while in the possession of a U.S.-based service provider, the bank had complied with PIPEDA.

Finding 2006-333⁶³ involved a security system provider, a Canadian subsidiary of a U.S. company, which had advised its Canadian customers that it intended to share customer contact information with its parent company by routing incoming home security alarm signals through another monitoring centre in North America. The only personal information shared would be information needed to provide monitoring and security services, such as the customers' home or business addresses, a phone number, and an emergency contact list.

Since the company sent out a notification explaining what it was doing with customers' personal information, the OPC concluded that the obligation under PIPEDA Principle 4.8⁶⁴ was satisfied because the company readily made available specific information about its policies and practices relating to the management of personal information.

Finding 2008-394⁶⁵, involved a website's e-mail operations that were outsourced to a U.S.-based firm. Existing subscribers were informed in advance that their new login to their account would be an opportunity for them to accept or reject the terms of the services. New e-mail subscribers were also

⁶² Available at: <https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2005/pipeda-2005-313/>.

⁶³ Available at: <https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2006/pipeda-2006-333/>.

⁶⁴ Principle 4.8 concerns Openness and states: “An organization shall make readily available to individuals specific information about its policies and practices relating to the management of personal information.”

⁶⁵ Available at: <https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2008/pipeda-2008-394/>.

informed, not only of information transfers to the U.S.-based provider but also the potential privacy implications.

The Privacy Commissioner rejected the complaints against the website owner insofar as the email provider had fulfilled its obligations to provide comparable protection under the Act by putting in place adequate contractual provisions. In this case, the Privacy Commissioner's position was re-iterated on two key points:

"Organizations must be transparent about their personal information handling practices. A company in Canada that outsources personal information processing to a company that operates in another country should notify its customers that the information may be available to the government of that country or its agencies under a lawful order made in that country."

"With regard to the issue of customer consent, the Office has taken the position that the sharing of information with a third-party service provider constitutes a "use" for the purposes of the Act. Organizations obtain customer consent for the use of personal information for the provision of services or products when individuals first apply for the service or product. Although service providers may change over time, if the purpose of the current provider's use of the personal information has remained the same, organizations are not required to obtain renewed customer consent for the information use."

Health Sector

Health Sector - Alberta. Alberta's *Health Information Act*⁶⁶:

- Prohibits compelling a witness to testify or compelling the production of documents unless such direction was made by a Canadian court or tribunal.
- Requires health information to only be disclosed under an order, warrant or subpoena issued by a court person or body that has jurisdiction in Alberta.
- Supports these restrictions with specific penalties for any contravention of these requirements.

Health Sector - Manitoba. Manitoba's *Personal Health Information Act*⁶⁷ authorizes the Lieutenant Governor-in-Council to make regulations governing the disclosure of personal health information to persons or bodies outside Manitoba. As of the writing of this assessment, no specific regulations have been promulgated and the *Personal Health Information Regulation*⁶⁸ contains no provisions concerning the subject of cross-border or cross-boundary transfers or disclosures.

Health Sector - Ontario. Ontario's *Personal Health Information Protection Act*⁶⁹ ("PHIPA") prohibits of "disclosures" outside of the province unless under certain circumstances. These circumstances are:

- The disclosure is permitted by the PHIPA or the regulations under that statute.
- The recipient performs functions similar to the functions performed by a person within the province to whom this disclosure is permitted under subsection 40(2) of PHIPA.
- The disclosure is for the purpose of health planning or health administration.
- The information relates to health care provided in the province to a person who is a resident of another province or territory of Canada
- The disclosure is made to the government of that other province or territory of Canada.
- The disclosure is reasonably necessary for the provision of health care to the individual, and the individual has not expressly instructed the custodian not to make the disclosure in its entirety.
- The disclosure is reasonably necessary for the payment for the provision of health care to the individual.

⁶⁶ RSA 2000, c H-5

⁶⁷ CCSM c P33.5, s. 66(1)(l).

⁶⁸ Man Reg 245/97.

⁶⁹ SO 2004, c 3, Sch A.

- The subject of the information consents to the disclosure.

Where a health information custodian discloses personal health information for healthcare purposes and the subject individual has instructed that not all the personal health information be disclosed, the recipient of the limited personal health information is to be apprised of the existence of the instruction and the limited disclosure.⁷⁰

Health Sector - New Brunswick. New Brunswick's *Personal Health Information Privacy and Access Act*⁷¹, unless otherwise indicated in the legislation, requires the express consent of an individual in relation to the collection, use or disclosure of his or her personal health information by a custodian, including when the custodian discloses information to a person outside New Brunswick.

Information managers providing a public body with information management or information technology services may store personal health information in their custody or in their control outside Canada.⁷²

Health Sector - Nova Scotia. The *Personal Health Information Act*⁷³ qualifies the ability of custodians to transfer personal health information. The requirements for any transfer are identical to those found in Ontario's PHIPA.

Health Sector - Newfoundland and Labrador. The *Personal Health Information Act*⁷⁴ requires a custodian to ensure compliance with the Act with respect to storage, transfer, copying, modification, use and disposition of personal information whether within or outside the province. Section 13(2) of the statute specifically imposes an obligation to protect the confidentiality of personal health information stored, used, or disclosed outside the province and the privacy of the subject individual. The disclosure of personal health information to a person outside the province is expressly prohibited unless specific requirements are met.⁷⁵ These requirements are identical to those found in Ontario's PHIPA⁷⁶.

Health Sector - Prince Edward Island. The *Health Information Act*⁷⁷ specified that a custodian may only disclose personal health information to a person outside the province without the consent of the subject individual only in certain circumstances as permitted under the statute.

[Remainder of page left intentionally blank.]

⁷⁰ See PHIPA, s. 50(2).

⁷¹ SNB 2009, c P-7.05, s. 19.

⁷² General Regulation, NB Reg 2010-112, s 22.

⁷³ SNS 2010, c 41, S. 44

⁷⁴ SNL 2008, c P-7.01.

⁷⁵ SNL 2008, c P-7.01, s. 47(1).

⁷⁶ SNL 2008, c P-7.01, s. 47(2).

⁷⁷ RSPEI 1988, c H-1.41, s. 35. The circumstances are as described in subsections 23(7), (10) and (13) or as specified in the regulations.

PART 6: PRIVACY ANALYSIS

Introduction. A reasonable framework for a privacy analysis involves consideration of specific legal requirements for the protection of personal information together with a “principles” analysis based on general concepts of privacy. These legal requirements are enacted in legislation and are relevant because an organization that proposes to use Microsoft Azure will collect personal information from, one or more of jurisdictions, in which such legislation has been enacted.

Personal information protection laws in Canada provide:

- Rules for the collection, use, disclosure, and security of personal information.
- A general right of access to one’s own personal information, subject to specified exceptions.
- A right to request correction or amendment of erroneous personal information.
- A process for the independent review of the decisions of personal information custodians.
- Enforcement mechanisms for contraventions of the legislation.

With respect to legislative requirements, there are six types of obligations for public sector institutions and essentially nine for private sector organizations⁷⁸. These categories of rules, and associated exceptions, form the fundamental compliance framework for Canadian institutions or organization.

Personal Information Protection Requirements	
Public Sector	Private Sector
Collection	Accountability
Accuracy	Purpose
Protection	Consent
Use	Collection
Disclosure	Use, Disclosure, Retention
Retention	Accuracy
	Safeguards
	Access
	Compliance

Table 3: Personal Information Protection Requirements

As a FPIA, several frameworks are considered in this document:

- For federal public sector organizations:
 - Legislative requirements under the *Privacy Act*⁷⁹.
- For private sector organizations:
 - Legislative requirements under the *Personal Information Protection and Electronic Documents Act*⁸⁰.
 - Legislative requirements under provincial legislation in Québec.
- For provincial public sector organizations in Ontario:
 - Legislative requirements under the *Freedom of Information and Protection of Privacy Act*⁸¹
- For health sector organizations in Ontario:
 - Legislative requirements under the *Personal Health Information Protection Act, 2004*.⁸²

⁷⁸ The federal *Personal Information Protection and Electronic Documents Act*, SC 2000, c 5 has a tenth concept of “openness”.

⁷⁹ RSC 1985, c. P-21.

⁸⁰ SC 2000, c 5.

⁸¹ RSO. 1990, c F.31

⁸² S.O. 2004, c. 3, Sched. A.

Similarly, since the OPC takes the position that there is a connection between privacy and the *Charter of Rights and Freedoms*⁸³, also included is a Charter analysis. This is, in part, because the Supreme Court of Canada has recognized that privacy interests have protection under the Charter and that the *Privacy Act* has quasi-constitutional status.⁸⁴

A. Privacy Act (Canada)

For institutions subject to the federal *Privacy Act*⁸⁵, section 4 of that statute requires an institution to have authority to collect personal information. This requirement is independent of Microsoft's receipt or holding of any personal information and is dependent on either a departmental statute or a statute authorizing a specific program or service. In the context of the *Privacy Act*, Microsoft can be characterized as a service provider to a federal institution, providing the Azure service.

Section 4 of the *Privacy Act* requires institutions to not collect personal information indiscriminately and not collect information unless it relates directly to an operating program or activity. The ultimate purposes for which the information is collected, used or disclosed for government program activities do not change as a result of any use of Microsoft Azure. Federal institutions are required by law to not collect information unless it relates directly to an operating program or activity. Aside from data for user registration and access control purposes, Microsoft does not independently collect personal information but "hosts" whatever information the organization provides. In the case of employees, even when Microsoft does collect such information it does not do so independently – it does so via the Customer seeking to enrol individual employees/contractors to allow them to use Azure services.

Microsoft does collect additional information (System Data and Professional Services Data) independently for specific identified purposes as described in the DPA, namely (i) processing to provide customer the products and services and (ii) processing for business operations incidental to those Products and Services. System Data does not contain personal information, but, depending on context, Professional Services Data may. However, to the extent that Professional Services Data includes personal information, it is collected through an express consent.

Section 8 of the *Privacy Act* provides a list of circumstances where personal information may be disclosed without the consent of the individual. Pursuant to s. 7 of the *Privacy Act*, information may be used for the purposes for which it could be disclosed to the institution under subsection 8(2) of the Act. The *Privacy Act* requires that information under the control of a government institution shall not, without the consent of the individual to whom it relates, be used except for the purpose for which the information was obtained or for a use that is consistent with the purpose of the original collection.

The change in moving to the use of Azure services in the Cloud does not change the purpose for which such information is used.

For Azure services, since a contracted service provider (Microsoft) is used, there is no "disclosure" but rather a "use". An organization seeking to use Microsoft Azure services will need to assure itself that access by Microsoft personnel is controlled and limited to authorized purposes and that the security measures to prevent any other unauthorized access is in place. [Annex C](#) describes the extensive security measures that Microsoft has implemented.

Subsection 9(1) of the *Privacy Act* requires the head of institution to retain a record of any use by the institution of personal information contained in a Personal Information Bank ("PIB") for any use or purpose for which that information is disclosed, for the use or purposes not included in the statements of the uses

⁸³ See Part 1 of the The Constitution Act, 1982, Schedule B to the Canada Act 1982 (UK), 1982, c 11.

⁸⁴ The legal framework for this position can be found in *Dagg v. Canada (Minister of Finance)* [1997] 2 SCR 403; *Canada (Information Commissioner) v. Canada (Commissioner of the Royal Canadian Mounted Police)* [2003] 1 SCR 66; *Lavigne v Canada (Office of the Commissioner of Official Languages)* [2002] 2 SCR 773, and *H.J. Heinz Co. of Canada v. Canada (Attorney General)* [2006] 1 SCR 441.

⁸⁵ RSC 1985, c P-21.

and purposes in connection with the relevant information bank. To the extent that there are inconsistent uses, Subsection 9(1) requires the record to be attached to the PIB. This requirement is unrelated to Microsoft and is a customer responsibility.

The retention of the information is as specified in an organization's PIBs. Organizations using a Microsoft Azure service, always remain in the control of their information while it is safeguarded in the Microsoft Azure cloud. Customers can configure retention periods, audit logging, access controls and specialized management roles. As part of service resilience, Microsoft applies additional retention capabilities to safeguard data in the event of customer accident. This includes the maintenance of backup copies for a limited period. Microsoft either securely destroys the customer information upon termination of the service or provides a mechanism for the customer to securely destroy (hard deletion) the data. Under certain scenarios Customers may revoke encryption keys and rendering the data permanently inaccessible. System Data and Professional Services Data is subject to Microsoft retention periods.

The *Privacy Act* requires the customer to take "all reasonable steps to ensure that personal information is as accurate, up-to-date and complete as possible" to minimize, to the extent possible, the possibility that inappropriate information could be used to make a decision about an individual. Control of the information in the custody of Microsoft, because of the use of one or more Azure services, remains with the organization.

With the disclosure of personal information to third parties, a federal institution must comply with the requirements of s. 12 of the *Privacy Act*. This means that procedures are required to be in place in order to provide notices of correction to third parties to whom Personal Information has been disclosed. A record is to be kept with respect of requests for a review of errors or omissions and corrections or decisions not to correct. Addressing this requirement remains with the customer and is unrelated to Microsoft or the use of any Microsoft Azure service.

B. Provincial Public Sector Legislation - FIPPA (Ontario)

In each province of Canada, "public sector" legislation⁸⁶, is intended to prevent the unauthorized collection, use and disclosure of personal information by public institutions. Where the collection of such information is authorized and subsequently collected, these statutes provide individuals with the right to access and correct such information, especially if those institutions use the information to make program or benefit-related decisions concerning the individual. While there are variations between jurisdictions in their public sector legislation, such variations are not great and for the purposes of this FPIA, Ontario's legislation is used for the purposes of illustrating how the use of Microsoft Azure services by a provincial public sector customer may be considered under such legislation.

Ontario's *Freedom of Information and Protection of Privacy Act* ("FIPPA") has two main objectives:

- To establish a general right of access, limited only by specific exemptions and exclusions expressly identified in the Act, to all recorded information in the custody or control of institutions subject to the legislation.
- To protect the privacy of individuals with respect to personal information about themselves in the custody or under the control of those institutions.

⁸⁶ The provincial "public sector" data protection statutes are: *Freedom of Information and Protection of Privacy Act*, RSA 2000, c F-25; *Freedom of Information and Protection of Privacy Act*, RSBC 1996, c 165; *Freedom of Information and Protection of Privacy Act*, CCSM c F175; *Right to Information and Protection of Privacy Act*, SNB 2009, c R-10.6; *Access to Information and Protection of Privacy Act*, SNL 2002, c A-1.1; *Freedom of Information and Protection of Privacy Act*, SNS 2025, c 13; Ontario: *Freedom of Information and Protection of Privacy Act*, RSO. 1990, c F.31; Prince Edward Island: *Freedom of Information and Protection of Privacy Act*, RSPEI. 1988, c F-15.01; *An Act respecting access to documents held by public bodies and the protection of personal information*, RSQ, c A-2.1; *Freedom of Information and Protection of Privacy Act*, SS 1990-91, c F-22.01; *Access to Information and Protection of Privacy Act*, S.N.W.T. 1994, c 20; *Access to Information and Protection of Privacy Act (Nunavut)*, SNWT. 1994, c 20; *Access to Information and Protection of Privacy Act*, RSY 2002, c 1.

For the purposes of this FPIA, the data elements identified as Customer Data (See [Part 4](#)), are found in “records” considered to be in “in the custody or under the control” of the institution and subject to public sector data protection legislation.

Under Ontario’s FIPPA, personal information is defined as:

“recorded information about an identifiable individual, including,

(a) information relating to the race, national or ethnic origin, colour, religion, age, sex, sexual orientation or marital or family status of the individual,

(b) information relating to the education or the medical, psychiatric, psychological, criminal or employment history of the individual or information relating to financial transactions in which the individual has been involved,

(c) any identifying number, symbol or other particular assigned to the individual,

(d) the address, telephone number, fingerprints or blood type of the individual,

(e) the personal opinions or views of the individual except where they relate to another individual,
(f) correspondence sent to an institution by the individual that is implicitly or explicitly of a private or confidential nature, and replies to that correspondence that would reveal the contents of the original correspondence,

(g) the views or opinions of another individual about the individual, and

(h) the individual’s name where it appears with other personal information relating to the individual or where the disclosure of the name would reveal other personal information about the individual.”⁸⁷

In Ontario, personal information does not include (i) information about an individual who has been dead for more than thirty years or (ii) the name, title, contact information or designation of an individual that identifies the individual in a business, professional or official capacity.⁸⁸

The obligations under FIPPA may be considered as falling into seven categories, which form the fundamental framework for an institution’s compliance obligations.

Collection. FIPPA provides that an institution, or any agent or service provider, cannot collect personal information “unless the collection is expressly authorized by statute, used for the purposes of law enforcement or necessary to the proper administration of a lawfully authorized activity.”⁸⁹

FIPPA further requires that personal information be collected directly by an institution unless “another manner of collection is authorized by or under a statute.”⁹⁰ This collection-related requirement is an institutional responsibility and does not directly involve Microsoft. The nature and volume “Customer Data” to be created is determined by the institution as a user of a Microsoft Azure service. To the extent Microsoft does collect personal information from those employees of the institution (e.g., user ID data or Professional Services Data) who use Azure services, such collection may be considered as “necessary for the administration of... [the] activity”.

Microsoft’s role in providing Microsoft Azure services does not involve any direct collection of personal information from an institution’s clients.

FIPPA requires that the subject individual is to be informed of (i) the legal authority for collection; (ii) the principal purpose for the use of the personal information collected; and (iii) the title and contact information of an official who can answer questions about the collection.⁹¹ This obligation goes to the direct collection of personal information for the institution’s program or activity. This obligation is the responsibility of the institution and does not involve Microsoft.

⁸⁷ RSO 1990, c F.31, s. 2(1)

⁸⁸ RSO 1990, c F.31, s. 2(2), 2(3).

⁸⁹ FIPPA, s. 38(2).

⁹⁰ FIPPA, s. 39(1)(h).

⁹¹ FIPPA, s39(2).

FIPPA further requires “personal information under the control of the institution that is organized or intended to be retrieved by the individual’s name or by an identifying number, symbol or other particular assigned to the individual” to be included in a personal information bank.⁹² Compliance with this requirement is done through inclusion of information within the Directory of Records⁹³. This obligation is also the responsibility of the institution and does not involve Microsoft.

Use. FIPPA permits the use of personal information for (a) the purpose for which that information was obtained, compiled, or disclosed; (b) a use consistent with that purpose; or (c) with the written consent of the individual.⁹⁴ An institution needs to comply with the specific requirements⁹⁵ in its use of information collected as part of its program or service activities..

The DPA, which applies to Microsoft Azure services defines Customer Data and identified the purposes for which Microsoft “processes” such information. To the limited extent it uses Customer data, Microsoft identifies the purposes for which it uses data as being to:

- To provide Customer the Products and Services in accordance with a customer’s documented instructions.
- For business operations incident to providing the Products and Services to Customer.

“Providing the products and services” is defined in the DPA. All rights, title and interest in Customer Data and Professional Services Data remains with the institution. Microsoft explicitly expressly indicates that it will not use or otherwise process Customer Data or Professional Services Data, for:

- User profiling.
- Advertising or similar commercial purposes,
- Market research aimed at creating new functionalities, services, or products or any other purpose, unless such use or processing is pursuant to customer instructions.

The topic of subcontractors or “subprocessors” is also addressed in the DPA. To the extent that Microsoft uses third parties to provide services, Microsoft Azure users can download lists of subcontractors⁹⁶.

Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft’s Online Services contingent staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft’s Online Services

Microsoft requires their subprocessors to join the *Microsoft Supplier Security and Privacy Assurance Program*.⁹⁷ This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft.

Disclosure. An institution is prohibited from disclosing personal information to third parties (other than service providers) unless such disclosure fits within a permitted exception found in Sections 21 or 41 and 42 (1) of FIPPA and provided such disclosure is consistent with the obligations found in the any applicable legislation. The use of Microsoft Azure services does not change this obligation. Microsoft and any associated “sub-contractors” are service providers to the institution.

Microsoft indicates that will not disclose Customer Data outside of Microsoft or its controlled subsidiaries and affiliates except (1) as the customer directs, (2) as described in the Online Product and Service Terms, or (3) as required by law.

⁹² FIPPA, s. 44.

⁹³ Available at <http://www.ontario.ca/document/directory-records>.

⁹⁴ FIPPA, s. 41(1).

⁹⁵ See FIPPA, s. 41(1).

⁹⁶ The list of subprocessors is current to 8 December 2025 and is available at:

<https://servicetrust.microsoft.com/DocumentPage/3a94127b-730e-42aa-a76d-40c97246da91>.

⁹⁷ Further information is available at: <https://www.microsoft.com/en-us/procurement/supplier-contracting.aspx>.

Microsoft has indicated that it will not disclose Customer Data to law enforcement authorities unless required by law. The company's position is that if enforcement contacts Microsoft with a demand for Customer Data or Personal Data, Microsoft will attempt to redirect the law enforcement agency to request that data directly from Customer. If compelled to disclose Customer Data or Personal Data to law enforcement, Microsoft will promptly notify Customer and provide a copy of the demand unless legally prohibited from doing so.

Upon receipt of any other third-party request for Customer Data (such as requests from customer's end users), Microsoft's position is that it will promptly notify the customer unless prohibited by law or will attempt to redirect the third party to request the customer data from the customer.

Except as the customer directs or unless required by law, Microsoft's policy is not to provide any third party: (1) direct, indirect, blanket or unfettered access to Customer Data; (2) the platform encryption keys used to secure Customer Data or the ability to break such encryption; or (3) any kind of access to Customer Data if Microsoft is aware that such data is used for purposes other than those stated in the request.

As it relates to personal information, Microsoft indicates in the DPA that they will disclose personal information only

- As the Customer directs.
- As described in the DPA.
- As required by law.

Microsoft further states that should a law enforcement agency contact Microsoft, the company will attempt to redirect the law enforcement agency to request that data directly from Customer. If compelled to disclose or provide access to any Customer Data, Microsoft will promptly notify the Customer and provide a copy of the demand unless legally prohibited from doing so.

Microsoft also indicates that it keeps an accurate accounting of disclosures of information held in each system of records under its control, including date, nature, and purpose of each disclosure of a record.

Accuracy. With respect to the use of the Microsoft Azure services, the institution is responsible for processes to:

- Determine the accuracy, completeness and timeliness of the personal information held.
- Update the information if requested to do so.
- Establish a frequency period, consistent with operational requirements (i.e. which do not interfere with operations) during which personal information is updated.
- Correct erroneous data.

Microsoft has a process to allow customers to correct or amend inaccurate personal information provided to Microsoft (e.g., user account registration information).

Retention. An institution is a public body for the purposes of provincial archival legislation. In Ontario, the applicable legislation is the *Archives and Recordkeeping Act*, 2006⁹⁸. Under s. 11(1) of that statute, an institution is required to "prepare a records schedule that sets out, for each class of public records that they create or receive, the length of time the records will be retained and the disposition of the records at the end of their retention period".

A records schedule is required to:

⁹⁸ SO 2006, c 34, Sch A.

- Identify and describe the records or classes of records to which it applies.
- Specify how long the records are to be retained by the public body.
- Specify the form in which the records are to be kept.
- Identify the records or classes of records that are records of archival value.
- Specify the transfer of records of archival value at the end of their retention period to the Archives of Ontario or the continued retention of such records in accordance with an agreement between the Ministry and Archivist of Ontario and contain any other information that may be required by the Archivist.

Section 5 of FIPPA Regulation 460, made pursuant to authority in FIPPA, requires a minimum one-year retention period for personal information that has been used by an institution unless the individual to whom the information relates consents to its earlier disposal.

A Directory of Records for provincial government institutions is available for viewing online.⁹⁹ The directory describes the kinds of personal information kept by each provincial government organization.

To the extent that the use of a Microsoft Azure service may constitute result in the collection or creation of new types of information, including personal information, it is the responsibility of the institution to determine whether its entries in this Directory should be amended because of the use of the Azure OpenAI service.

With respect to Microsoft Azure services, Customer Data (as defined in the DPA) is stored in a redundant environment with robust backup, restore, and failover capabilities to enable availability, business continuity, and rapid recovery. Multiple levels of data redundancy are implemented, ranging from redundant disks to guard against local disk failure to continuous, full data replication to a geographically dispersed datacenter. All Azure services undergo an annual validation of backup/recovery practices.

Microsoft indicates that it wipes storage hard drives using a solution that is compliant with National Institute of Standards & Technology (“NIST”) guidance.¹⁰⁰ For hard drives that cannot be wiped, there is a physical destruction process that destroys them and renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

Records of hardware destruction are retained and audited through Microsoft’s ISO process. All Microsoft services utilize approved media storage and disposal management services. To the extent that there may be relevant paper documents kept, such documents are destroyed on site using approved methods at the pre-determined “end-of-lifecycle”.

Protection. The protection of information is not expressly addressed in FIPPA but obligations concerning the security of personal information may be found in its regulations and can be characterized as broad.

Section 4 of the *General Regulation*¹⁰¹ provides a requirement to put in place reasonable measures to prevent unauthorized access, while the *Disposal of Personal Information Regulation*¹⁰² (“Regulation 459”) requires any disposal of information to be done in such a manner so as to ensure it cannot be reconstructed or retrieved.

See [Annex C](#) for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support the deployed safeguards.

Microsoft provides role-based security training to personnel with assigned security roles and responsibilities. All appropriate Microsoft Staff take part in a security-training program and are recipients

⁹⁹ Available at: <https://www.ontario.ca/page/directory-records>.

¹⁰⁰ See National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

¹⁰¹ RRO 1990, Reg 460.

¹⁰² RRO 1990, Reg 459.

of periodic security awareness updates when applicable. All contractors are required to take any training determined to be appropriate to the services they provide and the role(s) they perform.

All Microsoft staff are required to enrol in a security awareness training course within the first 30 days of their employment or transfer into the organization. Annual “refresher” training is also mandated for Microsoft staff. Non-operational personnel - anyone that is involved in development and quality assurance - are also required to take the mandatory training offered by Online Services Security, as well as training associated with the operating procedures related to asset handling, incident response, and change control. Security training is also required when there is a significant change to the system environment.

Access & Correction. FIPPA provides an individual with a right of access to information held about that person by an institution.¹⁰³ Exceptions exist where there is information related to an investigation, or “third party” information (information provided by another person who may be affected by the release of information).

FIPPA also provides a right of correction to any individual regarding his or her personal information and allows an individual to request correction of personal information.¹⁰⁴ Where there is disagreement as to a proposed correction or where a correction was requested and not made, a statement of disagreement is to be attached to the information reflecting any correction that was requested but not made. Third parties are to be notified of any correction or statement of disagreement.

With respect to access to personal information held by an institution as well as an individual's right to correct that information, institutions address such access requests in accordance with FIPPA and government freedom of information procedures. A formal freedom of information request may be made in writing by completing a request form¹⁰⁵ or writing a letter and forwarding the completed request form or letter to the “Freedom of Information and Privacy Coordinator” at the applicable institution.

The use of a Microsoft Azure service will not cause any change in:

- An individual's right to access and correct personal information held by an institution.
- The way access to personal information may be provided by an institution.
- The medium by which individuals may request access to his or her personal information from an institution.
- The institution's access procedures.
- How an individual can challenge the accuracy and completeness of their personal information held by an institution.

Microsoft has a process to allow customers to correct or amend inaccurate subscriber personal information, as appropriate. Information as to how to contact Microsoft is available online and using an online web form. As for Customer Data held by Microsoft in connection with the use of a Microsoft Azure service, the features and functionality of the Azure services allow customers to remain in control of content stored within the service.

C. Provincial Health Sector Legislation – PHIPA (Ontario)

Substantively, except for Alberta¹⁰⁶, Canadian provincial health information protection legislation is very similar in nature.¹⁰⁷ In all other jurisdictions, the collection, use or disclosure of personal health information may occur either with the individual's consent or as authorized by the applicable statute.

¹⁰³ FIPPA, s. 47(1).

¹⁰⁴ FIPPA, s. 47(2).

¹⁰⁵ The form is available at the Information and Privacy Commissioner's site: <https://www.ipc.on.ca/en/resources-and-decisions/request-form-fippamfippa>.

¹⁰⁶ *Health Information Act*, RSA 2000, c H-5, ss 18 and 25.

¹⁰⁷ The significant difference under Alberta's law is that it does not require consent so long as the intended collection or use is authorized by legislation but does require it for disclosure.

Because of this national “similarity”, for the purposes of this FPIA, Ontario’s *Personal Health Information Protection Act, 2004*¹⁰⁸ (“PHIPA”) is used as the basis of this assessment.

Ontario’s PHIPA, in creating a statutory framework for the collection, use and disclosure of personal health information in Ontario, applies to the management and safeguarding of “personal health information” held by a “health information custodian” (“HIC”). A HIC is a person or organization that has custody or control of personal health information because of, or in connection with, the person’s or organization’s powers or duties and is listed in s. 3 of PHIPA. This concept of “custodian” is similarly used in other Canadian jurisdictions.

PHIPA also applies to a certain extent to “agents” of providers, and “health information network providers”. This application to service providers is another concept found in Canadian health privacy legislation (in some provinces, this role is characterized as an “information management service provider”). Such a provider is defined as an entity that processes the records of a HIC or that provides information technology services with respect to such records¹⁰⁹.

Microsoft, as a provider of Microsoft Azure services, is a not HIC for the purposes of provincial legislation. In the other provinces in which it operates it could be classified as an “information manager”; in Ontario, it could be viewed as a service provider that, because of such status, is subject to s. 10(4) of PHIPA and the associated General Regulation.

With respect to personal health information, Ontario’s IPC has offered for use by HICs the privacy impact assessment questionnaire below. The responses provided below apply in the context of Microsoft being a service provider hosting and processing Customer Data within its data centers. The use of Microsoft Azure services does not change this aspect.

Service Provider Requirements

Service Provider Requirements – PHIPA s. 10(4)		
Citation	Requirement	Comment
General, O Reg 329/04, s. 6(1) #1	“The person shall not use any personal health information to which it has access in the course of providing the services for the health information custodian except as necessary in the course of providing the services.”	Microsoft does not use any Customer Data (as defined) that contains personal health information.
General, O Reg 329/04, s. 6(1) #2	“The person shall not disclose any personal health information to which it has access in the course of providing the services for the health information custodian.”	Microsoft does not disclose the Customer Data (as defined) to third parties unless authorized or required by law. Requests for access will be referred to the HIC.
General, O Reg 329/04, s. 6(1) #3	“The person shall not permit its employees or any person acting on its	Policies and procedures enforce access controls on a “least privilege” basis for operational systems and Customer Data (See

¹⁰⁸ *Personal Health Information Protection Act, 2004*, SO 2004, c. 3, Sch A.

¹⁰⁹ See, for example, *Health Information Act*, RSA 2000, c H-5, s 66(1); *Personal Health Information Act*, CCSM, c. P33.5, s 1(1); *Personal Health Information Privacy and Access Act*, SNB 2009, c P-7.05, s 1; *Personal Health Information Act*, SNL 2008, c P-7.01, s. 2(1)(l); *Health Information Protection Act*, SS 1999, c H-0.021, s. 2(j); and *Personal Health Information Act*, SNS 2010, c 41, ss. 24, 28; *Health Information Act*, SNWT 2014, c 2, s 13; and *Health Information Privacy And Management Act*, SY 2013, c 16.

	behalf to be able to have access to the information unless the employee or person acting on its behalf agrees to comply with the restrictions that apply to the person who is subject to this subsection.”	Microsoft Security Controls in Annex C). Access to personal information is limited and restricted to supporting and operating Microsoft Azure services. Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's Online Services contingent staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft's Online Services. Microsoft requires their subprocessors to join the <i>Microsoft Supplier Security and Privacy Assurance Program</i> (“SSPA”). Microsoft indicates that this program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft. The SSPA is in place to deliver Microsoft's data processing instructions to their suppliers in the form of Microsoft's Data Protection Requirements.
--	---	---

The table below addresses questions raised in Parts A and B of the Ontario Information and Privacy Commissioner's *PHIPA Privacy Impact Assessment Questionnaire*. The questions in Part A relate to privacy management and the responses are limited to the measures implemented by Microsoft; the questions in Part B relate specifically to Microsoft Security Services.

Part A: Organizational Privacy Management

No.	Question	Yes	No	Comment
A1	Is there an organizational strategic plan or business plan that addresses privacy protection?	X		Microsoft has a mature privacy and security program, with an identified management and governance framework for both privacy and information security. Both privacy and security are addressed in a series of comprehensive policy documents.
A2	Does your organization have a written privacy policy or statement of information practices?	X		Compliance with this requirement is a customer responsibility. In terms of Microsoft providing notice to end users, Microsoft provides a Privacy Statement¹¹⁰ in which it defines what constitutes Customer Data and the purposes for which it uses such data. See also the Data Protection Addendum

¹¹⁰ Available at: <https://www.microsoft.com/en-ca/privacy/privacystatement>.

No.	Question	Yes	No	Comment
				referred to in the Online Product and Service Terms.
A3	Have privacy policies or procedures been developed for various aspects of the organization's operations?	X		See Response A2.
A4	Do the privacy policies or procedures that you identified in response to questions A2 and A3 ensure the following:			
A4a	Personal health information is collected in accordance with PHIPA and other applicable legislation.	X		The collection of personal health information is the responsibility of the HIC.
A4b	Individual consent is obtained in accordance with section 18 of PHIPA where consent is required	X		Responsibility for obtaining consent rests with the HIC. Microsoft serves as a service provider or information manager to the HIC.
A4c	A written public statement about the organization's information practices, who to contact with privacy questions or complaints, and how to obtain access or request correction of a record of personal health information is readily available to individuals, as outlined in section 16 of PHIPA.		X	The HIC, as collector of PHI, has the obligation to inform the individual as to the provider's privacy practices. Requests for access or correction, received by Microsoft, are referred to the HIC. In terms of Microsoft providing notice to end users, Microsoft publishes a Privacy Statement¹¹¹ in which it defines what constitutes Personal Data and the purposes for which it uses such data. See also the Data Protection Addendum referred to in the Online Product and Service Terms. Microsoft's Privacy Trust Centre provides information as to what constitutes Customer Data, how it is safeguarded, and who has access to it.
A4d	Individuals are entitled to request access to and correction of their own personal health information as provided for under sections 52-55 of PHIPA, subject to exceptions.	X		See Response A4c. Microsoft is a service provider/information manager to the HIC.
A4e	There is a record retention schedule for records of personal health information that outlines the minimum and maximum lengths of time personal health information may be retained as well as procedures outlining the manner by which personal health information will be		X	Record retention is the HIC's responsibility and subject to the HIC's own record retention policies. In using Microsoft Azure services, Customers may apply their own data retention policies by maintaining the data until such time as they dispose of the information. Microsoft indicates that it wipes storage hard drives using a solution that is

¹¹¹ Available at: <https://www.microsoft.com/en-ca/privacy/privacystatement>.

No.	Question	Yes	No	Comment
	securely destroyed			compliant with NIST 800-88 ¹¹² . For hard drives that cannot be wiped, there is a physical destruction process that renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.
A5	Are administrative, technical and physical safeguards in place at the organization to protect personal health information against theft, loss, unauthorized use or disclosure and unauthorized copying, modification or disposal pursuant to section 12 of PHIPA?	X		See Annex C for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support the deployed safeguards.
A6	Is there an appointed privacy contact person in the organization?	X		Compliance with this requirement is a customer responsibility.
A7	Does a reporting process exist to ensure that the organization's management is informed of any privacy compliance issues?	X		See Annex C for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support the deployed safeguards.
A8	Are senior executives actively involved in the development, implementation and/or promotion of your organization's privacy program?	X		Compliance with this requirement is a customer responsibility.
A9	Are employees or agents with access to personal health information in your organization provided training related to privacy protection?	X		Policies and procedures enforce access controls on a "least privilege" basis for operational systems and Customer Data. Access to personal information is restricted to supporting and operating Microsoft Azure services. Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft service offerings. Microsoft requires their subprocessors to join the <i>Microsoft Supplier Security and Privacy Assurance Program</i>. This program is designed to standardize and strengthen data handling practices, and

¹¹² National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

No.	Question	Yes	No	Comment
				to ensure supplier business processes and systems are consistent with those of Microsoft.
A10	Have policies and procedures been developed concerning the management of privacy breaches, including the notification of individuals when the confidentiality of their personal health information has been breached?	X		See Annex C for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support the deployed safeguards.

Part B: Project Privacy Management

No.	Question	Yes	No	Comment
B1	Has a summary of the proposed or existing information system, technology or program been prepared, including a description of the requirements for the system, technology or program and a description of how the information system, technology or program will or does meet those needs?	X		Compliance with this requirement is a customer responsibility. However, Microsoft has extensive documentation online describing the functionality of the services that are offered by Microsoft Azure.
B2	Has a listing of all Personal Health Information or data elements that will be or are collected, used or disclosed in the proposed or existing information system, technology or program been prepared?	X		Responsibility for such a listing of personal health information elements belongs to the HIC. See also Part 3 above but only to the extent the use of an Azure service involves (or contains) personal health information.
B3	Have diagrams been prepared depicting the flow of Personal Health Information in the proposed or existing information system, technology or program?		X	Not applicable. Azure services are not designed for the direct collection or use of personal health information.
B4	Have documents been prepared showing which persons, positions or employee categories will have access to which elements or records of Personal Health Information?	X		Policies and procedures enforce access controls on a “least privilege” basis for operational systems and Customer Data. Access to personal information by Microsoft personnel is restricted to operating and supporting customer use of the Microsoft Azure services.
B5	Does consent from the individual or an authorized			Compliance with this requirement is a customer responsibility. Microsoft serves

	substitute decision-maker provide the primary basis for the collection, use and disclosure of Personal Health Information for the proposed or existing information system, technology or program?	X		as either a “service provider” or an “information manager” to the HIC.
B6	Have you documented the purposes for which Personal Health Information will be or is collected, used or disclosed in the information system, technology or program?	X		Compliance with this requirement is a customer responsibility. Microsoft states in the DPA that Customer Data (as defined in the DPA) will be used only to provide the customer with the Microsoft Azure services, including purposes compatible with providing those services. Microsoft indicates that Microsoft personnel will not (i) process Customer Data without authorization from Customer or (ii) use Customer Data or derive information from it for any advertising or similar commercial purposes.
B7	Is Personal Health Information collected, used, disclosed or retained exclusively for the identified purposes and for purposes that an individual would reasonably consider consistent with those purposes?	X		See Response B6.
B8	Will Personal Health Information in the proposed or existing information system, technology or program be linked or cross-referenced to other information in other information systems technologies or programs?		X	Compliance with this requirement is a customer responsibility.
B9	Will Personal Health Information collected or used in the information system, technology or program be disclosed to any persons who are not employees or agents of the responsible organization?	X		Policies and procedures enforce access controls on a “least privilege” basis for operational systems and Customer Data. Access to personal information is restricted to supporting and operating the Microsoft Security Services. Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft’s staff must also sign a non-disclosure agreement at the time of

				engagement and before being given access to Microsoft's services. Microsoft requires their subprocessors to join the <i>Microsoft Supplier Security and Privacy Assurance Program</i>. This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft.
B10	Have you made arrangements to provide full disclosure of all purposes for which the information system, technology or program will collect Personal Health Information?		X	Compliance with this requirement is a customer responsibility. Microsoft states in the DPA that Customer Data (as defined in the DPA) will be used only to provide the customer with the Microsoft Azure services, including purposes compatible with providing those services. Microsoft personnel will not process Customer Data without authorization from Customer and will not use Customer Data or derive information from it for any advertising or similar commercial purposes.
B11	Have communications products and/or a communications plan been developed to fully explain the information system, technology or program to individuals and how their Personal Health Information will be protected?	X		Compliance with this requirement is a customer responsibility. In terms of Microsoft providing notice to end users, Microsoft publishes a Privacy Statement¹¹³ in which it defines what constitutes Customer Data and the purposes for which it uses such data.
B12	Does the proposed or existing information system, technology or program involve the collection, use or disclosure of any Personal Health Information beyond Ontario's borders?		X	This is a Customer responsibility. Customer Data stored in a Microsoft datacenter in Canada, will be stored in Canada, unless the Customer expressly decides otherwise.
B13	Has an assessment been completed to identify potential risks to the privacy of individuals whose Personal Health Information is collected, used, retained or disclosed by the proposed or existing information system, technology or program?	X		Compliance with this requirement is a customer responsibility. This FPIA is intended to support customer privacy assessments.
B14	If potential risks to privacy have been identified, have			Application, network, and physical security measures have been

¹¹³ Available at: <https://www.microsoft.com/en-ca/privacy/privacystatement>.

	means to avert or mitigate those risks been incorporated into the design and/or implementation of the proposed or existing information system, technology or program?	X		implemented. A security incident management protocol exists. See Annex C for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support the deployed safeguards.
B15	Has an assessment been completed to identify whether other health information custodians have implemented the same or a similar information system, technology or program, the risks to privacy experienced by other health information custodians and the means implemented by these other health information custodians to avert or mitigate these risks?		X	Not applicable. Compliance with this requirement is a customer responsibility.
B16	Have key stakeholders been provided with an opportunity to comment on the sufficiency of privacy protections and their implications on the proposed or existing information system, technology or program?		X	Compliance with this requirement is a customer responsibility.
B17	Will users be trained in the requirements for protecting Personal Health Information and will they be made aware of the relevant notification procedures if Personal Health Information is stolen, lost or accessed by unauthorized persons?	X		Compliance with this requirement is a customer responsibility. Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft's services.
B18	Have security policies and procedures to protect Personal Health Information against theft, loss, unauthorized use or disclosure and unauthorized copying, modification or disposal been documented?	X		See Annex C for a description of safeguard measures deployed by Microsoft as well as the audit measures used to support the deployed safeguards.
B19	Have privacy policies or procedures been developed for various aspects of the operations for the proposed or	X		Compliance with this requirement is a customer responsibility. In terms of Microsoft providing notice to end users, Microsoft publishes a Privacy

	existing information system, technology or program?			Statement ¹¹⁴ in which it defines what constitutes Customer Data and the purposes for which it uses such data.
B20	Do the privacy policies or procedures that you identified in question B19 ensure the following:			
B20a	Personal Health Information in the proposed or existing information system, technology or program is collected in accordance with <i>PHIPA</i> and other applicable legislation;	X		Compliance with this requirement is a customer responsibility.
B20b	Individual consent is obtained in accordance with section 18 of <i>PHIPA</i> for the proposed or existing information system, technology or program where consent is required;		X	Obtaining consent is the responsibility of the HIC.
B20c	A written public statement about the purposes for which the proposed or existing information system, technology or program collects, uses or discloses Personal Health Information is readily available to individuals as outlined in section 16 of <i>PHIPA</i> ;	X		Compliance with this requirement is a customer responsibility. Microsoft states in the DPA that Customer Data (as defined in the DPA) will be used only to provide the customer with the Microsoft Azure services, including purposes compatible with providing those services. Microsoft has extensive documentation online describing the functionality of the services that comprise Microsoft Azure. Microsoft personnel will not process Customer Data without authorization from Customer. Microsoft will not use Customer Data or derive information from it for any advertising or similar commercial purposes.
B20d	Individuals are entitled to request access to and correction of their own Personal Health Information in the proposed or existing information system, technology or program as provided for under sections 52-55 of <i>PHIPA</i> , subject to certain exceptions.	X		In the event such a request is received, individuals are directed to the HIC for any access or correction requests.

¹¹⁴ Available at: <https://www.microsoft.com/en-ca/privacy/privacystatement>.

B20e	There is a record retention schedule for records of Personal Health Information that outlines the minimum and maximum lengths of time Personal Health Information may be retained in the proposed or existing information system, technology or program, as well as procedures outlining the manner by which Personal Health Information in the proposed or existing information system, technology or program may be securely destroyed.		X	NA. This obligation falls upon the HIC in that decisions about record retention are made by the HIC. Microsoft has established retention periods for backup storage. Microsoft also has secure disposal procedures for storage media.
B21	Does the proposed or existing information system, technology or program provide functionality for the logging of the insertion, access, modification or disclosure of Personal Health Information as well as an interface to audit those logs for unauthorized activities?	X		See Annex C for a description of safeguard measures deployed by Microsoft as well as the audit measures to support the deployed safeguards.

D. Necessity and Proportionality Test (Charter of Rights Analysis)

For public sector organizations, there is a connection between privacy and the *Charter of Rights and Freedoms* (the “Charter”). The Supreme Court of Canada has recognized that privacy interests have protection under the Charter¹¹⁵ and the Charter’s application extends to both federal and provincial legislation and government actions, where such legislation or actions impacts the privacy interests of Canadians.

In this light, the OPC has developed a four-part test to assess the impact of initiatives on the privacy of the subject individual(s). This test was originally articulated by the Supreme Court of Canada in the 1986 decision of *R. v. Oakes*¹¹⁶ but has been adapted by the OPC for privacy purposes. Any analysis works best when considering the institution because the initial collection and subsequent use and/or disclosure of personal information is done by the institution. In providing Azure services, Microsoft is a service provider with limited access to, and use of, Customer Data.

With respect to a specific program or initiative, government institutions should demonstrate that:

- Its activities are necessary to achieve a specific and legitimate purpose.
- It is likely to be effective in achieving that purpose.
- The intrusion on privacy is proportional to the benefit to be derived.
- This course of action, among all others, is the least privacy-invasive to achieve the desired results.

¹¹⁵ The legal framework for this position can be found in *Dagg v. Canada (Minister of Finance)* [1997] 2 SCR 403; *Canada (Information Commissioner) v. Canada (Commissioner of the Royal Canadian Mounted Police)* [2003] 1 SCR 66; *Lavigne v Canada (Office of the Commissioner of Official Languages)* [2002] 2 SCR 773, and *H.J. Heinz Co. of Canada v. Canada (Attorney General)* [2006] 1 SCR 441.

¹¹⁶ [1986] 1 SCR 103.

Necessity. *Is the measure demonstrably necessary to meet a specific need? The rationale should be clear and specific.*

The question can be characterized as whether there is a rational connection between what information is sought and why. Given the nature and large variety of Microsoft Azure services, this is a determination only Azure customers can make. Microsoft is a service provider that stores and processes whatever information a customer transmits to a Microsoft data center.

Microsoft does not use or access Customer Data except for user registration and service support purposes. Given the purposes for which Microsoft may use Customer data – as stated in the DPA - there is a rational connection between the data collected by Microsoft and the need for the data.

Effectiveness. *Will the program or initiative be effective in meeting the need?*

Azure, for the most part, provides a large variety of services, enumerated in a number of categories, that are cloud-based and revolve around the application of technology resources to store, transform or analyze information collected through Customer programs or activities. The use of Azure services will be effective in meeting such needs but, in the end, questions related to the program or initiative pertain more to the Customer than Microsoft.

Proportionality. *Is the loss of privacy proportional to the need?*

Any loss of privacy depends on the information collected, used and disclosed by an institution. This aspect is fact-dependent and will depend on whether other measures have been considered and rejected as unworkable.

With respect to Microsoft's collection and use of Customer Data, Professional Services Data System Data and Diagnostic Data, such data are either accessed by Microsoft with Customer consent or is anonymized or pseudo-anonymized to remove personal information.

Minimal Intrusiveness. *Is there a less privacy-invasive way of achieving the same end?*

Institutions are to show how the collection, use and disclosure of personal information is undertaken in the least privacy invasive manner possible and requires consideration of alternatives if they exist. Microsoft serves only as a service provider to the Customer/institution.

Information being collected by Microsoft from institutional employees for authentication purposes is related to the authentication that already occurs within Entra ID Directory.

E. Private Sector Legislation – CSA Code

For private sector organizations, a privacy analysis can be conducted using the ten fair information practice principles of the Canadian Standards Association *Model Code for the Protection of Personal Information* ("Code")¹¹⁷. These principles inform not only the current federal private sector legislation but also those statutes found in British Columbia¹¹⁸, Alberta¹¹⁹ and Manitoba¹²⁰. Québec's private sector

¹¹⁷ The text of the CSA Code forms Schedule 1 to PIPEDA and is available at: http://www.canlii.org/en/ca/laws/stat/sc-2000-c-5/latest/sc-2000-c-5.html#SCHEDULE_1_121957.

¹¹⁸ *Personal Information Protection Act*, SBC 2003, c 63, available at: <https://www.canlii.org/en/bc/laws/stat/sbc-2003-c-63/latest/sbc-2003-c-63.html>.

¹¹⁹ *Personal Information Protection Act*, SA 2003, c P-6.5, available at: <https://www.canlii.org/en/ab/laws/stat/sa-2003-c-p-6.5/latest/sa-2003-c-p-6.5.html>.

¹²⁰ *The Personal Information Protection and Identity Theft Prevention Act*, CCSM c P33.7, available at: <http://www.canlii.org/en/mb/laws/stat/ccsm-c-p33.7/latest/ccsm-c-p33.7.html>. As of the date of this assessment, this legislation is not yet in force.

legislation is discussed in a separate section. For this FPIA, any analysis using the Code is modified where there are specific statutory requirements or deviations from the Code. The Code principles are:

- Accountability
- Identifying Purpose
- Consent
- Limiting Collection
- Limiting Use, Disclosure and Retention
- Accuracy
- Safeguards
- Openness
- Access
- Challenging Compliance

Accountability. An organization is responsible for personal information under its control. At a minimum, such responsibility requires the designation of one or more individuals to be accountable for the organization's compliance with the principles described in the Code. This accountability extends to information that has been transferred to a third party for processing and obliges the organization to use contractual or other means to provide a comparable level of protection while the information is being processed by that third party.

Meeting these expectations requires evidence of a mature governance and administrative structure for the organization's privacy program. This includes having risks accepted at an appropriate senior level; documenting procedures; ensuring appropriate training is conducted and refreshed regularly; including privacy protective language in all contracts with third parties handling personal information; and ensuring that that privacy compliance audits are undertaken on a regular basis.

Microsoft is a service provider to a customer in the provision of Microsoft Azure services. Because of this role, the primary responsibility for legal/privacy compliance with the Code lies with customers. To the extent that Microsoft directly collects personal information, it is accountable for such information.

Generally, a customer's privacy and access framework is (or should be) designed to provide internal policies, procedures, and an administrative structure to comply with legal obligations. Customers must determine how the information it uses - including those stored or processed using an Azure service - will nestle within their own information management regime.

Satisfying the accountability principle in the use of Microsoft Azure services means an organization must have an agreement with Microsoft that adequately addresses privacy and security requirements and identifies who is accountable for "relations" with Microsoft. See [Annex E](#) for a mapping of Microsoft's contractual commitments to recommended contractual requirements in using third party service providers.

To the extent that Microsoft makes use of third parties in connection with Azure services, Microsoft makes a list of subcontractors¹²¹ available. The DPA states Microsoft's position with respect to its responsibility for the use of contracts and what the company does to ensure their compliance with obligations similar to those that Microsoft has with its customers.

Microsoft staff are required to sign confidentiality and non-disclosure agreements, as well as the Microsoft Employee Handbook, at the time of hire as a condition for employment. All Microsoft's Online Services contingent staff must also sign a non-disclosure agreement at the time of engagement and before being given access to Microsoft's Online Services.

¹²¹ The list of subprocessors is current to 8 December 2025 and is available at: <https://servicetrust.microsoft.com/DocumentPage/3a94127b-730e-42aa-a76d-40c97246da91>.

Microsoft requires their subprocessors to join the *Microsoft Supplier Security and Privacy Assurance Program*¹²². This program is designed to standardize and strengthen data handling practices, and to ensure supplier business processes and systems are consistent with those of Microsoft.

Identifying Purpose. Where personal information is collected, the purposes are to be identified by the organization at or before the time the information is collected. The collection of personal information for permitted purposes is a customer responsibility since Microsoft has no role in the collection of Customer Data. Customers should indicate to their employees that personal information (user account registration data) will be collected by Microsoft and that Microsoft will use such data for the purposes referred to in the DPA. See **Annex E** for specific categories/definitions of data and the purposes for which Microsoft uses such data in the provision of Azure services.

Microsoft indicates in its service terms that it does not use Customer Data or derive information from it for any advertising or similar commercial purposes. Microsoft also indicates that – where it collects personal information - it uses such data to operate their business. This includes analysing performance, meeting legal obligations, developing their workforce, and conducting research.

Consent. The knowledge and consent of the individual are required for the collection, use, or disclosure of that individual's personal information. Furthermore, the reasonable expectations of the subject individual must be met as well. It is expected that such consent will usually be obtained at the time of collection and that the purposes are stated in a manner where the individual can reasonably understand the proposed use and disclosure of personal information. Under this principle, notification language on forms or websites, containing a clear description of the purpose for collection, would be expected. Consent, for private sector organizations, also requires an ability to withdraw – whether in whole or in part – such consent. With respect to employees, in Canada, consent is not required from employees but a good practice - to especially ensure compliance with provincial personal information protection legislation – would be to provide notice to employees.

The responsibility for consent remains with the customer. Microsoft, as a service provider, has no specific obligation here concerning consent. as to the nature of the tools, the scope of their deployment (e.g., all employees, only certain classes of employees or only certain locations) and the type of information collected/generated. To the extent that Microsoft collects or accesses personal information in connection with Professional Services Data, express consent prior to such collection is required.

Limiting Collection. The collection of personal information is to be limited to that which is necessary for the identified purposes. This implies an obligation to ensure that the amount and the type of information collected are strictly necessary to fulfill the stated need. Another way to describe this concept is “data minimization”.

Collection of personal information is the responsibility of the Customer. Microsoft's collection of data – with respect to the any Azure service is limited to user registration purposes, system management and support purposes. Microsoft has indicated that the data elements collected for user administration and support purposes has been the subject of a data minimization exercise to reduce the number of type of data elements to what is considered required. The number and nature of the data elements collected by Microsoft are reasonable and necessary in connection with the purposes of their collection.

Limiting Use, Disclosure and Retention. Personal information is not to be used or disclosed for purposes other than those for which it was collected, except with the consent of the individual or as required or permitted by legislation. Customers are expected to have retention schedules to meet the requirements of this principle. Once personal information is no longer required for the identified purposes it is to be securely destroyed, erased, or made anonymous.

¹²² Further information is available at: <https://www.microsoft.com/en-us/procurement/supplier-contracting.aspx>.

Disclosure. Microsoft indicates in its DPA that it will not disclose Customer Data outside of Microsoft or its controlled subsidiaries and affiliates except as indicated. See [Annex E](#) for the specific DPA text concerning the disclosure of data processed by Microsoft.

Microsoft indicates that it keeps an accurate accounting of disclosures of information held in each system of records under its control, including date, nature, and purpose of each disclosure of a record.

Retention. Microsoft allows Customers to apply their own data retention policies by maintaining the data until such time as the Customer disposes of the information. Customer Data is stored in a redundant environment with robust backup, restore, and failover capabilities to enable availability, business continuity, and rapid recovery. Multiple levels of data redundancy are implemented, ranging from (i) redundant disks to guard against local disk failure to (ii) continuous, full data replication to (iii) geographically dispersed datacenters. Microsoft, in connection with providing Azure-based services, undergoes an annual validation of backup/recovery practices.

Microsoft indicates that it wipes storage hard drives using a solution that is compliant with NIST 800-88¹²³. For hard drives that cannot be wiped, there is a physical destruction process that renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

Records of hardware destruction are retained and audited through Microsoft's ISO process. All Microsoft services utilize approved media storage and disposal management services. Paper documents are destroyed by approved means at the pre-determined end-of-life cycle.

With respect to retention, See [Annex E](#) for the for specific DPA text concerning data retention and deletion of data processed by Microsoft.

Accuracy. The concept of "accuracy" as a principle is related to "use" in that if information is used to make a decision it should be as accurate and up to date as possible to ensure that inappropriate information will not be used to make a decision about an individual.

With respect to data it collects, Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate. As for Customer Data, Microsoft Azure services are within the control of customers who may access personal data to correct it whenever necessary.

Safeguards. Personal information is to be protected by security safeguards appropriate to the sensitivity of the information. This principle requires particular care to be used for data at rest and in transit, as well as the disposal or destruction of personal information.

See [Annex C](#) for a description of safeguard measures deployed by Microsoft as well as audit measures to support the deployed safeguards.

Microsoft provides role-based security training to personnel with assigned security roles and responsibilities. All appropriate Microsoft Staff take part in a security-training program and are recipients of periodic security awareness updates when applicable. All contract staff are required to take any training determined to be appropriate to the services being provided and the role they perform.

All staff are required to enroll in a security awareness training course within the first 30 days of their employment or transfer into the organization. Non-operational personnel - anyone that is involved in development and quality assurance - are also required to take the mandatory training offered by Online Services Security, as well as training associated with the operational procedures related to asset handling, incident response, and change control. Security training is also required when there is a significant change to the system environment.

¹²³ National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

With respect to safeguards, see [Annex E](#) for specific DPA text concerning data security and breach notification for data processed by Microsoft.

Openness. Organizations are to be open about their policies and practices with respect to the management of personal information. Descriptions of such policies and practices are to be made available in a form that is generally understandable.

The information made available shall include:

- The name/title and address of the person who is accountable for the personal information policies and practices and to whom complaints or inquiries or requests for recourse can be forwarded.
- The means of gaining access to personal information.
- A description of the type of personal information held including an account of its use.
- Information that explains the policies and procedures surrounding the use of personal information.

Compliance with the openness principle is a customer responsibility. In terms of Microsoft providing notice to end users, Microsoft publishes a Privacy Statement¹²⁴ in which it defines what constitutes Customer Data and the purposes for which it uses such data.

Access. Individuals have a right to access their own personal information and to request that corrections be made. The features and functionality of the various services provided by Microsoft Azure allow customers to remain in control of Customer Data stored in the Customer's tenant. The use of Azure service will not cause any change in:

- An individual's right to access and correct personal information.
- The way access to personal information may be provided by an organization.
- The medium by which individuals may request access to his or her personal information held by an organization.
- The Customer's access procedures.
- How an individual can challenge the accuracy and completeness of his or her personal information held by the Customer.

With respect to the information it collects, Microsoft has a process to allow customers to correct or amend inaccurate subscriber personal information, as appropriate. Information as to how to contact Microsoft is available through the Online Privacy Statement and through an online web form.

Microsoft has a process to allow customers to correct or amend inaccurate subscriber personal information, as appropriate.

Challenging Compliance. Organizations are required to have procedures in place to address complaints or inquiries pertaining to the handling of personal information. The complaint process is to be easily accessible and simple to use. Where a complaint is justified, systemic problems are to be addressed through the amendment of applicable policies and practices.

Microsoft's Privacy Statement and Microsoft's terms of service both contain language as to how to contact Microsoft concerning complaints and/or inquiries. Microsoft's DPA contain the following statement:

If Customer believes that Microsoft is not adhering to its privacy or security commitments, Customer may contact customer support or use Microsoft's Privacy web form, located at <https://account.microsoft.com/privacy/privacy-request-signedout>. Microsoft's mailing address is:

¹²⁴ Available at: <https://privacy.microsoft.com/en-ca/privacystatement>.

Microsoft Enterprise Service Privacy

Microsoft Corporation

One Microsoft Way

Redmond, Washington 98052 USA

Microsoft Ireland Operations Limited is Microsoft's data protection representative for the European Economic Area and Switzerland. The privacy representative of

Microsoft Ireland Operations Limited can be reached at the following address:

Microsoft Ireland Operations, Ltd.

Attn: Data Protection

One Microsoft Place

South County Business Park

Leopardstown

Dublin 18, D18 P521, Ireland

F. Québec Private Sector Law

For private sector organizations operating in the Province of Québec, the personal information of individuals residing in that province is subject to *An Act respecting the Protection of Personal Information in the Private Sector*¹²⁵ (the "Private Sector Law"). This statute applies to both the activities of "for profit" and "not-for-profit" organizations as well as to personal information held by a professional order¹²⁶. Enforcement of the law, when required, is undertaken by the Commission d'accès à l'information ("CAI").

Microsoft is a service provider to a private sector customer in the provision of Microsoft Azure services. Because of this role, the primary responsibility for legal/privacy compliance with the Private Sector Law lies with the organizations who use one or more Azure service. To the extent that Microsoft directly collects personal information, it is accountable for such information.

Consent. An organization may only collect, use, or disclose personal information about an individual with the consent of that individual, as authorized by law, or with deemed consent as determined by statute.¹²⁷

In Québec, consent must be clear, free, and informed and be given for specific purposes. In addition, consent must be requested for each purpose and in clear and simple language. If a request for consent is made in writing, it must be presented separately from any other information provided to the person concerned. If the data subject requests, assistance is to be provided to help them understand the scope of the consent requested.

Consent is valid only for the time necessary to achieve the purposes for which it was requested. Any consent not given in accordance with the Private Sector Law is void.¹²⁸ In Québec, as with all jurisdictions in Canada, an organization may collect, use and disclose personal information without consent if authorized or required by law.¹²⁹

With respect to:

- Customer Data, Microsoft plays no role in obtaining consent and responsibility for obtaining such consent lies with the Customer.

¹²⁵ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1. Statute is available at: <https://www.canlii.org/en/qc/laws/stat/cqlr-c-p-39.1/latest/cqlr-c-p-39.1.html>.

¹²⁶ But only to the extent provided for by the *Professional Code*: RSQ, c C-26; See *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 1.

¹²⁷ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 13 and *Civil Code of Québec*, art. 37.

¹²⁸ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 14.

¹²⁹ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 6, 13, and 18.

- User Data, consent is implied by actions taken to register the user to use any Microsoft Azure service.
- Professional Services Data, to the extent such data may be considered Personal Data, consent is expressly requested from users prior to the provision of support services.

Collection. Information must be collected directly and only from the subject individual unless certain circumstances apply. Indirect collection is allowed where authorized by law or the individual has provided consent. Such indirect collection may also occur when there is a serious reason to do so; it is the individual's interests and direct collection cannot happen in a timely manner, or where direct collection would result in the collection of inaccurate information.¹³⁰

Collection requires the individual to be notified¹³¹, at the time of collection or upon request, of the:

- Purposes for which the information is collected.
- Means by which the information is collected.
- Rights of access and rectification provided by law.
- Person's right to withdraw consent to the communication or use of the information collected.

The information to be provided must be given to the person concerned in clear and simple language, regardless of the means used to collect the personal information.

If applicable, the person concerned is to be informed of the name of any third person for whom the information is being collected; the name(s) of the third persons or categories of third persons to whom it is necessary to communicate the information for the purposes indicated, and the possibility that the information could be communicated outside Québec.

On request, the data subject is to also be informed of the personal information collected from them, the categories of persons who have access to the information within the organization, the retention period, and the contact information of the person in charge of the protection of personal information.

Any collection, use or disclosure of personal information for the supply of a product or service is limited to that necessary to provide the product or service, or as authorized by law or if the request for the product or service is not lawful.¹³²

Microsoft directly collects user registration data as well as Professional Services Data. Customers should indicate to their employees that personal information (user account registration data) will be collected by Microsoft and that Microsoft will use such data for the purposes referred to in the DPA.

Microsoft plays no role in the collection of personal information contained within Customer Data.

Use. Québec permits the use of personal information only for the purposes for which it was collected unless consent is obtained or unless authorized by law.¹³³

Microsoft identifies the purposes for which it "uses" data in its Privacy Statement as well as specifically in the DPA. See [Annex E](#) for specific categories/definitions of data and the purposes for which Microsoft uses such data in the provision of Azure services

Disclosure. In Québec, if disclosure has occurred, the recipient may further disclose the information – only to the extent necessary – to perform his or her duties or to meet the purposes for which he or she received the information.¹³⁴

¹³⁰ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 6.

¹³¹ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 8.

¹³² *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 9.

¹³³ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 12-13.

¹³⁴ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 18 and 18.1.

In addition to disclosure to one's own legal advisor, disclosure is permitted for reasons related to:

- The prevention, detection, repression or prosecution of criminal or statutory offences.
- The existence of, or reasonable belief that there is, a life, health or safety-threatening situation.
- A requirement under a law or a collective agreement, whether to an individual or a public institution.
- Debt collection.
- Research or statistical purposes.
- The existence of a power to compel communication of the information.¹³⁵

Organizations may conduct research without consent in that they can disclose personal information to a person or body wishing to use the information for study or research purposes or to produce statistics, provided a privacy impact assessment indicates that:

- The objective of the research can be achieved only if the information is communicated in a form allowing the persons concerned to be identified.
- It is unreasonable to require the person or body to obtain the consent of the persons concerned.
- The objective of the research outweighs the impact of communicating and using the information on the privacy of the persons concerned.
- The personal information is used in such a manner as to ensure confidentiality.
- Only the necessary information is communicated.¹³⁶

Microsoft indicates in its DPA that it will not disclose Customer Data outside of Microsoft or its controlled subsidiaries and affiliates except as indicated. See [Annex E](#) for the for specific DPA text concerning the disclosure of data stored or processed by Microsoft.

Microsoft indicates that it keeps an accurate accounting of disclosures of information held in each system of records under its control, including date, nature, and purpose of each disclosure of a record. Microsoft does not use User Data or Customer Content Data for research purposes but does use the limited Personal Data collected for the purposes identified in its Privacy Statement and DPA.

Outsourcing and cross-border transfers. As noted in [Part 5](#) (Data Residency) communicating personal information to a service provider (or a mandatary/agent) does not require the consent of an individual. Service agreements, however, are to be in writing and contain provisions:

- Specifying the measures to protect the confidentiality of the personal information.
- Ensuring use is limited to the performance of services.
Ensuring destruction or return following the end of the contract.
- Requiring prompt notification in the event of an actual or suspected data incident or breach.
- Permitting any verification relating to confidentiality requirements.¹³⁷

With respect to cross-border transfers, organizations, before communicating personal information outside Québec, “must conduct an assessment of privacy-related factors”, considering the:

- Sensitivity of the information.
- Purposes for which it is to be used.
- Protection measures that would apply to the information.

¹³⁵ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 18 and 18.1.

¹³⁶ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 21. See also sections 21.0.1 and 21.0.2 for further qualifications for researchers seeking to use personal information for research purposes.

¹³⁷ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s 18.3.

- Legal framework applicable in the State to which the information would be communicated, including the legal framework's degree of equivalency with the personal information protection principles applicable in Québec.¹³⁸

Access. Under the Private Sector Law, there is a general right of access to one's own personal information¹³⁹.

Subject to specific exceptions, access to personal information must be provided to the subject individual so long as it is reasonable to do so. In addition, the organization must also describe the purposes for which the information is used and, if disclosed the names of recipients and the context of the disclosure¹⁴⁰. In Québec, if requested, reasonable accommodation must be provided to people with disabilities to allow them to exercise the right of access¹⁴¹.

Québec's legislation, both in the *Civil Code* and the Private Sector Law, differs from the other jurisdictions with respect to the exemptions to access. Under the *Civil Code*, information may not be disclosed where there is a serious and legitimate reason for refusing access or where the information may seriously prejudice a third person.¹⁴²

An organization, characterized as a "person carrying on an enterprise", must refuse to disclose personal information:

- Where disclosure would likely reveal personal information about a third party or even that party's existence, and the disclosure may cause that person serious harm, unless the third-party consents to disclosure or where the life, health or safety of the person concerned is threatened¹⁴³.
- To a testamentary administrator, a life insurance beneficiary, an heir, or a successor, except where such disclosure concerns the interests or rights of the person requesting it in his or her capacity as such¹⁴⁴. This is qualified in that disclosure about a deceased person may be made to the spouse or a close relative of the person if knowledge of the information could help the applicant in the grieving process and if the deceased person did not record in writing his refusal to grant such a right of access.¹⁴⁵
- To an individual under 14 years of age as to the existence or disclosure of a record containing personal information "of a medical or social nature", except where requested by the minor's attorney in the context of judicial proceedings¹⁴⁶.

Discretionary exceptions (i.e., the organization may disclose if it chooses) may be made in two situations:

- A person carrying on a professional health care enterprise may temporarily refuse access to personal information if such access would result in serious harm to the applicant's health. Other types of enterprises may also refuse access, provided that the applicant is offered the opportunity of designating a health care professional to receive the information¹⁴⁷.

¹³⁸ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 17.

¹³⁹ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 8 and 27.

¹⁴⁰ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, ss. 8 and 27. For Québec, see also CCQ, s. 39.

¹⁴¹ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 27.

¹⁴² *Civil Code of Québec*, s. 39.

¹⁴³ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 40.

¹⁴⁴ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 41.

¹⁴⁵ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 40.1.

¹⁴⁶ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 38.

¹⁴⁷ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 37.

- Where disclosure would be likely hinder an inquiry, the purpose of which is the prevention, detection, or repression of criminal or statutory offences, or would be likely to affect judicial proceedings¹⁴⁸.

In Québec, a refusal to provide access or rectification (correction) must be given in writing, with reasons and information as to the recourse open to the individual.¹⁴⁹

Responsibilities with respect to access requests to Customer Data remain with the Customer. With respect to the personal information that Microsoft may collect – more in connection with user registration data - Microsoft has a process to allow customers to correct or amend inaccurate personal information, as appropriate. Information as to how to contact Microsoft is available through the Microsoft Privacy Statement and using an online web form.

The features and functionality of the various services provided by Microsoft Azure allow customers to remain in control of Customer Data stored in the Customer's tenant. The use of Azure service will not cause any change in:

- An individual's right to access and correct personal information.
- The way access to personal information may be provided by an organization.
- The medium by which individuals may request access to his or her personal information from an organization.
- The customer's access procedures.
- How an individual can challenge the accuracy and completeness of his or her personal information held by the customer.

Correction. An individual may request the correction or rectification of an error or omission in personal information under the control of an organization¹⁵⁰. The subject individual must make the request in writing with sufficient detail to enable, with a reasonable effort, the identification of the personal information or correction being sought.¹⁵¹

If inaccurate or incomplete personal information is determined to exist, the organization must correct the information as soon as reasonably possible.¹⁵² If it decides not to do so, a notation is to be made on the record that the correction was requested but not made.¹⁵³

If an organization has disclosed incorrect information to other organizations, each of those organizations must be notified of the corrected information.¹⁵⁴ In Québec, the organization must notify every person that received the information in the preceding six months and, where applicable, the person who provided that information.¹⁵⁵

Responsibility for the correction of personal information stored or processed using a Microsoft Azure service remains with the Customer.

As for user data and Professional Services Data, Microsoft has a process to allow customers to correct or amend inaccurate personal information.

Accuracy. Each organization in Québec is to ensure that any personal information is accurate and up to date when used to make a decision about an individual.¹⁵⁶ Unlike other jurisdictions in Canada, Québec's

¹⁴⁸ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 39.

¹⁴⁹ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s.34.

¹⁵⁰ *Civil Code of Québec*, ss. 38, 40.

¹⁵¹ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 30.

¹⁵² *Civil Code of Québec*, ss. 38, 40.

¹⁵³ *Civil Code of Québec*, ss. 38, 40.

¹⁵⁴ *Civil Code of Québec*, ss. 38, 40.

¹⁵⁵ *Civil Code of Québec*, s. 40.

¹⁵⁶ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 11; see also *Civil Code of Québec*, s. 40.

legislation permits “accuracy” to be achieved through the deletion of personal information, when personal information has been collected or generated but not in a manner authorized by law.¹⁵⁷

Microsoft has a process to allow customers to correct or amend inaccurate subscriber personal information, as appropriate. The use of a Microsoft Azure service does not affect a customer’s control of Customer Data.

Retention. Québec’s Private Sector Law requires an organization - subject to any preservation period provided under any legislation – to destroy or anonymize personal information, when the purposes for which personal information was collected or used are achieved. Information is considered anonymized “if it is reasonably foreseeable in the circumstances that it irreversibly no longer allows the person to be identified directly or indirectly.” Information is to be anonymized according to generally accepted best practices and according to the criteria and terms determined by regulation.¹⁵⁸

With respect to retention, see [Annex E](#) for the for specific DPA text concerning data retention and deletion of data processed by Microsoft.

Microsoft allows customers to apply their data retention policies by maintaining the data until such time as the Customer disposes of such information. Customer Data is stored in a redundant environment with robust backup, restore, and failover capabilities to enable availability, business continuity, and rapid recovery. Multiple levels of data redundancy are implemented, ranging from (i) redundant disks to guard against local disk failure to (ii) continuous, full data replication to (iii) a geographically dispersed datacenter. All Microsoft services undergo an annual validation of backup/recovery practices.

Microsoft indicates that it wipes storage hard drives using a solution that is compliant with NIST 800-88¹⁵⁹. For hard drives that cannot be wiped there is a physical destruction process that renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

Records of hardware destruction are retained and audited through Microsoft’s ISO process. All Microsoft services utilize approved media storage and disposal management services. Paper documents, should they exist, are destroyed by approved means at the pre-determined end-of- life cycle.

Security. With respect to security, Québec’s Private Sector Law requires:

*A person carrying on an enterprise must take the security measures necessary to ensure the protection of the personal information collected, used, communicated, kept or destroyed and that are reasonable given the sensitivity of the information, the purposes for which it is to be used, the quantity and distribution of the information and the medium on which it is stored.*¹⁶⁰

See [Annex C](#) for a description of safeguard measures deployed by Microsoft and the audit measures used to support the deployed safeguards.

Microsoft provides role-based security training to personnel with assigned security roles and responsibilities when required by information system changes. All appropriate Microsoft Staff take part in a security-training program and are recipients of periodic security awareness updates when applicable. All Contractor Staff are required to take any training determined to be appropriate to the services being provided and the role they perform.

¹⁵⁷ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 28.

¹⁵⁸ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 23. The Anonymization Regulation came into force on 30 May 2024, except with respect to a requirement to record certain prescribed information in a register, which comes into force on 1 January 2025. The Anonymization Regulation is available at:

https://www.publicationsduquebec.gouv.qc.ca/fileadmin/gazette/pdf_encrypte/lois_reglements/2024A/106829.pdf.

¹⁵⁹ National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

¹⁶⁰ *An Act respecting the Protection of Personal Information in the Private Sector*, RSQ c P-39.1, s. 10.

All staff are required to enrol in a security awareness training course within the first 30 days of their employment or transfer into the organization. Non-operational personnel, anyone that is involved in development and quality assurance, are also required to take the mandatory training offered by Online Services Security, as well as training associated with the operational procedures related to Asset Handling, Incident Response, and Change Control. Security training is also required when there is a significant change to the system environment.

[Remainder of page left intentionally blank.]

ANNEX A – MICROSOFT AZURE SERVICES

As noted in Part 2, characterizing all of Azure services can be challenging because of the evolution of services, the retirement of services or simply the rebranding of services. This Annex enumerates the most recent comprehensive listing of Azure services as described in Microsoft's 2024-2025 SOC II report¹⁶¹.

It should be noted that Microsoft makes an important distinction with respect to a subset of Azure services and characterizes those services as "Core Services". Core Services are those that form the bedrock of cloud computing and are (i) usually available in every region and (ii) essential for building any application. Microsoft currently defines "core services"¹⁶² as the following:

"Azure AI, Azure AI Content Safety, Anomaly Detector, API Management, App Service (API Apps, Logic Apps, Mobile Apps, WebJobs, Functions), Lab Services, Application Gateway, Azure Monitor, Automation, Azure API for FHIR, Azure App Configuration, Azure Bastion, Azure AI Bot Service, Azure Cache for Redis, Azure AI Search, Azure Communication Services, Azure Container Apps, Azure Container Instances, Azure Container Registry (ACR), Azure Cosmos DB, Azure Data Explorer, Azure Database for MySQL, Azure Database for PostgreSQL, Azure Databricks, Azure DDOS Protection, Azure DevOps, Azure DNS, Microsoft Entra ID, Azure Event Grid, Microsoft Fabric, Azure Firewall, Azure AI Document Intelligence, Azure Health Data Services, Azure AI Immersive Reader, Azure Kubernetes Service, Azure Managed Grafana, Azure Machine Learning, Azure AI Metrics Advisor, Azure NetApp Files, Microsoft Foundry Models (includes Azure OpenAI), Azure Red Hat OpenShift, Azure VMware Solution, Microsoft Purview Data Map (Classic), Microsoft Purview Data Catalog (Classic), Microsoft Purview Data Estate Insights (Classic), Microsoft Purview Data Policies (Classic), Azure Resource Manager, Azure Spring Apps, Azure Time Series Insights, Azure AI Video Indexers, Azure Web PubSub, Backup, Batch, Cloud Services, Computer Vision, Content Moderator, Azure AI Custom Vision, Data Factory, Data Lake Analytics, Data Lake Store, Event Hubs, Express Route, Face, HDInsight, Import/Export, IoT Hub, Key Vault, Language Understanding, Load Balancer, Media Services, Microsoft Azure Portal, Notification Hubs, Azure AI Personalizer, Power BI Embedded, QnA Maker, Microsoft Defender for Cloud, Service Bus, Service Connector, Service Fabric, Azure SignalR Service, Site Recovery, Speech Services, SQL Database, SQL Managed Instance, SQL Server Stretch Database, Storage, StorSimple, Stream Analytics, Synapse Analytics, Text Analytics, Traffic Manager, Azure AI Translator, Virtual Machines, Virtual Machine Scale Sets, Virtual Network, and VPN Gateway."

It should also be noted that some services that appear in the above list do continue to exist but no longer use the name found in the above description and some services listed above do not appear as an Azure service in the SOC 2 report.

Compute

Azure App Service

Azure App Service is a PaaS for building, deploying, and scaling web apps, REST APIs, and mobile backends. It supports multiple languages (e.g., .NET, Java (in Java SE, Tomcat, and JBoss flavors), Node.js, Python, and PHP) and can run them on both Windows and Linux. Features of the service include auto-scaling, load balancing and CI/CD integration.

¹⁶¹ See Microsoft Corporation – Azure Including Dynamics 365 (Azure & Azure Government), System and Organization Controls (SOC) 2 Report, October 1, 2024 to September 30, 2025.

¹⁶² See Privacy & Security Terms, available at: <https://www.microsoft.com/licensing/terms/product/PrivacyandSecurityTerms/all>.

Azure Arc

Azure Arc is a management platform that extends Azure's capabilities to hybrid environments for the management of resources such as virtual machines, Kubernetes clusters, and databases regardless of location (i.e., on-premises, at the edge, or in other clouds). It provides a unified means, through Azure Resource Manager, to apply Azure's governance, security, and management tools consistently across an organization's infrastructure.

Azure Cloud Services

Cloud Services is a PaaS designed to support scalable, reliable, and low-admin applications executed in virtual machines running a version of Windows Server. Virtual machines created in Cloud Services are distinct from the ones created with Azure Virtual Machines in that Azure manages the Cloud Service virtual machines.

Azure Cloud Services (Extended Support)

Cloud Services (extended support) is a new Azure Resource Manager based deployment model for Azure Cloud Services. The primary benefit is in providing regional resiliency along with feature parity with Azure Cloud Services deployed using Azure Service Manager. It also offers some Azure Resource Manager capabilities such as role-based access and control, tags, policy, and supports deployment templates.

Azure Functions

Azure Functions is a service that allows clients to build apps using less code, and with less infrastructure. Functions provides a set of event-driven triggers (such as an HTTP request, a timer, or a change in storage) and bindings that connect an organization's functions (i.e., small pieces of code) to other services without the need to write extra code or manage the underlying infrastructure.

Azure Large Instances

Azure Large Instances is comprised of dedicated large compute instances and provide isolated environments with high-speed networking; specialized configurations for large-scale databases, and complex application suites that exceed standard virtual machine capabilities. Features include: (i) high-performance, sharable storage and (ii) function-specific virtual LANs (VLANs) in an isolated environment.

Azure Machine Configuration

Azure Machine Configuration is a service that provides the capability to audit or configure operating system settings as code for machines running in Azure, on-premises, or in other cloud environments (via Azure Arc-enabled servers). It is an extension of Azure Policy, allowing administrators to manage and enforce compliance of machine settings at scale.

Azure Service Fabric

Azure Service Fabric is a PaaS used to package, deploy, and manage scalable microservices-based applications and containers.

Azure Virtual Desktop

Azure Virtual Desktop is a service that provides remote desktops and apps. It functions as Desktop-as-a-Service.

Azure Virtual Machines

Azure Virtual Machines are on-demand, scalable computing resources that let organizations to create and run Windows or Linux virtualized servers in Microsoft's data centers, whether from a standard image or one that is supplied by an organization. Essentially, the service provides IaaS for running applications without managing physical hardware. Azure Virtual Machine sizes are designed to provide a wide range of options for hosting servers and their workloads in the cloud. Sizes are categorized into different families and types, each optimized for specific purposes. Users can choose the most suitable VM size based on their requirements, such as CPU, memory, storage, and network bandwidth.

Azure Virtual Machine Scale Sets

Azure Virtual Machine Scale Sets is a service that permits organizations to create and manage groups of identical, auto-scaling virtual machines in order to build highly available, scalable applications for workloads, automatically adding or removing instances based on demand or schedule for better performance and cost efficiency.

Azure VM Image Builder

Images ordinarily include predefined security, configuration settings, and any necessary software. Azure VM Image Builder is a service where resource providers configure it by specifying a source image, a customization to perform, and where the new image is to be distributed. When a configuration is submitted to the service, Azure builds and distributes the image.

VMware Solution

Azure VMware Solution is a service for private clouds that contain VMware vSphere clusters. All provisioned private clouds have VMware vCenter Server, VMware vSAN, VMware vSphere, and VMware NSX. Organizations can migrate workloads from their on-premises environments, deploy new virtual machines, and consume Azure services from their private clouds.

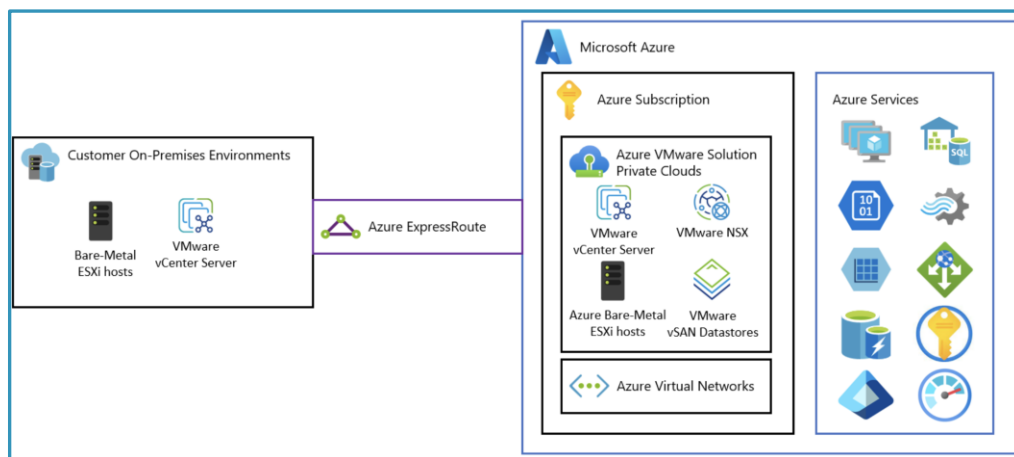


Image 2: Azure VMware Solution

Azure Batch

Azure Batch is a service that allows organizations to run large-scale parallel and high-performance applications in the cloud. The service creates and manages a pool of compute nodes (virtual machines), installs the applications, and schedules jobs to run on the nodes. Batch APIs and tools, command-line scripts, or the Azure portal are used to configure, manage, and monitor jobs.

Azure Planned Maintenance

Azure Planned Maintenance is a service that provides advance notice of scheduled updates (e.g., security patches, performance fixes, new features) for the underlying Azure PaaS/IaaS services or infrastructure. This allows organizations using Azure to manage potential, usually brief, service disruptions via Azure Service Health. Notification is provided through a variety of means (e.g., the Azure portal, email, SMS).

Azure Virtual Machines Licensing

Azure Virtual Machine Licensing refers to a set of licensing/pricing models and benefits that determine how organizations pay for operating systems and software running on Azure virtual machines in the Azure cloud.

Containers

Azure Arc Enabled Kubernetes

Azure Arc-enabled Kubernetes allows organizations to attach Kubernetes clusters, running anywhere, to permit their management and configuration in Azure.

Azure Container Apps

Azure Container Apps is a serverless platform for running containerized apps and microservices, abstracting away infrastructure management like Kubernetes orchestration. It provides a higher-level abstraction for deploying applications that need auto-scaling, observability, and support for HTTP/event-driven workloads.

Azure Container Instances

Azure Container Instances is a serverless platform for running single Docker containers or groups of containers directly in Azure without managing virtual machines or orchestration. It provides fast, isolated compute for traffic that arrives spikes (e.g., event-driven apps, simple web apps, build/data jobs, and bursting from Kubernetes).

Azure Container Registry

Azure Container Registry is a managed Docker registry service based on the open-source Docker Registry 2.0. Clients can create and maintain Azure container registries to store and manage private Docker container images.

Azure Kubernetes Service

Azure Kubernetes Service is a service to deploy and manage containerized applications using Kubernetes on Azure. It simplifies Kubernetes operations by automating tasks like upgrades, scaling, and provisioning to manage the underlying infrastructure. The Azure platform manages the service's control plane, which is responsible for the Kubernetes objects and worker nodes that are deployed to run client applications.

Azure Red Hat OpenShift

Azure Red Hat OpenShift is an offering by Microsoft and Red Hat that provides a Kubernetes platform on the Azure cloud. Running containers in production with Kubernetes requires other tools and resources, which often includes the need to coordinate image registries, storage management, networking solutions, and logging and monitoring tools that must be versioned and tested together. Azure Red Hat OpenShift combines all those items into a single platform.

Microsoft Artifact Registry

The Microsoft Artifact Registry, formerly known as the Microsoft Container Registry, is the primary public repository for all official software artifacts published by Microsoft.

Networking

Azure Application Gateway

Azure Application Gateway is a dedicated virtual appliance providing application delivery controller as a service. It offers various Layer 7 load balancing capabilities for customer applications. It allows customers to optimize productivity by offloading CPU intensive SSL termination to the application gateway.

Traditional load balancers operate at the transport layer (OSI layer 4 – TCP and UDP) and route traffic to a destination IP address and port. Application Gateway can make routing decisions based on additional attributes of an HTTP request, for example, a URI path or host headers.

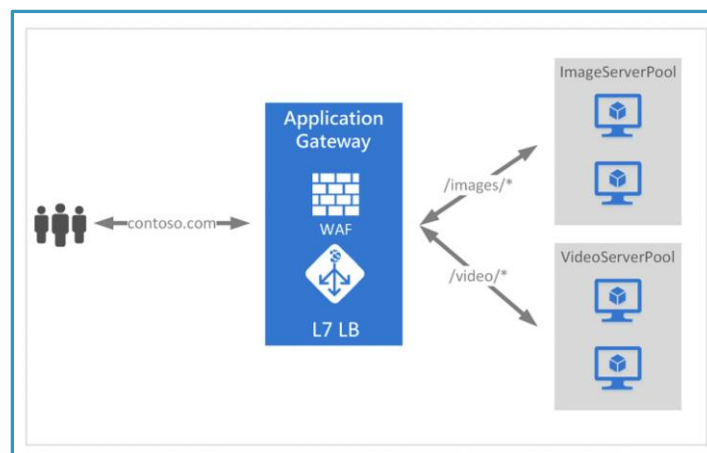


Image 3: Azure Application Gateway

Azure Bastion

Azure Bastion is a PaaS that provides RDP/SSH access to virtual machines, via a private IP address, directly from the Azure portal or native clients, without exposing those virtual machines to the public internet. It acts as a hardened gateway, encrypting all traffic over TLS on port 443, protecting against port scanning and exploits, and simplifying management by eliminating the need for jump boxes or VPNs for basic access.

Azure Communications Gateway

Azure Communications Gateway is a service that provides a voice gateway designed specifically for telecommunications operators. It acts as a bridge, connecting an operator's fixed and mobile voice networks to Microsoft Teams and other communication services like Zoom Phone.

Azure Content Delivery Network

Azure Content Delivery Network ("CDN") is a global service that speeds up delivery of web content (images, videos, apps, etc.) by caching it on servers worldwide, bringing it closer to users, reducing latency, handling traffic spikes, and lowering origin costs. It can be hosted in Azure or any other location. Azure CDN permits the caching of static objects loaded from Azure Blob storage, a web application, or any publicly accessible web server, by using the closest point of presence server. Azure CDN can also accelerate dynamic content, which cannot be cached, by leveraging various network and routing optimizations. It offers options like Azure Front Door for advanced features (WAF, security) and permits

fast, secure, and scalable content distribution with features like custom domains, HTTPS, and geo-filtering.

Azure DDoS Protection

Azure DDoS Protection is a service that defends applications and resources from large-scale Distributed Denial of Service attacks by providing always-on monitoring, adaptive traffic analysis, and automated mitigation for Layer 3/4 network attacks. There are basic (free) and advanced (paid) tiers, the latter offering more features like logging, alerting, and a rapid response team.

Azure DNS

Azure DNS is Microsoft's cloud-based Domain Name System ("DNS"). It translates domain names into IP addresses through the Azure portal, APIs, and tools.

Azure ExpressRoute

Azure ExpressRoute is a service that creates private connections between a client's on-premises infrastructure and Azure datacenters, over a private connection with the help of a connectivity provider. Connectivity can be from an any-to-any (IP VPN) network, a point-to-point Ethernet network, or a virtual cross-connection through a connectivity provider at a colocation facility. ExpressRoute connections do not use the public Internet. As a result, the connections offer more reliability, faster speeds, consistent latencies, and higher security when compared to the public internet.

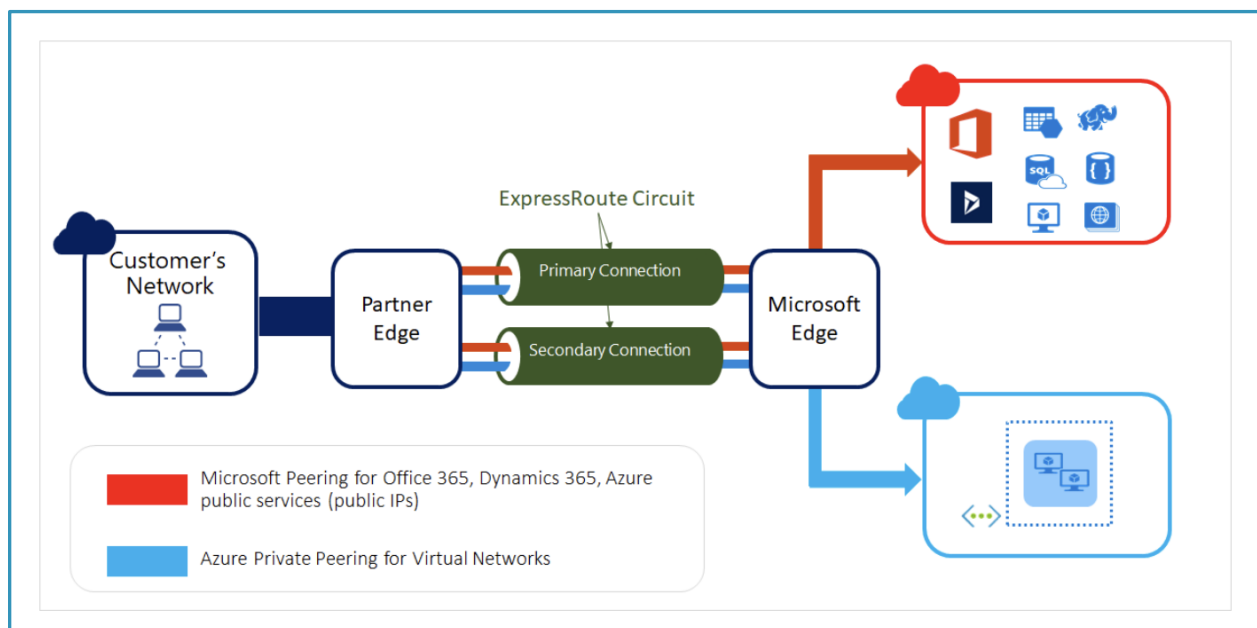


Image 4: Azure ExpressRoute

Azure Firewall

Azure Firewall is a network security service that protects a client's Azure Virtual Network resources. It is a fully stateful firewall-as-a-service that can centrally enforce network and application connectivity policies, automatically scales to meet demand, and includes built-in high availability. It inspects both traffic coming into a network ("north-south") and traffic between different parts of a network ("east-west").

Azure Firewall Manager

Azure Firewall Manager is a security management service that provides central security policy and route management for cloud-based security perimeters. Azure Firewall Manager can provide security management for two network architecture types: secured virtual hub and hub virtual network.

Azure Front Door and Azure Front Door (classic)

Azure Front Door is a global CDN and application acceleration service that delivers high performance, scalability, and security for web applications. It acts as a global entry point, using Microsoft's edge network, to route user traffic to the nearest and fastest available application backend, while also providing security features like a Web Application Firewall. The service enables customers to define, manage, and monitor the global routing for web traffic by optimizing for best performance and instant global failover for high availability. As of August 2025, Azure Front Door (classic) no longer supports new domain onboarding or profile creation.

Azure Load Balancer

Azure Load Balancer is a service that distributes incoming network traffic across backend virtual machines (or virtual machine scale sets). It operates at Layer 4 (TCP, UDP) of the Open Systems Interconnection model. It is the single point of contact for clients that distributes inbound flows from the load balancer's frontend to backend pool instances. These flows are distributed according to configured load-balancing rules and health probes. The backend pool instances can be Azure virtual machines or virtual machine scale sets. Microsoft indicates that Basic Load Balancer was retired in September 2025, however Standard Load Balancer remains an active service.

Azure NAT Gateway

Azure NAT Gateway is a Network Address Translation ("NAT") service that provides outbound internet connectivity for resources in a virtual network subnet, translating their private IPs to a static public IP or pool of IPs. Organizations can use Azure NAT Gateway to let all instances in a subnet connect outbound to the internet while remaining fully private. Unsolicited inbound connections from the internet are not permitted through a NAT Gateway. Only packets arriving as response packets to an outbound connection can pass through a NAT Gateway.

Azure Network Function Manager

Azure Network Function Manager was a service that simplified deploying and managing network services like SD-WAN, VPNs, and private 5G/LTE mobile cores at the network edge. Microsoft indicates that this service was retired in October 2025.

Azure Orbital Ground Station

Azure Orbital Ground Station is a managed "Ground Station as a Service" that allows satellite operators to communicate with, control, and downlink data from their spacecraft directly into Microsoft Azure.

Azure Peering Service

Azure Peering Service is a networking service that optimizes routing on the Microsoft network to ensure that customer traffic is only handed off to the peering service provider chosen by the customer at a preferred location. This ensures that customer traffic stays on the Microsoft network rather than routing through various other networks before returning to the customer's last mile network. As a result, organizations have more control and performance assurance as to how their traffic will be handled compared to normal internet routing.

Azure Private Link

Azure Private Link is a service that provides secure, private connectivity from an organization's virtual network directly to Azure PaaS services or client-hosted services, using Private Endpoints that map to an instance of a service. This enables an organization to keep traffic off the public internet and on the Microsoft backbone network.

Azure Route Server

Azure Route Server is a service that acts as a Border Gateway Protocol route reflector within an organization's virtual network, automatically managing route distribution between network virtual appliances and Azure's routing infrastructure. It simplifies dynamic routing and enables automatic route exchange through, eliminating the need for manual route table configuration and maintenance.

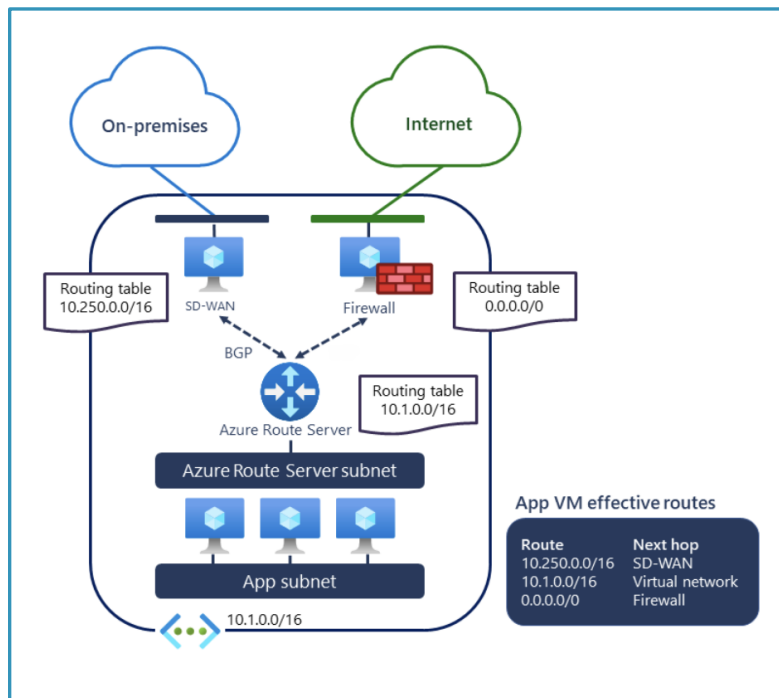


Image 5: Azure Route Server

Azure ExpressRoute Traffic Collector (also known as Azure Traffic Collector)

Azure ExpressRoute Traffic Collector is a service that samples network flows over a client's private ExpressRoute circuits. The resulting flow logs are sent to an export destination (e.g., Log Analytics, Event Hubs, and Storage Accounts) for further analysis (e.g., deep traffic analysis, performance monitoring, capacity planning, security insights) using custom log queries. The service provides flow logs for understanding usage patterns, troubleshooting, and integrating with Security Information and Event Management tools for broader security.

Azure Virtual Network

Azure Virtual Network is a service to provision and manage virtual private networks in Azure as well as securely link these networks with on-premises IT infrastructure. This extends on-premises networks into the cloud with control over network topology, including configuration of DNS and IP address ranges for virtual machines.

Azure Virtual Network IP Services (also known as Azure IP Services)

IP services are a collection of IP address-related services that enable communication in an Azure virtual network. Public and private IP addresses are used in Azure for communication between resources. The communication with resources can occur in a private Azure virtual network and the public Internet.

Azure Virtual Network Manager

Azure Virtual Network Manager is a centralized management service that enables organizations to group, configure, deploy, and manage virtual networks globally across subscriptions and tenants. It simplifies creating complex topologies (e.g., hub-and-spoke or mesh), enforces consistent security rules across a cloud environment, and automates route management.

Azure Web Application Firewall

Azure Web Application Firewall is a cloud-native security service that protects web apps from common exploits like SQL injection and cross-site scripting, malicious bots, and DDoS attacks by inspecting HTTP traffic at the application layer (Layer 7).

Network Security Perimeter 10

Azure Network Security Perimeter is a service that creates a logical boundary to secure PaaS resources (e.g., Storage, Key Vault, SQL DB) outside an organization's virtual networks. It acts as a centralized firewall to control inbound/outbound access, prevent data exfiltration, and enable secure service-to-service communication within its protected area by default, blocking public access and requiring explicit rules for allowed traffic. It complements Azure Private Link by securing the PaaS service itself, not just the connection path.

Azure Network Watcher

Azure Network Watcher is a service that provides a suite of tools to monitor, diagnose, view metrics, and enable or disable logs for Azure IaaS resources (e.g., virtual machines, virtual networks, application gateways, load balancers). It offers tools (i.e., IP flow verify, packet capture, connection monitoring, and topology visualization) to troubleshoot connectivity and performance issues.

Azure Traffic Manager

Azure Traffic Manager is a DNS-based traffic load balancer. Traffic Manager uses DNS to direct client requests to the appropriate service endpoint based on a traffic-routing method. The endpoint can be any Internet-facing service hosted inside or outside of Azure. It provides a range of traffic-routing methods and endpoint monitoring options to suit different application needs and automatic failover models.

Azure Virtual WAN

Azure Virtual WAN is a networking service that brings many networking, security, and routing functionalities together to provide a single operational interface. The service centralizes and simplifies connecting branches, users, and on-premises networks to Azure. It automates large-scale branch connectivity and integrates Azure Firewall as well as other security appliances for enhanced security and traffic management.

Azure Virtual Network Gateway

An Azure Virtual Network Gateway is a service that acts as a secure bridge, connecting an organization's Azure Virtual Network to other networks. It allows organizations to send encrypted traffic between an Azure virtual network and on-premises locations over the public Internet using encrypted connections.

over the internet (via a VPN Gateway) or private connections (via an ExpressRoute Gateway). It manages traffic flow, enabling secure communication and data exchange between these networks.

Storage

Azure Archive Storage

Archive Storage is lowest-cost tier within Azure Blob Storage, which is optimized for storing data that is rarely accessed and stored for at least one hundred eighty (180) days with flexible latency requirements.

Azure Backup

Azure Backup is a service that extends traditional on-premises backup tools with tools in the cloud. Azure Backup allows the protection of data received from customer datacenters as well as cloud applications using on premise and cloud storage.

Azure Data Box

Azure Data Box is a group of Microsoft physical appliances and virtual devices that securely and quickly transfer large amounts of data (terabytes to petabytes) into and out of Azure cloud storage. These encrypted devices are shipped to a location where an organization copies data onto them using standard protocols (SMB/NFS) and then returned to Microsoft for upload to Azure. Azure's Import/Export service has been integrated into Azure Data Box.

Azure File Sync

Azure File Sync is a service that centralizes an organization's file shares in Azure Files while keeping the flexibility, performance, and compatibility of a Windows file server. It acts as a hybrid cloud file solution for organizations needing scalability, backup, and disaster recovery with Server Message Block ("SMB")/ Network File System ("NFS") access. It transforms Windows Servers into a cache of an Azure file share, using features like cloud tiering to move less-used files to the cloud, saving local space.

Azure Files

Azure Files is a service that offers cloud file shares that organizations can access from anywhere via SMB or NFS protocols and Azure Files REST API.

Azure HPC Cache

Azure HPC Cache was a cloud-based file caching service designed to provide low-latency access to data for high-performance computing (HPC) workloads. Microsoft indicates that the service was officially retired in September 2025.

Azure Managed Lustre

Lustre is an open-source parallel file system that can scale to massive storage sizes while also providing high-performance throughput. It is used by the world's fastest supercomputers and in data-centric workflows for many types of industries. Azure Managed Lustre is a managed file system that offers scalable, powerful, cost-effective storage for high-performance computing workloads.

Azure Net App Files

NetApp Files is a file storage service that provides *Volumes as a service* on Microsoft Azure. Delivering low-latency, scalable file shares for demanding applications. NetApp Files supports SMB, NFS, and dual protocols volumes and can be used for use cases such as file sharing, home directories, databases and high-performance computing.

Azure Site Recovery

Azure Site Recovery is a service that replicates virtual machines, physical servers, and workloads from a primary site (on-premises or another Azure region) to a secondary location (usually Azure) for disaster recovery and business continuity purposes. It enables failover and failback and allows non-disruptive testing of disaster recovery scenarios.

Azure Storage (Azure Blob Storage, Azure Disk Storage, Azure Queue Storage, Azure Table Storage, Azure Data Lake Storage)

Azure Storage is Microsoft's cloud storage solution for various data types like files, blobs (objects), queues, and tables and is accessible globally via REST APIs and SDKs. It provides different storage types, including Disk Storage (for virtual machines), Blob Storage (for unstructured data/lakes), Files (SMB/NFS shares), Queues (messaging), and Tables (NoSQL data) within a single storage account. Storage is managed through tools like the Azure Portal, CLI, and PowerShell.

Azure Storage consists of: Blob storage, File storage, Disc storage, Table storage, and Queue storage. Blob storage supports both standard and premium storage, with premium storage using only SSDs for the fastest performance possible. Another feature is "cool" storage, allowing the customer to store large amounts of rarely accessed data for a lower cost.

Azure Storage includes the Storage Resource Provider, the frontend service for Azure Storage, exposing the storage API surface to Azure Customers. The Customer can create and manage blob, table, queue and storage account management resources in simple to use templates via storage APIs through the Azure Resource Manager.

Blob

Azure Blob Storage is a scalable REST-based cloud object store, designed to store unstructured data, such as text or binary data. A blob is a file of any type and size (up to one terabyte). A storage account can contain an unlimited number of blob containers, each of which groups together a set of blobs. Azure applications can also use Azure drives, which let blobs provide persistent storage for a Windows file system mounted in an Azure instance. The application sees ordinary Windows files, but the contents are stored in a blob. Blob Storage is accessed through the REST protocol and managed APIs.

Disk

Virtual machines in Azure use disks as a place to store an operating system, applications, and data. All Azure virtual machines have at least two disks – a Windows operating system disk and a temporary disk. The operating system disk is created from an image, and both the operating system disk and the image are virtual hard disks ("VHDs") stored in an Azure storage account. Virtual machines also can have one or more data disks, that are also stored as VHDs.

Azure managed disks are block-level storage volumes managed by Azure and used with Azure Virtual Machines. There are five types of managed disks: Ultra Disks, Premium solid-state drives (SSD) v2, Premium SSD, Standard SSD, and Standard hard disk drives (HDD).

Queue

Azure Queue Storage is a service for storing large numbers of messages that can be accessed from anywhere in the world via authenticated calls using HTTP or HTTPS. While tables and blobs are primarily intended to store and access data, the main goal of queues is to allow communication between different parts of an Azure application. Queues are accessed through the REST protocol.

Table

Azure Table Storage offers Non-relational SQL (NoSQL) capabilities for applications that require storage of large amounts of unstructured data through a key/value store. Tables allow an application to store properties of various types, such as strings, integers, and dates. An application can then retrieve a group of properties by providing a unique key for that group. Table Storage is scalable, with a single table able to hold as much as a terabyte of data. Table Storage is accessed through the Representational State Transfer (REST) protocol and managed APIs.

Data Lake Storage

Azure Data Lake Storage is a set of capabilities dedicated to big data analytics that combines the capabilities of Azure Data Lake Storage with Azure Blob Storage. Data Lake Storage makes Azure Storage the foundation for building enterprise data lakes and allows organizations to store any data (structured, semi-structured, unstructured) in its native format for large-scale processing. It offers hyper-scalability, high performance, and integration with Azure analytics services, acting as central storage for diverse data types and ingestion speeds.

Databases

Azure Storage Mover

Azure Storage Mover is a service to migrate files and folders from on-premises storage (NAS/SMB) or other clouds into Azure Storage (Blob/Files). It uses agents for on-premises moves and direct cloud-to-cloud transfers, maintaining metadata and handling large dataset.

Azure Managed Redis (formerly Azure Cache for Redis)

Azure Managed Redis is a data store, built on Redis Enterprise that Microsoft runs on Azure. This service is a successor to Azure Cache for Redis, a service that allowed organizations to access a secure data cache and messaging broker. This service is able to process large volumes of application requests by keeping frequently accessed data in the server memory, which can be written to and read from quickly. Microsoft indicates that Azure Cache for Redis is retiring in September 2028 and Azure Cache for Redis Enterprise in March 2027 and is directing users to Azure Managed Redis.

Azure Cosmos DB

Azure Cosmos DB is a globally distributed, multi-model database that enables organizations to elastically and independently scale throughput and storage across any number of Azure's geographic regions. It offers throughput, latency, availability, and consistency.

Azure Database for MariaDB

Azure Database for MariaDB was a fully managed relational database service based on the open-source MariaDB community edition. Microsoft indicates that this service was retired in September 2025.

Azure Database for MySQL

Azure Database for MySQL is a relational database service based on the open-source MySQL Server engine. It is a PaaS offering that allows developers to host, manage, and scale MySQL databases without managing the underlying infrastructure, operating system, or hardware.

Azure Database for PostgreSQL

Azure Database for PostgreSQL is a relational database service based on the open-source Postgres database engine. It is a service that offers features such as autonomous tuning, vector search for AI, automated maintenance, and support for distributed PostgreSQL.

Azure Database Migration Service

Azure Database Migration Service is a service designed to enable migrations from multiple database sources to Azure data platforms with minimal downtime.

Azure Health Data Services

Azure Health Data Services is a suite of purpose-built technologies for health information. In offering additional technology and services, Azure Health Data Services is the evolved version of Azure API for FHIR. As a PaaS offering, it permits healthcare organizations to securely ingest, store, manage, and analyze protected health information using open standards like FHIR (Fast Healthcare Interoperability Resources) and DICOM (Digital Imaging and Communications in Medicine). It offers dedicated services like the FHIR service for data exchange, DICOM service for medical imaging, and MedTech service for IoT data. It also includes a de-identification service that enables healthcare organizations to de-identify clinical data.

Azure SQL

Azure SQL is a family of database products built on the SQL Server database. Azure has three main deployment options: (i) Azure SQL Database, (ii) Azure SQL Managed Instance and (iii) SQL Server on Azure Virtual Machines.

Azure SQL Managed Instance

Azure SQL Managed Instance is a scalable database service that provides compatibility with on-premises SQL servers, allowing for “lift-and-shift” migrations without needing to refactor applications. It allows organizations to focus on domain-specific database administration and optimization activities while Azure handles backups, patching and updating of the SQL and operating system code.

Synapse Analytics

Azure Synapse Analytics is an enterprise analytics service that brings together data warehousing, big data analytics (Apache Spark), and data integration (ETL/ELT) into a single service, allowing organizations to ingest, prepare, transform, and analyze data at scale for business intelligence, machine learning, and real-time reporting. It offers flexible querying (serverless or dedicated) and integrates with tools like Power BI.

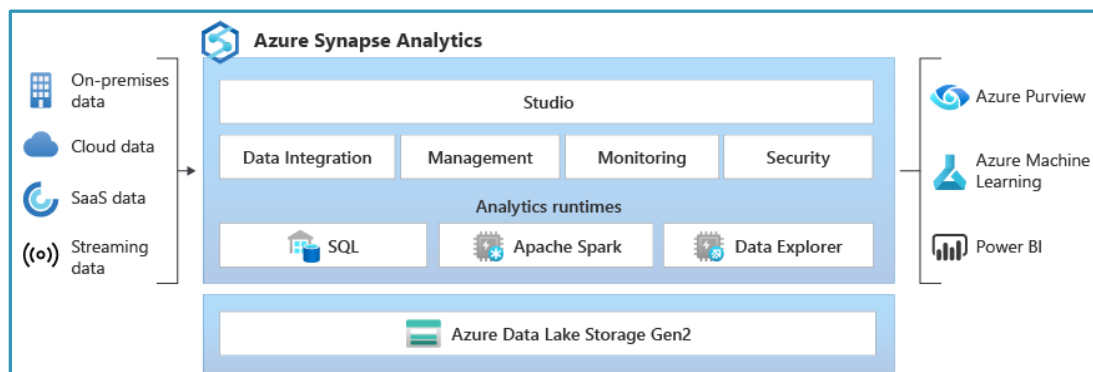


Image 6: Azure Synapse Analytics

Azure Managed Instance for Apache Cassandra

Azure Managed Instance for Apache Cassandra is a service for open-source Apache Cassandra clusters. It automates deployment, scaling, backups, and patching, while offering control over configurations, hybrid cloud integration, and compatibility with existing Cassandra tools and drivers. This allows users maximum flexibility and control where needed.

SQL Managed Instance enabled by Azure Arc

SQL Managed Instance enabled by Azure Arc is an Azure SQL data service that allows organizations to run a fully managed version of the SQL Server database engine on the infrastructure of its choice (e.g., on-premises, at the edge, or in other public clouds) using Kubernetes.

SQL Server enabled by Azure Arc

SQL Server enabled by Azure Arc is a service that connects an organization's existing on-premises or multi-cloud SQL Server instances to the Azure control plane. The service is different from "Arc-enabled SQL Managed Instance." That service runs a containerized database in Kubernetes while this service allows an organization to manage existing SQL Server installations (on physical or virtual machines) as native Azure resources.

Azure SQL Server on Virtual Machines

Azure SQL Server on Virtual Machines is an IaaS solution permitting organizations to run full SQL Server instances on Azure virtual machines.

Developer Tools

Azure App Configuration

Modern programs, especially programs running in a cloud, generally have many components that are distributed in nature. Spreading configuration settings across these components can lead to errors during an application's deployment. Azure App Configuration provides a service to centrally manage application settings and feature flags, acting as a key-value store to separate configuration from code and simplifying management across different environments (dev, staging, prod) without redeploying applications.

Azure Deployment Environments

Azure Deployment Environments is a service that helps platform engineers apply policies and settings on various types of environments, control the resource configuration that developers can create, and track environments across projects. This service lets developers quickly spin up application infrastructure using Infrastructure-as-Code templates. They can further apply Azure governance based on the type of environment, such as sandbox, testing, staging, or production.

Azure DevTest Labs

Azure DevTest Labs is a service that enables developers and testers to quickly create and manage Azure virtual machines for development and testing. DevTest Labs resources are organized into Labs, which provide preconfigured bases and artifacts for creating virtual machines.

Azure for Education

Azure for Education is a suite of cloud services, software, and learning resources designed to support students, educators, and academic institutions. It primarily functions through three main programs: Azure for Students, Azure Dev Tools for Teaching, and Azure Lab Services.

Azure Lab Services

Azure Lab Services is a service to create labs with infrastructure managed by Azure. The service handles infrastructure management to allow users to quickly set up and manage virtual labs with preconfigured virtual machines for training, classes, and testing. This allows educators and trainers to provide controlled, on-demand access to specific software and environments for students or participants. Microsoft indicates that Azure Lab Services will be retired in June 2027.

Azure App Testing

Azure App Testing lets developers and QA teams run large-scale functional and performance tests to identify issues in their applications. Azure App Testing allows users to run functional tests with Playwright Workspaces and performance tests using Azure Load Testing.

Load Testing

Azure Load Testing (now part of Azure App Testing) is a service for simulating high-scale user traffic to identify performance bottlenecks and optimize application performance, scalability, or capacity. Microsoft indicates that Azure Load Testing has been integrated into Azure App Testing.

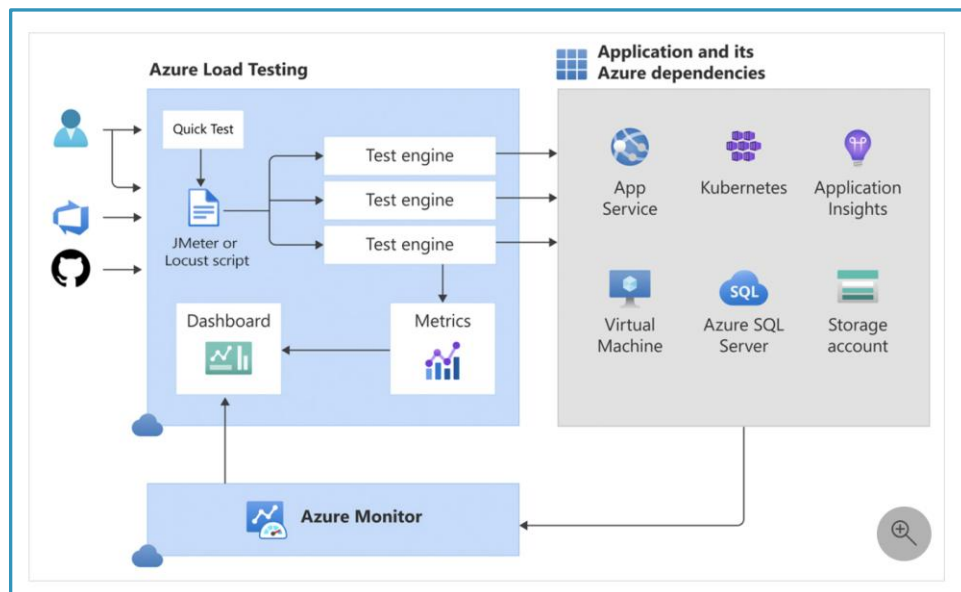


Image 7: Azure Load Testing Architecture

Playwright Workspaces

Playwright Workspaces is a service designed to automate Playwright end-to-end tests to ensure web applications work as expected, across different web browsers and operating systems. Microsoft indicates that there is a service called "Microsoft Playwright" that will be retired in March 2026, and users should migrate to using a Playwright Workspace in Azure App Testing.

Azure Managed Grafana (formerly Azure Grafana Service)

Azure Managed Grafana is a data visualization platform built using the Grafana software created by Grafana Labs, an open-source analytics platform. This service can create interactive dashboards to visualize metrics, logs, and traces from various data sources. Users can view and analyze application and infrastructure telemetry data in real-time.

Microsoft DevBox

Microsoft DevBox is a service providing developers with secure, on-demand, preconfigured, high-performance cloud-based workstations (dev boxes) for building and testing applications. As of November 2025, existing users can continue using the service as normal; new users will be able to access DevBox's features through Windows 365.

Azure Service Connector

Azure Service Connector is a service designed to simplify the connection between Azure compute services and other backing Azure services (such as databases, storage accounts, and message brokers). Service Connector configures the network settings and connection information (for example, generating environment variables) between compute services and target backing services.

Analytics

Azure Analysis Services

Azure Analysis Services is a PaaS, integrated with Azure data platform services, to provide a data modeling service. An organization can combine data from multiple sources, define metrics, and secure data in a single, trusted semantic data model. The data model provides a way for users to browse massive amounts of data with applications like Power BI, Excel, Reporting Services, third-party, and custom apps.

Azure Chaos Studio

Azure Chaos Studio is a platform for "chaos engineering" that allows organizations to intentionally inject faults (e.g., network latency, CPU pressure, or outages) into Azure applications to test and improve their resilience. This provides essentially stress-testing systems in controlled "experiments" to validate reliability, identify gaps, and plan mitigations by simulating real-world failures.

Azure Data Explorer

Azure Data Explorer is a data analytics platform to analyze high volumes of data in "near real time" and is useful for log analytics, time series analytics, IoT, and general-purpose exploratory analytics. The Azure Data Explorer toolbox permits data ingestion, query, visualization, and management. It uses a traditional relational model, organizing data into tables with strongly typed schemas. Tables are stored within databases, and a cluster can manage multiple databases.

Azure Data Factory

Azure Data Factory is a data integration service that permits the orchestration and automation of data movement and data transformation. It simplifies complex *Extract, Transform, Load (ETL)* and *Extract, Load, Transform (ELT)* processes at an enterprise scale. It does this by connecting to and moving data from a wide variety of sources, transforms it using various compute services, and loads it into target data stores.

Azure Data Share

Azure Data Share is a service for securely sharing data with multiple customers and partners from various Azure sources (e.g., SQL DB, Blob Storage, ADLS) using either snapshot-based copying or in-place access (for Azure Data Explorer). It allows organizations to manage who gets data, the terms of use, and monitor the sharing process from a central portal.

Azure HD Insight

Azure HDInsight is a platform that permits organizations to run “big data” frameworks like Apache Spark, Apache Hive, LLAP, Apache Kafka, Apache Hadoop, and others in an Azure environment. It is designed to handle large volumes of data with high speed and efficiency and allow organizations to easily process massive datasets for analytics, machine learning, and ETL purposes.

Azure Stream Analytics

Azure Stream Analytics is a “real-time” analytics service examine high volumes of data streaming from devices from various sources (e.g., devices, sensors, web sites, social media feeds or applications). The service also supports extracting information from data streams, identifying patterns and/or relationships. It can be used for predictive maintenance, anomaly detection, and real-time dashboards.

Healthcare data solutions in Microsoft Fabric

Healthcare data solutions in Microsoft Fabric is a purpose-built analytics SaaS platform. This platform enables healthcare organizations to ingest, store, and analyze data from various sources and modalities. These data solutions provide a set of capabilities that enable a multi-modal “biomedical lakehouse”, which can handle clinical, imaging, claims, conversational, and social determinants of health data. It adheres to Fast Healthcare Interoperability Resources (FHIR) and Digital Imaging and Communications in Medicine (DICOM) standards, introduces data transformations, and ensures a secure, regulatory-compliant framework for managing data.

Microsoft Fabric

Microsoft Fabric is a data analytics platform that combines and simplifies data ingestion, transformation, real-time event routing, and visualization through data engineering, data science, data warehousing, and business intelligence tools. OneLake is the default storage for all Fabric items (e.g., Lakehouses, Warehouses), unifying data across workspaces and domains into one logical lake, regardless of underlying physical location. The power of Fabric is in the ability to connect to a variety of distributed data sources with centralized governance.

Power BI Embedded

Power BI is a suite of a collection of software services, apps, and connectors that change unrelated sources of data into sets of coherent, visually immersive, and interactive insights. Power BI Embedded Analytics is service that allows developers to integrate Power BI reports, dashboards, and visuals directly into their custom web, mobile, or desktop applications, portals, or websites. This allows them to have branded analytics experiences without users needing separate Power BI licenses. It also allows end users to independently explore, analyze, and visualize data and decision-making without having to switch to separate BI tools outside of the applications.

AI & Machine Learning

AI Builder

AI Builder is a low-code/no-code Microsoft Power Platform capability that allows business users to add artificial intelligence to their apps and automated workflows. It is built on top of Azure AI services but provides a simplified, point-and-click interface designed for individuals who do not have extensive coding or data science expertise.

Azure AI Foundry Portal

The Azure AI Foundry portal (formerly known as Azure AI Studio) is a platform for developers and organizations to build, deploy, and manage AI applications and agents. Through the portal users can access services, tools and Generative AI models.

Azure AI Services

Azure AI services is a suite of APIs and SDKs that allow developers to integrate artificial intelligence capabilities into their applications without needing deep data science expertise. These services provide AI capabilities such as generative language models, semantic search services, speech and voice features, language analysis and translations, document and image analysis, and more. Organizations can connect to these services programmatically using the available software development kits to build custom AI solutions. These services have been largely unified and rebranded as Foundry Tools, a core component of the broader Microsoft Foundry (formerly Azure AI Foundry) platform.

Azure AI Anomaly Detector

Azure AI Anomaly Detector is a service that uses AI to find unusual patterns/ anomalies (e.g., spikes or trend changes) in time-series data. Microsoft indicates that the service is being retired in October 2026.

Azure AI Services: Azure AI Containers

Azure AI containers are a deployment option that allows organizations to run specific Azure AI services in their own environment — on-premises, at the edge, or in other clouds — using Docker containers.

Containerization is a form of software distribution where an application or service, including its dependencies & configuration, is packaged together as a container image. The container image can then be deployed on a container host, while isolated from other containers and the underlying operating system. Containers can be instantiated from container images for short-term tasks and removed when no longer needed.

Azure AI Services: Azure Content Safety (successor and replacement for Azure Content Moderator)

Azure Content Safety is a service to apply guardrails and security to AI agents, detecting harmful content (violence, hate, sexual, self-harm, prompt injection) in text/images, and enforcing responsible AI use, whether in user inputs or AI outputs. Organizations can configure the level severity thresholds that they desire.

Azure AI Services: Azure AI Custom Vision

Azure AI Custom Vision is a service to build and deploy custom image recognition models for unique tasks, such as classifying product photos or detecting specific defects, by simply uploading and labeling images. It can be used to train models for image classification (tagging) or object detection (locating).

Azure AI Services: Azure Document Intelligence

Azure Document Intelligence is a service that uses machine learning to automatically read, understand, and extract data (text, fields, tables) from documents like PDFs, images, and forms. Document analysis (general extraction) models enable text extraction from forms and documents and return structured business-ready content.

Azure AI Services: Azure AI Face Service

Azure AI Face is a specialized cloud-based service within the Azure AI suite designed for face detection, identification, and verification. Microsoft indicates that the service is governed by strict Responsible AI policies, focusing on identity security and secure access rather than broad surveillance.

Azure AI Services: Azure AI Immersive Reader

Azure AI Immersive Reader is a Service that allows users to improve reading comprehension through AI-powered features like text-to-speech, translation, text spacing, and visual focus tools. It is designed for new readers, language learners, and people with learning differences.

Azure AI Services: Azure AI Language

Azure AI Language is an integrated suite of AI services that provides pre-built and customizable Natural Language Processing features (e.g., entity extraction, summarization, sentiment analysis, question answering) to build intelligent, conversational AI applications.

Azure AI Services: Azure AI Metrics Advisor

Azure AI Metrics Advisor is a service that proactively monitors time-series data, detects anomalies, and helps diagnose issues for business metrics (e.g., sales, website traffic) or operational data (e.g., manufacturing data), using capabilities for root cause analysis, alerting, and custom model tuning. Microsoft indicates that the service will be retired in October 2026.

Azure AI Services: Azure AI Personalizer

Azure AI Personalizer is an API service that uses reinforcement learning to deliver personalization in real-time. It offers content (e.g., products, articles, ads) to show users based on their context and behavior. The service continuously learns and improves its recommendations.

Azure AI Services: Azure AI Search

Azure AI Search is a service that allows an organization to build AI-powered search for their own data. The service unifies access to enterprise and web content so agents and LLMs can use context, chat history, and multi-source signals to produce answers. It is designed to transform raw, unstructured data into a searchable knowledge base.

Azure AI Services: Azure AI Translator

Azure Translator is a neural machine translation service, now integrated into the Azure AI Foundry platform, to build multilingual AI apps, websites, and workflows by embedding real-time text and document translation for over 100 languages via a simple REST API. This service's focus is on text translation.

Azure AI Services: Azure AI Video Indexer

Azure AI Video Indexer is a cloud and edge video analytics service that uses AI to extract actionable insights from video and audio content.

Azure AI Services: Azure AI Vision

Azure AI Vision is now called Azure Vision and integrated into the Azure AI Foundry platform. It is a service that permits applications to "see" and "understand" images by extracting text (OCR), detecting objects, analyzing content, and providing descriptions. It offers prebuilt APIs for tasks like image captioning, object detection, and face analysis.

Azure AI Services: Conversational Language Understanding

The Azure Language service, now part of Azure AI Foundry platform, is a cloud-based API service that applies custom machine-learning intelligence to a user's conversational, natural language text to predict overall meaning, and draw out relevant, detailed information. Its former name was Conversational Language Understanding.

Azure AI Services: Question Answering

The service formerly known as "Azure Question Answering" is now part of Azure AI Language within the Microsoft Foundry platform. It is now referred to as Question Answering, a modular tool used to create conversational layers over data.

Azure AI Bot Service

Azure AI Bot Service is an integrated environment and set of tools for building, connecting, managing, and deploying intelligent, conversational bots that interact with users via text, speech, and rich cards across various channels. This service leverages the Microsoft Bot Framework SDK for coding in multiple languages.

Azure Health Bot

The Azure AI Health Bot Service enables healthcare organizations to build their own virtual health assistants to interact with patients and manage administrative workloads. It combines medical intelligence with natural language processing to handle patient interactions like symptom checking, appointment scheduling, and information delivery. It offers built-in medical content, customization tools for specific clinical needs, and integration capabilities with electronic medical records systems.

Azure Open Datasets

Azure Open Datasets are curated, cloud-hosted public datasets (e.g., weather, census, holidays), integrated within Microsoft Azure to add "real-world" data to Machine Learning models. These datasets are accessible in Azure Machine Learning, Databricks, and Power BI.

Azure OpenAI

Azure OpenAI refers to the foundational models and powerful reasoning models from OpenAI found in Azure Foundry.

Azure Machine Learning

Azure Machine Learning is a service that accelerates the training, deployment, automation of machine learning (ML) models and manages the machine learning project lifecycle. ML professionals, data scientists, and engineers use it to train and deploy models and manage machine learning operations.

Copilot for Service

Copilot for Service is a service specifically tailored for customer service representatives. It integrates AI capabilities into existing contact centers and CRM systems, such as Salesforce, ServiceNow, and Zendesk. It is designed to accelerate onboarding and case resolution and automate tasks.

Copilot for Finance

Copilot for Finance is an AI assistant integrated within Microsoft 365 (e.g., Excel, Outlook, and Teams) and Dynamics 365 Finance. It is designed to automate repetitive financial workflows and provide insights by connecting directly to ERP systems like Dynamics 365 Finance and SAP.

Microsoft 365 Copilot for Sales

Microsoft 365 Copilot for Sales is an AI assistant specifically designed to automate administrative tasks and provide insights for sales professionals. It is designed to connect the Microsoft 365 ecosystem (e.g., Outlook, Teams, Word) directly to CRM systems such as Dynamics 365 Sales and Salesforce.

Microsoft Bot Framework

Microsoft Bot Framework (and the associated Azure AI Bot Service) are a collection of libraries, tools, and services that permit organizations to build, test, deploy, and manage intelligent bots. The Bot Framework includes a modular and extensible SDK for building bots and connecting to AI services. Microsoft indicates that this service is undergoing a transition at the end of 2025 in that the core Bot Framework SDK repository on GitHub has been archived and support tickets for the Bot Framework SDK will no longer be serviced after December 2025. Existing bots built with the SDK will continue to function. Microsoft is encouraging developers to use Microsoft 365 Agents SDK and Microsoft Copilot Studio.

Microsoft Genomics

Microsoft Genomics was a service for the rapid, secondary analysis of human genomes. Microsoft indicates that the service will retire in early January 2026.

Seeing AI

Seeing AI, part of Microsoft's accessibility suite, is a free Microsoft research app designed specifically for the blind and low-vision community. It uses artificial intelligence to narrate the world by turning visual information into an audible experience through a smartphone camera.

Internet of Things

Azure Digital Twins

Azure Digital Twins is a service that permits the creation of detailed digital models (digital twins) of physical environments (e.g., buildings, factories, or entire cities) and their connection to real-world data from IoT devices and business systems. The solution builds a “twin graph” by modeling relationships between people, places, and devices, permitting queries to assist in decision-making.

Event Grid

Azure Event Grid is a scalable and managed publish-subscribe service for message distribution. The service offers flexible message consumption patterns and uses the Message Queuing Telemetry Transport (“MQTT”) and HTTP protocols. The service routes events from any source to any destination (e.g., functions, webhooks, queues) for event-driven architectures, serverless apps, and app integration. It acts as a central event backbone, connecting publishers (e.g., a storage upload) with subscribers (e.g., a data processing function).

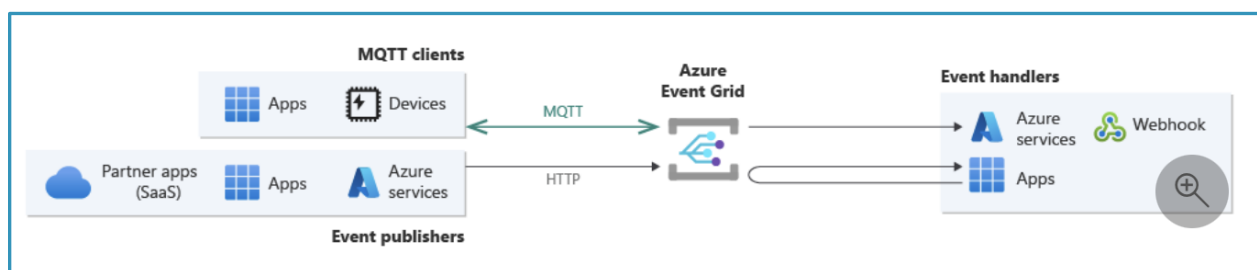


Image 8: Azure Event Grid

Azure IOT Central

IoT Central is an *application platform as a service* that simplifies building, deploying, and managing large-scale IoT solutions. It does this by providing a user interface, device management, data visualization, and integration capabilities. Organizations can quickly connect devices, monitor device telemetry, create rules, and manage devices and their data throughout their life cycle. IoT Central runs on IoT Hub.

Azure IOT Hub

IoT Hub is a service that enables bidirectional communications between IoT devices and a solution back end. The service provides multiple device-to-cloud and cloud-to-device communication options, including one-way messaging, file transfer, and “request-reply” methods. It provides (i) built-in declarative message routing to other Azure services, (ii) a “queryable” store for device metadata and synchronized state information; and (iii) extensive monitoring for device connectivity and device identity management events. It also enables secure communications and access control using per-device security keys or X.509 certificates and includes device libraries for popular languages and platforms.

Azure Sphere

Azure Sphere is a platform comprised of a secured, connected, crossover microcontroller unit, a custom high-level Linux-based operating system, and a cloud-based security service that provides continuous, renewable security. The Azure Sphere MCU integrates “real-time” processing capabilities with the ability to run a high-level operating system. This enables the creation of secure, internet-connected devices that can be updated, controlled, monitored, and maintained remotely.

Azure Time Series Insights

Azure Time Series Insights was a fully managed analytics, storage, and visualization service designed to ingest and analyze large volumes of time-series data from IoT devices. Microsoft indicates that the service was retired in March 2025 and recommends the use of Azure Data Explorer and Microsoft Fabric as successors.

Device Update for IoT Hub

Device Update for IoT Hub is an end-to-end, cloud-based platform used to publish, distribute, and manage “over-the-air” updates for IoT devices.

Azure Event Hubs

Azure Event Hub is a data ingestion service that can process millions of events per second from numerous sources. It is used to build data pipelines, capture and retain event streams, and make data available for analysis by other services.

Microsoft Cloud for Sustainability

Microsoft Cloud for Sustainability is a SaaS offering designed to help organizations record and report on their environmental impact. Its components include Microsoft Sustainability Manager; Sustainability Data Solutions in Microsoft Fabric; and Emissions Impact Dashboard.

Microsoft Defender for IoT

Microsoft Defender is a suite of tools that provides security protection for an organization’s endpoints (including IoT devices), identities, email, and applications. This service is not within the scope of this FPIA but is examined in a separate FPIA concerning Microsoft Security Services.

Azure Notification Hubs

Azure Notification Hubs is a service that provides a multi-platform, scaled out “push” infrastructure that enables organizations to send mobile push notifications from any backend to and mobile platform by making a single API call.

Integration

API Management

API Management is a PaaS that enables organizations to securely publish, govern, and manage the full lifecycle of their APIs. It acts as a central control plane for all APIs, whether traditional services or AI models, across various environments. It allows an organization to protect and optimize APIs with Key, JSON Web Token validation and IP filtering.

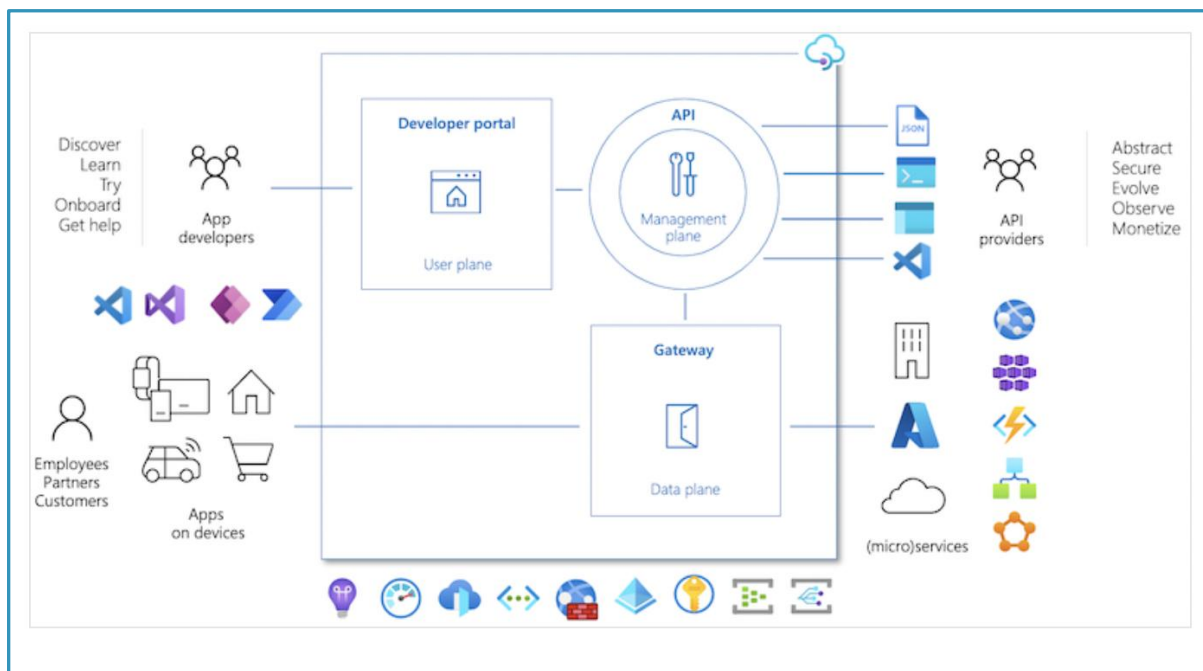


Image 9: Azure API Management

Azure API Management is made up of an API *gateway*, a *management plane*, and a *developer portal*, with features designed for different audiences in the API ecosystem:

- **API Gateway:** This is the single-entry point for all API calls. The gateway acts as a façade to an organization’s backend services, enforces security policies (e.g., authentication and rate limits), transforms requests and responses, handles caching, and provides metrics and logs for monitoring.
- **Management Plane:** This is the administrative interface (accessible via the Azure portal, PowerShell, CLI) where API providers configure API settings, define policies, package APIs into “products,” and manage users.
- **Developer Portal:** An automatically generated, customizable website that serves as a hub for API consumers. Developers can find APIs, read documentation, test APIs using an interactive console, manage their subscriptions, and access usage analytics.

These components are Azure-hosted and fully managed by default. API Management is available in various tiers differing in capacity and features.

Azure Data Manager for Energy

Azure Data Manager for Energy (formerly Microsoft Data Energy Services) is a PaaS offering for the energy industry, built on the open OSDU® Data Platform and Microsoft Azure, integrating SLB's (formerly Schlumberger) domain expertise. The solution provides strong data management, federation and storage to provide insights for exploration, production, and energy transition.

Azure Logic Apps

Azure Logic Apps is a platform that permits users to automate and orchestrate tasks, business processes, and workflows when they need to integrate apps, data, systems, and services across enterprises or organizations. It provides a serverless and visual designer with pre-built connectors to connect different systems without writing complex code, although it also supports advanced development. A Logic App workflow starts with a trigger and includes a series of actions, making it ideal for tasks like document processing, scheduled jobs, and employee onboarding.

Azure Service Bus

Data is transferred between different applications and services using messages. A message is a container decorated with metadata and contains data. Azure Service Bus is a messaging service that acts as a broker/ third-party/intermediary to connect different applications, enabling them to communicate asynchronously and in a decoupled way. This service helps prevent system overloads and ensure messages are not lost. It uses features like queues (point-to-point) and topics/subscriptions (publish-subscribe) to buffer messages.

Universal Print

Universal Print is a printing solution that allows for the management of printers centrally via Azure. The service integrates with Microsoft 365, and offers features like driverless printing, centralized management, and secure print release.

Identity

Active Directory B2C

Azure Active Directory (Azure AD) B2C is an identity management service that enables organizations to customize and control how their customers sign up, sign in, and manage their profiles when using organizational applications. Azure AD B2C enables these actions while protecting the identities of customers at the same time. It provides a "white label" Identity-as-a-Service, handling authentication and security, so developers can avoid building login systems. Microsoft indicates that as of May 2025 Azure AD B2C will no longer be available to purchase for new customers, but current Azure AD B2C customers can continue using the product. The product experience, including creating new tenants or user flows, will remain unchanged; however, new tenants can only be created with Azure AD B2C P1. Microsoft further indicates that Azure AD B2C P2 will be discontinued in March 2026 for all customers. Its replacement, not within the scope of this FPIA, will be Microsoft Entra External ID.

Microsoft Entra Domain Services

Microsoft Entra Domain Services provides domain services such as group policy, lightweight directory access protocol, and Kerberos/NTLM authentication. The service enables organizations to run legacy applications in the cloud that cannot use modern authentication methods. It integrates with an organization's existing Microsoft Entra tenant and permits users to sign in to services and applications connected to the managed domain using their existing credentials. It does this by replicating identity information from Microsoft Entra ID to work with Microsoft Entra tenants that are cloud-only or synchronized with an on-premises AD DS environment.

Microsoft Entra ID

Microsoft Entra ID is an identity and access management service that provides the identity, authentication and policy management to secure users, devices, apps, and resources. Every new Microsoft Entra directory includes an initial domain name, like contoso.onmicrosoft.com.

Microsoft Entra Permissions Management

Microsoft Entra Permissions Management is a cloud infrastructure entitlement management solution that provides extensive visibility into permissions assigned to all identities. The service detects, automatically right-sizes, and continuously monitors unused and excessive permissions.

Global Secure Access

Global Secure Access is the unifying term used for both Microsoft Entra Internet Access and Microsoft Entra Private Access. Both of these services make up Microsoft's Security Service Edge solution. Global Secure Access is located in the Microsoft Entra admin center.

Microsoft Entra Internet Access protects access to internet and SaaS apps with an identity-based Secure Web Gateway.

Microsoft Entra Private Access provides users – whether in an office or working remotely – secure access to private, corporate resources. The service builds on the capabilities of the Microsoft Entra application proxy and extends access to any private resource, port, and protocol. It offers per-app adaptive access based on Conditional Access policies, for more granular security than a VPN.

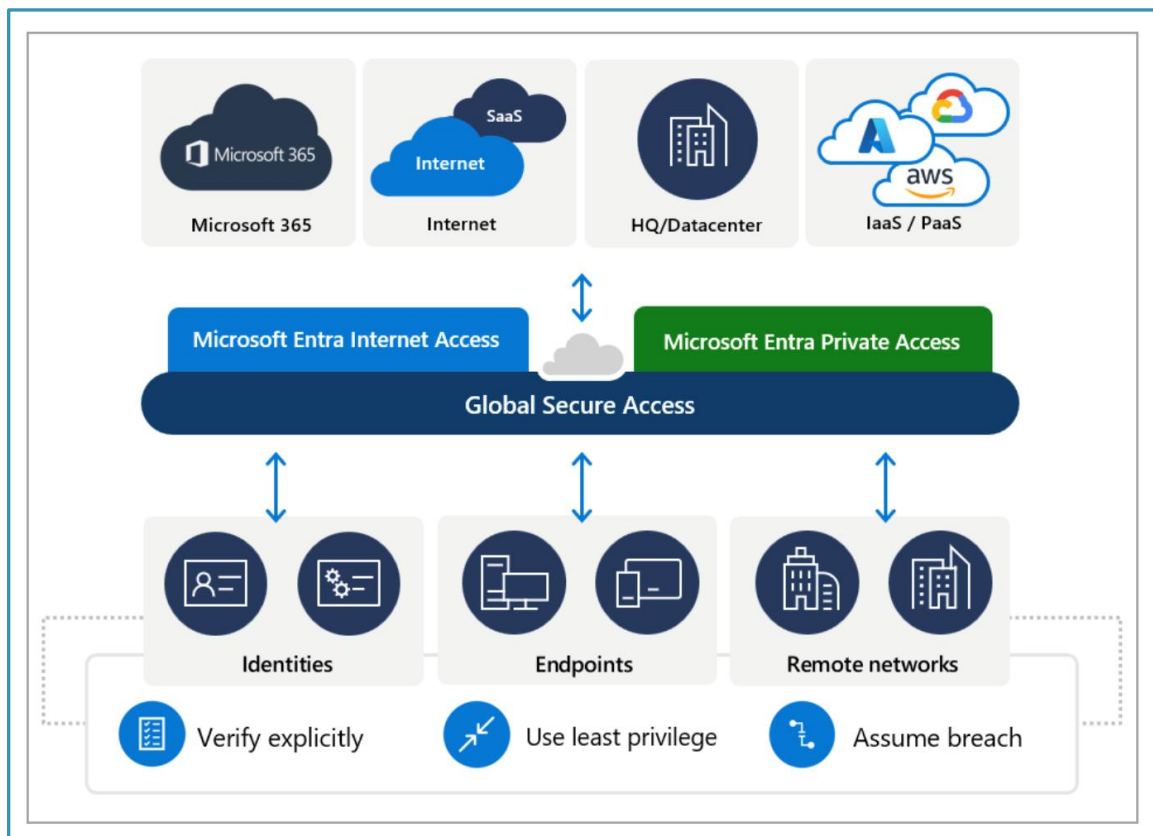


Image 10: Azure Global Access

Microsoft Purview

Microsoft Purview (formerly Azure Purview) is a data governance, security, and compliance platform. This platform is not within the scope of this FPIA but is examined in a separate FPIA concerning Microsoft Security Services.

Management & Governance

Application Change Analysis

Azure Application Change Analysis is a feature of Azure Monitor that tracks configuration and code changes in Azure resources and applications. It is used to pinpoint what caused issues such as performance degradation or outages, showing *who*, *what*, and *when* changes occurred across infrastructure (VMs, App Services) and application layers.

Azure Automation

Azure Automation provides an automation and configuration service for both Azure and non-Azure environments. The service includes process automation, configuration management, shared capabilities, and heterogeneous features to automate frequent, error-prone management tasks across Azure, on-premises, and other clouds, using scripts (Runbooks) and configuration management. It provides a secure environment for orchestrating processes, managing updates, and tracking changes in hybrid IT environments. Azure Automation can process a template to deploy an Azure resource and then process a set of post-deployment configuration tasks.

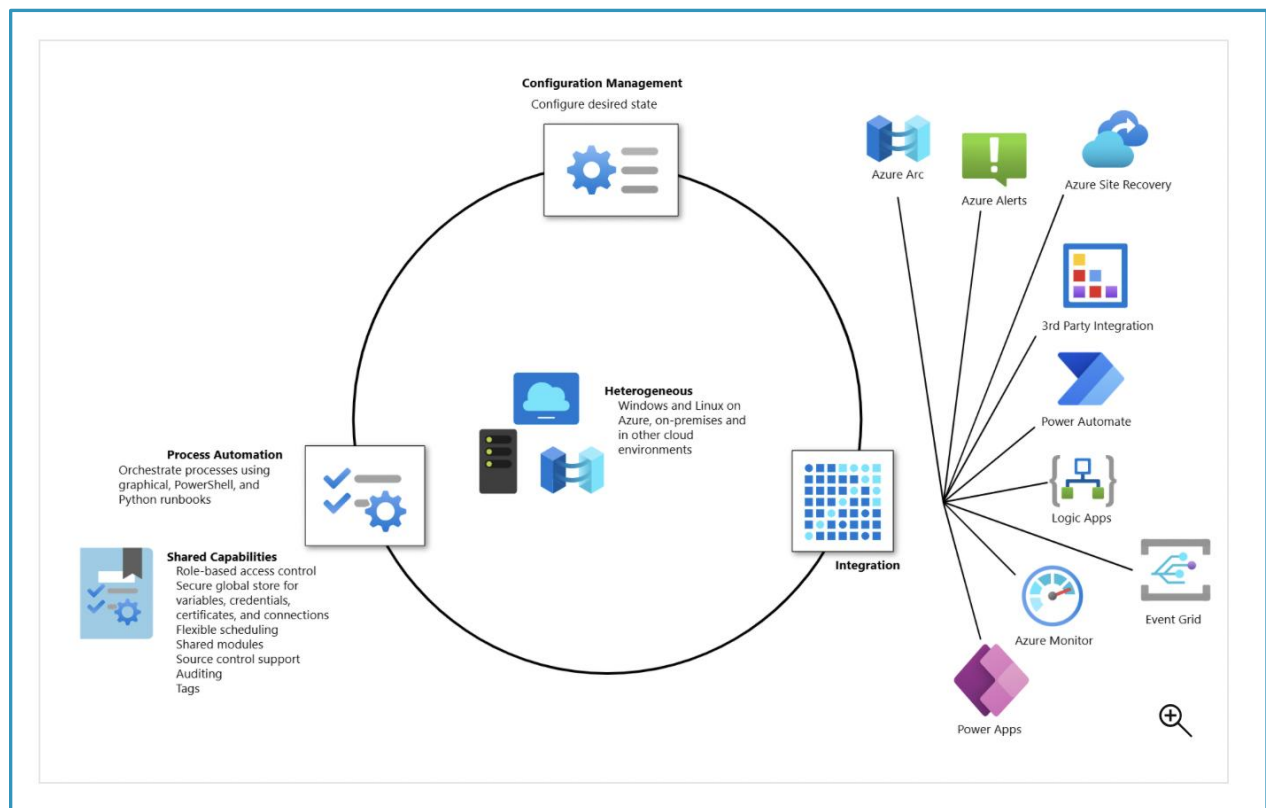


Image 11: Azure Automation

Azure Advisor

Azure Advisor is a service that analyzes resource configuration and usage telemetry and recommends solutions to help improve the performance, security, and availability of resources.

Azure Blueprints

Azure Blueprints is a service for defining and deploying standardized cloud environments, essentially acting like an architectural blueprint for Azure resources, policies, access controls, and ARM templates. Microsoft indicates that the Azure Blueprints service is still available but is set for deprecation in July 2026.

Azure Lighthouse

Azure Lighthouse is a service for managing Azure resources across multiple customer tenants or internal enterprise environments from a single, centralized control plane. It allows service providers to perform management tasks on customer subscriptions/resource groups without needing direct login to each tenant.

Azure Managed Applications

Azure Managed Applications permits publishers to package complex cloud solutions using ARM templates, offering them via Azure Marketplace or internal catalogs for customers to easily deploy and operate, while the publisher retains management/support via a dedicated resource group in the customer's subscription.

Azure Migrate

Azure Migrate is a service that assesses on-premises workloads for migration to Azure. It assesses the migration suitability of on-premises machines; performs performance-based sizing and provides cost estimations for running on-premises machines in Azure.

Azure Monitor

Azure Monitor is a service for collecting, analyzing, and responding to monitoring telemetry data (e.g., logs and metrics) to ensure performance, availability, and proactive issue detection. It uses tools like Application Insights, Workbooks, and Log Analytics to provide a global view of resource health.

Azure Policy

Policies enforce different rules and effects over resources, so those resources remain compliant with corporate standards and service level agreements. Azure Policy is a service to create, assign, and manage policies. The service also evaluates resources for non-compliance with assigned policies.

Azure Quotas

Azure Quota is a service that provides a centralized interface and programmatic access point to manage limits across an organization's Azure subscriptions. The Azure Portal provides a visual dashboard to view usage, monitor limits, and request increases. There is also a Quota REST API that permits programmatic retrieval of current limits and usage or request increases for specific resource providers like Compute and Machine Learning. Similarly, each individual Azure subscription also has a "Usage + quotas" blade under its settings for quick, filtered access to that specific subscription's data.

Resource Graph

Azure Resource Graph is a tool for cloud inventory management, governance, compliance, and auditing of Azure resources. It is used to query and explore the properties of Azure infrastructure resources (e.g., virtual machines, storage accounts) across multiple subscriptions for inventory management, governance, and compliance purposes. It provides a way to manage and audit an Azure environment using the Kusto Query Language.

Azure Resource Manager

Azure Resource Manager is a service to deploy, update, or delete all resources in a single coordinated operation. The service also has security, auditing, and tagging features to help manage resources after deployment.

Azure Resource Mover

Azure Resource Mover is a service to simplify moving Azure resources (e.g., virtual Machines, networks, disks) between different Azure regions, resource groups, or subscriptions. The service provides a centralized hub to plan and prepare moves with features such as dependency identification, automated cleanup, and testing.

Azure Signup Portal

The Azure Signup Portal is where individuals and organizations register for a Microsoft Azure account. It is distinct from the management portal, serving as the starting point for setting up billing, identity verification, and initial subscriptions.

Azure Update Manager

Azure Update Manager is a service for centrally managing and governing software updates for Windows and Linux machines across Azure, on-premises, and other clouds (via Azure Arc). The service provides a single dashboard for monitoring compliance, scheduling, and deploying updates in real-time or automatically to keep servers secure and functional. It offers features like automated guest patching, maintenance windows, and “on-demand” updates.

Azure Cloud Shell

Azure Cloud Shell is an interactive shell for managing Azure resources. It provides the flexibility of choosing the preferred shell experience: Linux users can opt for a Bash experience, while Windows users can opt for PowerShell.

Microsoft Cost Management

Microsoft Cost Management is a suite of free tools within Azure to track, analyze, manage, and optimize an organization’s cloud spending by providing visibility into costs. It permits organizations to monitor usage by resource, service, or tags, forecast spending, and integrate cost data for financial governance.

Azure Portal

The Azure Portal (also known as the Azure Management Portal) is a web-based console to create and manage Azure resources. It includes a customizable dashboard, tools for managing Azure resources, and provides an entryway into subscription settings and billing information.

Security

Azure Confidential Computing is a cloud solution that protects "data in use" by isolating it within a hardware-based Trusted Execution Environment. When Azure Confidential Computing is used with data encryption "at rest" and "in transit", it extends data security to further protect data while confidential computing is in use. This capability is helpful for organizations that seek further protection for sensitive data and applications hosted in cloud environments.

Azure Confidential Ledger

Azure Confidential Ledger is a service for storing sensitive data immutably. It provides tamper-proof, cryptographically verifiable evidence that data has not been altered, where records need high integrity for regulatory compliance and archival purposes. Azure Confidential Ledger combines cryptographic techniques and blockchain technology.

Azure Dedicated HSM/Azure Cloud HSM

Azure Dedicated HSM (Hardware Security Module) is a HSM service allowing for full customer control. Azure Cloud HSM is single-tenant, managed HSM cluster is a successor to Azure Dedicated HSM. The service provides cryptographic key storage in Azure for organizations who require FIPS 140-2 Level 3-validated devices. In using this service, organizations have full administrative control for high-assurance applications like SSL/TLS, code signing, and custom key management.

Azure Payment HSM

Azure Payment HSM is a service delivered using Thales "payShield" 10K payment hardware security modules. These modules are physical devices that provide cryptographic key operations for "real-time", critical payment transactions in the Azure cloud. Payment HSMs are provisioned and connected directly to users' virtual network. Such HSMs are under an organization's sole administration control.

Customer Lockbox for Microsoft Azure

Customer Lockbox for Microsoft Azure provides an interface for customers to review and approve or reject customer data access requests. It is used in cases where a Microsoft engineer needs to access customer data, whether in response to a customer-initiated support ticket or a problem identified by Microsoft.

Azure Key Vault

Azure Key Vault is a service that allows organizations to store and manage passwords, connection strings, certificates and cryptographic keys in a secure manner within the Azure environment. Key Vault service supports two types of containers: vaults and managed hardware security module ("HSM") pools. Key Vault allows developers to use these secrets without embedding them directly in their applications, and it can also perform cryptographic operations on their behalf. With Azure Key Vault, compared to Azure Key Vault HSM, Microsoft manages the underlying hardware. The premium tier of Key Vault offers HSM protection, but it is still within a shared environment with a Microsoft-controlled "root of trust".

Microsoft Azure Attestation

Attestation is a process for demonstrating that software binaries were properly instantiated on a trusted platform. Microsoft Azure Attestation is a service for remotely verifying the trustworthiness of a platform and integrity of the binaries running inside it.

Microsoft Security Copilot

Microsoft Security Copilot (formerly known as Microsoft Copilot for Security) is a generative AI-powered assistant used to respond to threats, manage risks, and hunt for threats faster by using natural language to process signals, summarize incidents, and automate tasks. It assists in accelerating investigations, streamlining workflows, and reducing manual effort.

Microsoft Defender for Cloud

Microsoft Defender is a suite of tools that provides security protection for an organization's endpoints, identities, email, and applications. This service is not within the scope of this FPIA but is examined in a separate FPIA concerning Microsoft Security Services.

Microsoft Defender Threat Intelligence

Microsoft Defender is a suite of tools that provides security protection for an organization's endpoints, identities, email, and applications. One of the tools in Microsoft Defender is Microsoft Defender Threat Intelligence. This service is not within the scope of this FPIA but is examined in a separate FPIA concerning Microsoft Security Services.

Microsoft Sentinel

Microsoft Sentinel is a scalable, cloud-native SIEM solution for threat detection, investigation and response. It uses both Microsoft's threat intelligence stream and permits organizations to incorporate their own threat intelligence resources. This service is not within the scope of this FPIA but is examined in a separate FPIA concerning Microsoft Security Services.

Multi-Factor Authentication

The Azure Multi-factor Authentication is a service that requires users to provide two or more verification methods to gain access to resources. It is now part of Microsoft Entra ID (formerly Azure Active Directory).

Windows Autopatch

Windows Autopatch is a service that automates the deployment and orchestration of updates for Windows, Microsoft 365 Apps, Microsoft Edge, and Microsoft Teams. Windows Autopatch is not to be confused with Microsoft Update. Microsoft Update is the underlying cloud infrastructure and catalog of all software updates for Windows and other Microsoft products. Windows Autopatch is a service that uses that infrastructure.

Media

Azure Media Services

Azure Media Services was a service for encoding, streaming, or content protection. Microsoft indicates that the service was retired in June 2024.

Web

Azure Fluid Relay

The Fluid Framework is an open source, platform independent framework. Azure Fluid Relay is a managed offering for the Fluid Framework that helps developers build "real-time" collaborative experiences and replicate state across connected JavaScript clients in "real-time".

Azure Maps

Azure Maps is a collection of geospatial services and SDKs that lets developers add location intelligence (e.g., maps, search, routing, traffic, weather, time zones) to web and mobile apps. The service uses REST APIs to render vector and raster maps in multiple styles and satellite imagery. It enables features like geospatial analytics, time zone and geolocation services, search services, asset tracking, vehicle routing, and data visualization.

Azure SignalR Service

Azure SignalR Service (built on ASP.NET SignalR) serves as a scalable proxy. This service simplifies adding real-time communication (e.g., chat, live updates, notifications) to web apps without handling server provisioning, scaling, or connection management. This “real-time” functionality allows the service to push content updates to connected clients without the need for them to poll the server or submit new HTTP requests for updates.

Azure Spring Apps

Azure Spring Apps is PaaS offering for building, deploying, scaling, and monitoring Spring Boot and Spring Cloud applications in the cloud. Microsoft indicates that all Azure Spring Apps plans will be retired in March 2028 and recommends migration to Azure Container Apps and Azure Kubernetes Service.

Azure Web PubSub

Azure Web PubSub is a service for the building of web applications to enable bi-directional communication and data exchanges between server and clients. The service supports large scale client connections as well as a wide variety of client SDKs and programming languages.

Mixed Reality

Azure Remote Rendering

Azure Remote Rendering is a service that renders complex, high-fidelity 3D models in the cloud and streams the resulting visuals in real-time to edge devices. It lets developers handle massive models on less powerful devices, integrating with apps via SDKs for Unity or C++.

Hybrid & Multicloud

Azure Arc enabled System Center Virtual Machine Manager

Azure Arc-enabled System Center Virtual Machine Manager is a hybrid management solution that connects an organization's on-premises infrastructure to the Azure Resource Manager control plane. It serves as a "bridge" that allows organizations to manage Hyper-V virtual machines located in their private data centers as if they were native Azure resources.

Azure Arc enabled VMware vSphere

Azure Arc-enabled VMware vSphere is a hybrid cloud service that allows organizations to manage VMware vCenter-managed virtual machines alongside native Azure resources from the Azure Resource Manager control plane.

Azure Center for SAP Solutions

Azure Center for SAP solutions is service that enables organizations to create and run SAP systems as a unified workload on Azure. It creates a logical representation of an organization's SAP landscape known as a Virtual Instance for SAP solutions, which allows for the management of the entire system as a single entity rather than as disconnected virtual machines, disks, and networks.

Azure Kubernetes Service on AzureStack HCI

Azure Kubernetes Service enabled by Azure Arc on Azure Local is a managed Kubernetes service for the deployment and management of containerized applications on-premises, in datacenters, or at edge locations.

Azure Operator Nexus

Azure Operator Nexus is a hybrid cloud platform for telecommunication operators. The platform automates the lifecycle management of the infrastructure, including network fabric, bare-metal hosts, and storage appliances. It also automates the lifecycle management of tenant workloads for containerized network functions and virtualized network functions.

Azure Operator Service Manager

Azure Operator Service Manager is an orchestration service for telecom operators that automates the lifecycle (modeling, deployment, updates, deletion) of complex, multi-vendor network services on Azure Operator Nexus and other Arc-connected platforms.

Azure Monitor for SAP solutions

Azure Monitor for SAP solutions is a tool/service that provides centralized monitoring for SAP landscapes running on Azure. The service collects and analyzes data from SAP applications, databases (HANA, SQL Server), OS (Linux), and Azure infrastructure to help visualize, troubleshoot, and optimize performance and availability through the use of dashboards, alerts, and unified telemetry. It is a free tool that simplifies monitoring by correlating data from different layers (application, database, infrastructure) into one place.

[Remainder of page left intentionally blank.]

ANNEX B – CLOUD COMPUTING GUIDANCE

The Treasury Board Secretariat (“TBS”) has issued guidance for federal departments planning to adopt cloud-services, and store information - classified up to and including Protected B - in the cloud. While the guidance is federal policy for federal government entities concerning the procurement of cloud-services, it is also useful for private sector organizations to consider. This guidance consists of requirements that relate to:

- Baseline Security Controls
- Third-Party Assurance
- Continuous Monitoring
- Information Assurance and Asset Protection
- Secure Software Development
- Data Residency
- Privileged User Access Controls
- Use of Encryption
- Personnel Screening
- Physical Security
- Service Continuity
- Supply Chain Risk Management
- Incident Response

This annex describes the requirements of the TBS Guidance and how Microsoft operates to meet those requirements.

Baseline Security Controls. TBS directs departments to the *Government of Canada’s Security Control Profile for Cloud-Based GC IT Services*¹⁶³ for a set of recommended baseline security controls to be present and implemented by cloud-service providers.

The Security Control Profile was designed to consider generic departmental requirements when dealing with deliberate and accidental threats. Security controls, applied to cloud service providers, should include:

- Implementation of “Defence-in-depth”.
- An ability to provision users with “least-privilege”.
- An ability to prevent, detect, analyze, respond, and recover from attacks.
- Layered Defence.
- An ability to isolate the customer institution’s tenancy.

How Microsoft adheres to these requirements is described in detail in [Annex C](#).

Third-Party Assurance. TBS encourages departments to leverage independent reporting to validate the service provider’s security controls such as:

- ISO/IEC 27001.
- ISO/IEC 27017.
- ISO/IEC 27018.
- Federal Risk and Authorization Management Program (FedRAMP).
- Payment Card Industry Data Security Standard (PCI-DSS).
- Cloud Security Alliance (CSA) Security, Trust and Assurance Registry (STAR).
- AICPA Service Organization Controls (SOC) audit reports or certifications.

¹⁶³ Available at: <https://www.canada.ca/en/government/system/digital-government/modern-emerging-technologies/cloud-services/government-canada-security-control-profile-cloud-based-it-services.html>.

Microsoft has completed ISO/IEC 27001:2013, ISO/IEC 27018, SOC 1 Type 2, SOC3, and FedRAMP attestations for Azure. Copies of the relevant certificates available through the Microsoft Service Trust Portal.

Continuous Monitoring. Cloud-service providers are expected to continuously monitor their cloud services in order to detect changes in the security posture of the service environment. This includes including monitoring their security controls, assessing security controls regularly **and** demonstrating that the security posture is continuously acceptable.

Centralized monitoring, correlation, and analysis systems manage the large amount of information generated by devices within the Azure environment, providing both visibility and alerts to the Microsoft teams that manage the service.

Microsoft administrative operations, including system access, are logged to provide an audit trail if unauthorized or accidental changes are made. In addition to addressing software vulnerabilities, one aspect of security is the minimization of operational weaknesses. For Azure, Microsoft uses an Operational Security Assurance (“OSA”) framework, which supports continuous monitoring, provides operational security guidelines, and validates adherence to those guidelines. The objective is to increase resiliency by decreasing the amount of time needed to detect and respond to security threats.

OSA is built on the fundamental principles of modeling threats, designing secure configurations, testing operational effectiveness, and promptly responding to and remediating security concerns. The requirements for some domains involve collecting documentation or training staff to ensure that they have skills to provide work of appropriate quality. Other domains with security requirements can take advantage of automated solutions that can demonstrate that operational baseline requirements are being addressed.

The scope of OSA is limited to a set of control objectives or domains most likely to be affected by external Internet-based attack. This set of domains closely maps to the control areas that are used by NIST 800-53 and ISO 27001. OSA defines the aspects of these domains by first establishing baseline requirements that each service should meet or exceed. These baseline requirements are then used to establish a test plan that can be used to validate a service’s security during an assessment.

Different sources of information continually feed into the OSA methodology:

- Organizational learning and improvements, used to improve Microsoft services.
- International standards and mature external security practices, such as updates to NIST SP 800-53, ISO 27001, and other relevant practices.
- Security incidents and threats, and the corresponding incident response measures.
- Industry associations and experts.
- Threat intelligence programs using data from Internet services and more than 600 million computers worldwide.
- Security technologies and security solutions developed both inside and outside of Microsoft.

Secure Software Development. Cloud-based services are expected to be designed and developed following industry best practices (for example, SAFECode Fundamental Practices for Secure Software Development, ISO/IEC 27034 and OWASP) to minimize security issues that could compromise Government of Canada (GC) information, cause a loss of service or enable other malicious activity.

Azure code development adheres to Microsoft’s Security Development Lifecycle (“SDL”), a process that allows developers to build more secure software and address security compliance requirements.

The SDL¹⁶⁴ is a Microsoft-wide, mandatory software development process with the objective of reducing the number and severity of vulnerabilities in Microsoft software. Since 2004, the SDL has been used to institutionalize and embed security requirements into the Microsoft product lifecycle (i.e., from planning to design, development, and deployment phases). After a product is made available to customers, the focus shifts to vulnerabilities. Microsoft indicates that it has created teams have been created to respond to any incidents, and their findings inform the SDL to help improve future products. Microsoft indicates that Microsoft's SDL conforms with ISO 27034.

Data Residency. The TBS Guidance states that federal entities departments are expected to apply the Directive on Service and Digital¹⁶⁵ when implementing safeguards for electronic data residency. The Directive states that the Departmental CIO is responsible for:

“Ensuring computing facilities located within the geographic boundaries of Canada or within the premises of a Government of Canada department located abroad, such as a diplomatic or consular mission, be identified and evaluated as a principal delivery option for all sensitive electronic information and data under government control that has been categorized as Protected B, Protected C or is Classified.”

Data location information specific to Microsoft services is located online.¹⁶⁶ The DPA also has specific language pertaining to Microsoft's commitments to data transfers and location of customer data.

Identity, Credential and Access Management. The controls required under this section of the Treasury Board Guidance largely are the responsibility of government departments. The only specific requirement, when accessing cloud-based services, is the use of strong authentication mechanisms, such as two-factor or multi-factor authentication.

Microsoft provides multi-factor authentication for Azure services¹⁶⁷. The options available are:

- “Call my mobile phone”: The user receives a phone call that asks him/her to press the pound key. Once the pound key is pressed, the user is logged in.
- “Text code to my mobile phone”: The user receives a text message containing a six-digit code that he/she must enter into the portal.
- “Call my office phone”: This is the same as “Call my mobile phone”, but it enables the user to select a different phone if he/she does not have a mobile phone readily available.
- “Notify me through app”: The user previously configured a smartphone app (“Authenticator”), and he/she receives a notification in the app that he/she must confirm the login. Smartphone apps are available for Windows Phone, iPhone, and Android devices.
- “Show one-time code in app”. The same smartphone app is used. Instead of receiving a notification, the user starts the app and enters the six-digit code from the app into the portal.

Users and groups can be enabled for Azure Multi-Factor Authentication to prompt for additional verification during the sign-in event. Security defaults are available for all Microsoft Entra ID tenants to enable the use of the Microsoft Authenticator app for all users.

Users can register themselves for both self-service password reset and Azure Multi-Factor Authentication in one step. Administrators can define what forms of secondary authentication can be used. Azure Multi-Factor Authentication can also be required when users perform a self-service password reset to further secure that process.

¹⁶⁴ Further information concerning SDL is publicly available at: <https://www.microsoft.com/en-us/sdl/default.aspx>.

¹⁶⁵ Located at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32601>. See Section 4.4.3.14.

¹⁶⁶ See “Where is Your Data Located”, available at: <https://www.microsoft.com/en-ca/trust-center/privacy/data-location>.

¹⁶⁷ Further information concerning authentication is available at: <https://docs.microsoft.com/en-us/azure/active-directory/authentication/concept-mfa-howitworks>.

For more granular controls, conditional access policies can be used to define events or applications that require MFA. These policies can allow regular sign-in events when the user is on the corporate network or a registered device, but prompt for additional verification factors when remote or on a personal device.

Network Security. TBS guidance suggests that cloud-service providers should only make use of CSE-approved cryptographic algorithms and protocols, as outlined in CSE's *ITSP.40.111 Cryptographic Algorithms for Unclassified, Protected A, and Protected B Information*¹⁶⁸ and CSE's *ITSP.40.062 Guidance on Securely Configuring Network Protocols*¹⁶⁹

Encryption methods and protocols used for data at rest and data in transit are described at length in [Annex C](#).

Personnel Screening. Cloud-service providers are expected to demonstrate the measures they use to assess, grant, and maintain the required level of security screening for their personnel. TBS requires that security screening be:

- Applied in accordance with or use an adequate risk-based approach aligned with the definition and practices in the Treasury Board Directive on Security Screening¹⁷⁰ as stated for Reliability Status.
- Subject to the provisions of any international information-sharing agreements.

Microsoft screens personnel prior to providing access to customer content. "Cloud" background checks are required to be completed prior to creating any service team account with access to such data.

Microsoft's "cloud" background check includes checking criminal history. Microsoft personnel requesting additional access to a multi-tenant role type are required to undergo additional screening. Enforcing screening requirements at the time of account creation and permission assignment ensures that personnel will not be inadvertently granted access prior to successful screening.

Azure personnel with "cloud" and "multi-tenant" designations are re-screened every two years. Access to systems is revoked for personnel who do not pass rescreening.

It should be noted that staff at Microsoft Canada datacentres are screened by the Government of Canada.

Physical Security. Under the TBS Guidance, cloud-service providers are expected to demonstrate measures to ensure asset protection and resilience, such as:

- Physical protection of commercial facilities that host GC data and IT assets.
- Controlled maintenance of information systems and their components to protect their integrity and ensure their ongoing availability.
- Protection of assets that store or process GC data against all forms of tampering, loss, damage, or seizure.

Physical protection measures:

- Must be applied in accordance with, or use an adequate risk-based approach aligned with the physical security controls outlined in the *Government of Canada Security Control Profile for Cloud-Based GC IT Services*¹⁷¹

¹⁶⁸ Available at: <https://www.cyber.gc.ca/en/guidance/cryptographic-algorithms-unclassified-protected-protected-b-information-itsp40111>.

¹⁶⁹ Available at: https://www.cyber.gc.ca/sites/default/files/cyber/publications/itsap40062-e_0.pdf

¹⁷⁰ Available at: <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32805>.

¹⁷¹ Available at: <https://www.canada.ca/en/government/system/digital-government-innovations/cloud-services/government-canada-security-control-profile-cloud-based-it-services.html>.

- Must be applied in accordance with or use an adequate risk-based approach aligned with the practices in the Royal Canadian Mounted Police guidance and standards on physical security.
- Are subject to the provisions of any international information-sharing agreements.

Annex C details the physical security measures Microsoft has in place at its data centres. **It should also be noted that Microsoft's data centre facilities have received facilities clearance at Protected B by PSPC Industrial Security.**

Service Continuity. TBS guidance states that cloud-based services should be designed to take into consideration suitable geographic dispersal and data replication capabilities to meet business continuity objectives.

The Microsoft Canada Data Centres replicate their data across the Toronto and Quebec City facilities to ensure that customer data remains available. This approach to data replication is intended to ensure continuous service delivery.

Service Acquisition. Cloud-service providers are expected to apply supply chain risk management practices to maintain confidence in the security of the sources of information systems and the IT components used to provide their cloud services.

Microsoft does hire subcontractors to provide certain limited or ancillary services on its behalf. Microsoft indicates that such subcontractors may only access Customer Data to deliver the services they have been retained to provide and are prohibited from using Customer Data for any other purpose. Microsoft confirms that it remains responsible for its subcontractors' compliance with the obligations in the DPA.

Prior to the receipt of any Customer Data, subcontractors will have entered into written agreements with Microsoft requiring that the subcontractor abide by terms no less protective than those described in the DPA. Microsoft will not transfer to any third party (not even for storage purposes) personal data that a customer has provided to Microsoft.

Cloud-service providers are also expected to prohibit unauthorized access to, use, or alteration of GC data hosted in their cloud service environments. This restriction includes implementing measures to support an exit strategy, which includes:

- The removal of all GC data by an agreed method and time frame, in alignment with CSE's *ITSP.40.006 v2_IT_Media Sanitization*¹⁷² guidance.
- The ability for the GC to retrieve its data in an agreed format and time frame until the exit process is complete.

Microsoft indicates that no more than 180 days after expiration or termination of Customer's use of an Azure service, Microsoft will disable the account and delete Customer Data from the account. As previously noted, there is no return of data to the customer.

Microsoft wipes storage hard drives using a solution that is compliant with NIST 800-88¹⁷³ (referenced in ITSP.40.006 V2). For hard drives that cannot be wiped, there is a physical destruction process that destroys them and renders the recovery of information impossible. The appropriate means of disposal is determined by the asset type.

Records of hardware destruction are retained and audited through Microsoft's ISO process. All Azure services utilize approved media storage and disposal management services. Paper documents are destroyed using approved methods at the pre-determined "end-of-lifecycle".

¹⁷² Available at: <https://www.cyber.gc.ca/sites/default/files/cyber/publications/itsp-40-006v2-eng.pdf>.

¹⁷³ National Institute of Standards & Technology Special Publication 800-88, Guidelines for Media Sanitization.

Incident Response. Cloud-service providers are expected to notify the Government of Canada when a security incident or breach of government data or their cloud services impacts the government's service. Such notifications should be distributed to:

- Relevant departmental contacts (for example, cloud-based service owner).
- Government of Canada's Computer Incident Response Team.

Microsoft indicates that it will promptly:

- Notify the Customer of the Security Incident.
- Investigate the security incident.
- Provide the customer with detailed information about the security incident.
- Take reasonable steps to mitigate the effects and to minimize any damage resulting from the security incident.

While not a contractual obligation, Microsoft has also recently adopted a policy to notify customers if they believe that a customer account has been targeted or compromised by an individual or group working on behalf of a nation state. This policy has been adopted because a "state-sponsored" attack could be more sophisticated, or more sustained, than attacks from cybercriminals or others. These notifications do not mean that Microsoft's own systems have been compromised. If customers receive such a notification, this means that there is evidence the customer account has been targeted. This allows customers to take additional measures to keep their account secure.

[Remainder of page left intentionally blank.]

ANNEX C - MICROSOFT SECURITY CONTROLS

This Annex provides a more detailed description of Microsoft's approach to service management and information security with respect to Microsoft Azure service offerings, any supporting Azure services and the hosting datacenters.

Security Governance. Security for Azure service offerings involves measures both at the service level and in the form of customer controls that allows customers to customize their use of Azure's services according to specific organizational requirements.¹⁷⁴ ***This requires any Customer to be aware that there is a "shared responsibility" for the protection of personal information.*** The fact that data is held by Microsoft does not mean that only Microsoft is responsible for information security with respect to that data.

Microsoft has adopted the ISO/IEC 27018 code of practice, which concerns the processing of personal information by cloud service providers. Microsoft indicates that Azure complies with the ISO/IEC 27001/27002:2022 standards, which defines the security controls required of an information security management system.

At the service level, Microsoft indicates that it follows a "defense-in-depth" philosophy to protect information at the physical, logical and data layers of any service. Security controls are present at each layer of a service to ensure, in the event of the failure of one security measure, that compensating controls maintain data security.

To support its business activities, including the Azure cloud offerings, Microsoft has developed an Information Security Management System ("ISMS"). Microsoft's ISMS is built on business objectives and security requirements and includes a compliance framework as well as an audit schedule that results in certifications and attestations.

The governance and controls framework of ISMS consists of:

- The *Microsoft Security Policy* suite, which includes the policy, standards, baselines, and standard operating procedures. These are the Microsoft-specific security requirements that must be followed by all Microsoft teams.
- The *Requirements* are a collection of regulatory, statutory, and industry obligations, as well as any additional business requirements that the cloud infrastructure must meet for Microsoft's cloud services.
- The *Control Activities*, which represent operational work in support of security objectives. Each control activity has an owner and maps to both the Microsoft Security Policy suite and the Requirements.
- *Audits*, which ensure that the performance of control activities meet the Requirements.

This framework is connected by various governance workflows – for example, filing an exception when the policy cannot be met or creating and managing issues when gaps are identified between control activities and requirements.

Change Management. Microsoft indicates that an operational change control procedure exists for Azure and system changes. This procedure considers:

¹⁷⁴ Further information about security measures for Azure can be found at: <https://learn.microsoft.com/en-us/azure/security/fundamentals/infrastructure>.

- The identification and documentation of the planned change.
- An assessment process of the potential impact of planned changes.
- Change testing in an approved non-production environment.
- A Change communication plan.
- A Change management approval process.
- A Change abort and recovery plan (when applicable).

Security reviews are conducted every six (6) months.

Capacity planning is conducted to ensure information processing capacity, telecommunications, and environmental support exists and is appropriate during contingency operations.

Changes to any information system are analyzed in a separate test environment before implementation in an operational environment. Production environments are logically partitioned from all other environments (e.g., various development environments) in the same manner. Program managers, Leads or managers can approve changes, but requestors are prohibited from doing so (i.e., they cannot approve changes that they request).

Access. Microsoft has procedures as well as automated and semi-automated systems for granting and revoking access to (i) servers in the "Managed" domain that contains customer applications and data as well as (ii) servers in the "Management" domain which provides systems management functions (e.g., monitoring, backup, troubleshooting, software, and patch management).

Personnel in Microsoft's "Access and Identity Group" manage access via Microsoft Entra ID (formerly known as Active Directory) to the "Managed" and "Management" domains. Authority is granted by Service Managers in each area using the "Least Privilege Access" principle. Microsoft users of production systems are restricted to only one User ID per system.

Microsoft personnel do not have standing access to any service operation ("zero standing permission"). All access control activities are logged and audited.

Microsoft indicates that none of its personnel has standing access to customer content in Azure. Microsoft Azure uses Microsoft Entra ID to manage user accounts. Security group membership must be approved by the designated security group owners within Microsoft Azure. Automated procedures are in place to disable Microsoft Entra ID Directory accounts upon the user's leave date. Domain-level user accounts are disabled after 90 days of inactivity.

Microsoft further indicates that it enforces segregation of duties through defined groups to minimize the risk of unintentional or unauthorized access or change to production systems. Information system access is restricted based on a user's job responsibilities. Services are engineered to minimize, to the extent possible, access to customer content by people performing service operations.

In the event a situation involving a user's content requires the assistance of a Microsoft technician or support engineer, that technician or support engineer must be pre-authenticated and undergo dual approvals within Microsoft to be able to respond to the Customer issue. The Microsoft technician would use a Secure Administrative Workstation to address the issue. Following the completion of support activities, the administrative permissions are then withdrawn. All activities conducted by Microsoft technicians are logged and audited.

Access to the Azure environments is restricted to operations personnel. Development and test teams may be granted access to information provided from the production environment to help troubleshoot issues.

The concept of "data minimization" is used to reduce the actual amount of Customer Data (i.e., usage data, administration account & address book data and all other Customer Data) that is managed on the customer's behalf. This is done by a process of "tiering" to specify which Microsoft internal teams can access what data.

Microsoft personnel build servers before they are commissioned for the multi-tenant environment. Once a server build is complete, the build teams have their permissions removed. When servers are subsequently commissioned, there are limited pathways through which Microsoft personnel may obtain permissions to a system running on a commissioned server. Support staff may obtain access in response to a service ticket that requires access to install software or resolve a problem. In such cases, the audit log would show who logged in and when.

Tenant Isolation. “Multi-tenancy” – the sharing of common infrastructure across numerous customers – is a core concept in the provision of cloud-based services. This, however, raises customer questions about the separation between customers that are hosted on the same infrastructure. This separation, or “tenant isolation”, in a multi-tenant environment is necessary to (i) prevent data leakage or unauthorized access across tenants, and (ii) prevent the actions of one tenant from adversely affecting the service for another tenant.

A tenant exists in a single partition, which is chosen based on properties of the tenant. Secrets and other sensitive information in each partition are encrypted with a dedicated encryption key. Such keys being generated automatically when a new partition is created. Partition information is abstracted away from users.

Based on the number of role instances specified by a customer, Azure creates a virtual machine for each role instance, then runs the role in those virtual machines. These virtual machines in turn, run on a hypervisor that is specifically designed for use in the cloud (the Windows Azure Hypervisor). One virtual machine is special: it runs a hardened operating system called the root operating system that hosts a fabric agent. Fabric agents are used in turn to manage guest agents within guest operating systems on customer virtual machines. Fabric agents also manage storage nodes. The collection of a Windows Azure hypervisor, a root operating system/fabric agent, and customer virtual machines constitute a compute node.

Together with the root operating system, the hypervisor enforces constraints on outside communications and divides resources. This is done using network packet filters that assure that untrusted virtual machines cannot generate spoofed traffic; cannot receive traffic not addressed to them; cannot direct traffic to protected infrastructure endpoints and cannot send or receive inappropriate broadcast traffic. This provides the isolation of the root virtual machine from the guest virtual machines, and the guest virtual machines from one another, all managed by the hypervisor and the root operating system.

The Azure hypervisor is based on the Windows Hypervisor that has been certified as meeting the Common Criteria for IT Security Evaluation¹⁷⁵.

[Remainder of page left intentionally blank.]

¹⁷⁵ The Common Criteria is designed to allow comparisons between independent IT security evaluations. This is achieved by providing a common set of requirements for the security functionality of IT products along with the assurance measures to be applied to them during a security evaluation. The evaluation process is intended to show that the security functionality of the IT product meet the common requirements.

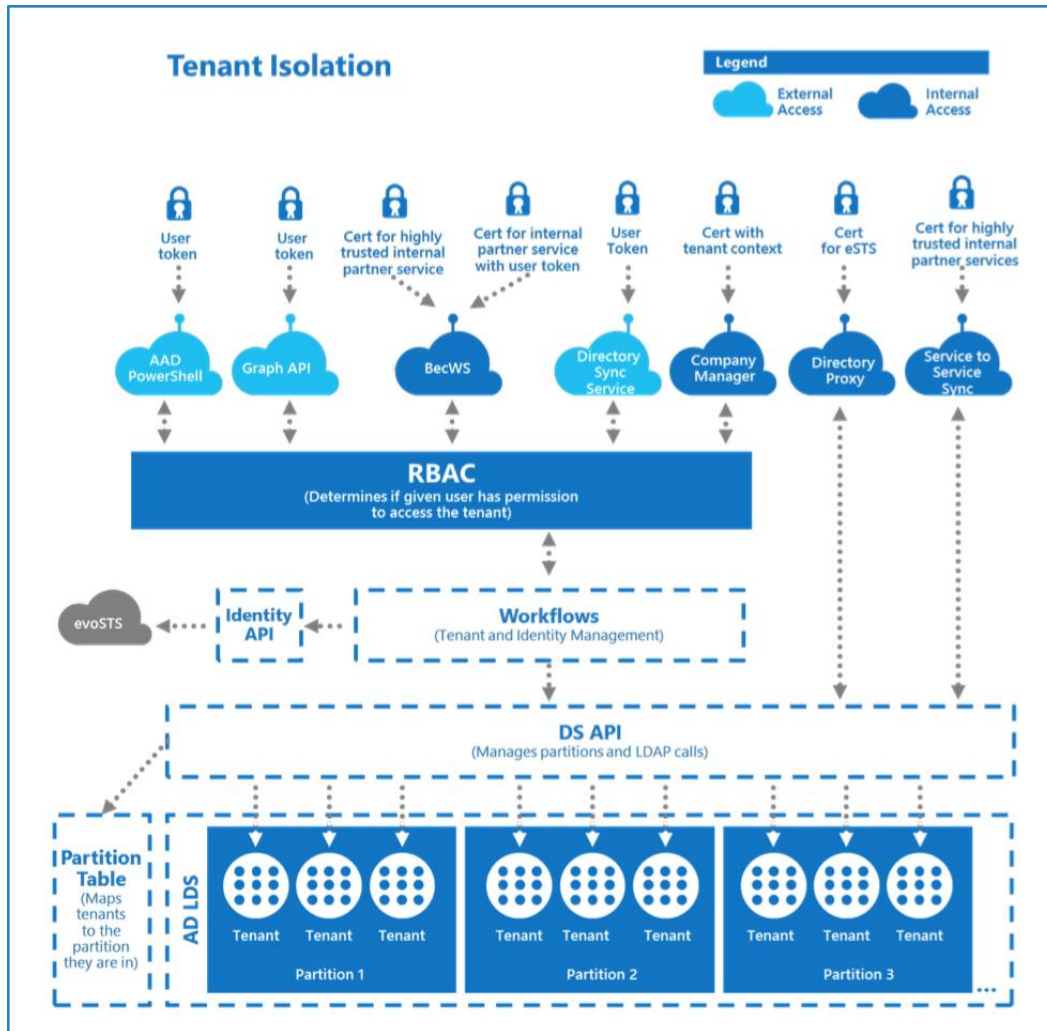


Image 12: Azure AD Internal Topology Indicating Tenant Isolation

Support. Microsoft indicates that most support operations are designed to be self-service or automated. Wherever possible, human intervention is replaced by an automated, tool-based process. This includes routine functions such as deployment, debugging, diagnostic collection, and service restarts. Where human intervention is required, it is controlled and isolated from customer content. All access control activities related to providing support to customers using Azure services, including the RBAC functionality, are logged and audited.

Mandatory personal background checks are required for high privilege access. Microsoft also conducts background verification checks of certain operations personnel and limits access to applications, systems, and network infrastructure in proportion to the level of background verification.

Physical Security. Microsoft's Canadian data centers are in Quebec City and Toronto. These facilities are designed to run "24x7x365" and employ a variety of measures to minimize the possibility of power failures, physical intrusions, and network outages.

The data centre buildings are nondescript and do not advertise that Microsoft Data Centre hosting services are provided at the location. Access to data centre facilities is restricted. The main interior or reception areas have electronic card access control devices on the perimeter door(s), which restrict access to the interior facilities. Rooms within the data centres that contain critical systems (e.g., servers,

generators, electrical panels, network equipment) are either restricted through various security mechanisms such as electronic card access control, keyed lock and/or biometric devices.

While they are located within non-Microsoft facilities, Microsoft operations within the two Canada regions are managed, monitored, and administered by Microsoft personnel. Microsoft indicates that the features of these facilities include:

- Perimeter Security: The data centers have “on-premises” security staff on a 24x7 basis.
- Surveillance: The data centres are monitored using motion sensors, video surveillance, and security breach alarms.
- Physical Access controls: Multi-factor authentication is used, including biometric scanning, badges, and smart cards for data centre access.
- Computer rooms: Rooms are equipped with two-factor access control biometric and card readers as well as cameras.
- Segregation: The internal data centre network is segregated from the external network.
- Power: Uninterruptable power supplies and diesel generators are present in the event of a power failure.

Further measures include:

- Role separation to render the location of specific Customer Data unintelligible to the personnel that have physical access.
- The demagnetization and physical destruction of faulty hard drives.
- The physical destruction of decommissioned hard drives.

Application Security. The provision of Azure services has several technical security controls. These include:

- Security Update management.
- Data Isolation (within multi-tenant environment).
- Data redundancy.
- Data destruction.
- Operating system security patching.
- Multi-factor authentication for service access.

Azure is a multi-tenant service, where deployments of virtual machines of multiple customers are stored on the same physical hardware. Data storage and processing involve the logical segregation of customers of the same service through the structure and capabilities of Microsoft Entra ID Directory - specifically developed to help build, manage, and secure multitenant environments.

Azure code development adheres to Microsoft’s Security Development Lifecycle (“SDL”), a process that allows developers to build more secure software and address security compliance requirements. The SDL¹⁷⁶ is a Microsoft-wide, mandatory software development process with the objective of reducing the number and severity of vulnerabilities in Microsoft software. Microsoft indicates that, since 2004, the SDL has been used to institutionalize and embed security requirements into the Microsoft product lifecycle (i.e. from planning to design, development, and deployment phases). After a product is made available to Customers, the focus shifts to vulnerabilities. Microsoft indicates that it has created teams have been created to respond to any incidents, and their findings inform the SDL to help improve future products. Microsoft indicates that the Microsoft SDL conforms to ISO/IEC 27034-1:2011.

Network Security. It is to be emphasized that security cloud services and resources involve action by both Azure and the Customer. In accepting incoming traffic from the Internet, a combination of mechanisms blocks attacks and harmful traffic while allowing legitimate requests further into the network.

¹⁷⁶ Further information concerning SDL is publicly available at: <https://www.microsoft.com/en-us/sdl/default.aspx>.

In typical enterprise networks, the core infrastructure is heavily protected at the edge, or perimeter, with multiple layers of security devices. Each layer consists of devices and security policy decisions to be enforced. Devices in this context involves a combination of firewalls, denial of service prevention, intrusion detection systems (“IDS”) or intrusion protection systems (IPS”), and VPN devices. Policy enforcement can take the form of firewall policies, access control lists (“ACLs”), or specific routing.

Translating this into a cloud context, Azure has a layer to protect against Distributed Denial of Service attacks. This layer has no user configurable attributes and is not accessible to the customer. It is important to note that Azure DDoS only looks for large-scale attacks, and it is possible that a specific service could be overwhelmed before the platform level protection thresholds are reached.

The next layer is customer-defined public IP addresses (endpoints), which are used to determine which traffic can pass through the cloud service to the virtual network. Native virtual network isolation ensures complete isolation from all other networks and that traffic only flows through user configured paths and methods. These paths and methods are the next layer, where network security groups (“NSGs”), user data repositories (“UDR”), and network virtual appliances can be used to create security boundaries to protect Customer applications.

These virtual networks are created by customers and are what their workloads are connected to. In these networks, basic network-level security applies. It is a private network (a virtual network overlay) in Azure with the following features and characteristics:

- **Traffic isolation:** Virtual machines in one virtual network cannot communicate directly to virtual machines in a different virtual network, even if both virtual networks are created by the same customer.
- **Multi-tier topology:** Customers can define a multi-tier topology by allocating subnets and designating separate address spaces for different elements or “tiers” of their workloads. Customers can then define different access policy based on the workload types, and control traffic flows between the tiers.
- **Cross-premises connectivity:** Using VNet Peering, Azure VPN Gateways, third-party network virtual appliances, or ExpressRoute, customers can establish cross-premises connectivity between a virtual network and multiple on-premises sites or other virtual networks in Azure.
- **NSG** allows customers to create rules (“ACLs”) at the desired level of granularity: network interfaces, individual virtual machines, or virtual subnets. Customers can control access by permitting or denying communication between the workloads within a virtual network, from systems on customer’s networks via cross-premises connectivity, or direct Internet communication.
- **UDR and IP Forwarding** allow customers to define the communication paths between different tiers within a virtual network. Customers can deploy a firewall, IDS/IPS, and other virtual appliances, and route network traffic through these security appliances for security boundary policy enforcement, auditing, and inspection.
- **Network virtual appliances** such as firewalls, load balancers, and IDS/IPS are available in the Azure Marketplace and the VM Image Gallery. Customers can deploy these appliances into their virtual networks, and specifically, at their security boundaries.

At the interface with the public network, Microsoft uses special-purpose security devices for firewall, NAT, and IP filtering functions. Functions at this layer include denial of service blocking, intrusion detection systems, SSL, and initial access/certificate validation. The edge of the service network houses those servers and services that provide first level authentication and load balancing.

The networks within the Azure datacenters are designed to create multiple, distinct network segments. The preferred method for logically partitioning systems, at the network level, are router ACLs, VLANs, and appropriately placed firewalls. This partitioning strategy is used to separate front end components (e.g. web servers) from the back-end components (e.g. databases or management devices).

For Azure, several network security measures exist:

- Penetration testing.
- Network-level Distributed Denial-of-Service detection and prevention.
- Network isolation.
- Virtual networks.
- Anti-virus and anti-malware protection.
- Anti-spam controls.
- Port scanning and remediation.
- Perimeter vulnerability scanning.

Microsoft indicates that vulnerability assessment and scanning tools are specifically designed to operate in virtualized environments. Procedures have been established and implemented to scan for vulnerabilities on managed hosts. Vulnerability scanning on server operating systems, databases, and network devices is performed, at a minimum, on a quarterly basis.

Microsoft indicates that it also contracts with external penetration testers who also constantly scan Azure systems. Identified vulnerabilities are tracked and verified for remediation. The Microsoft Security Response Center regularly monitors external security vulnerability awareness sites. Microsoft indicates that Azure software and hardware configurations are reviewed at least quarterly to identify and eliminate any unnecessary functions, ports, protocols, and services.

There is a default “deny-all” policy; and only the specific ports and protocols required for the operation of the service are allowed. All traffic leaving the boundary for any Azure service is encrypted and restricted.

Filtering routers at the edge of the network provides security at the packet level to prevent unauthorized connections to Azure services.

Monitoring. Centralized monitoring, correlation, and analysis systems manage the large amount of information generated by devices within the Azure environment, providing both visibility and alerts to the teams that manage Azure services.

In addition to addressing software vulnerabilities, one aspect of security is the minimization of operational weaknesses. Microsoft administrative operations, including system access, are logged to provide an audit trail if unauthorized or accidental changes are made. The “administrator audit log” records specific actions performed by administrators and users who have been assigned administrative privileges. Customers can search for and view entries from the administrator audit log to determine what actions have been performed by Microsoft administrators and delegated administrators.

Access to logs is defined by policy and restricted. Logs are reviewed on a regular basis. Customers are permitted to directly view a subset of logs to verify who has accessed what data, and what they did with it. While Customers cannot access system event logs in real-time, Microsoft indicates that it has mechanisms in place to provide access in the event of a security incident and subsequent investigation.

Azure’s security monitoring agent collects users and groups that have been added to virtual machine as well as diagnostics, audit, and IIS logs. Logs are maintained for 90 days and are protected through access controls to authorized users. Restrictions on software installation are maintained through scanning on a periodic basis.

Anti-malware. Microsoft indicates that it freely provides *Antimalware for Azure Cloud Services and Virtual Machines* that helps identify and remove viruses, spyware, and other malicious software, with configurable alerts to indicate when known malicious or unwanted software attempts to install itself or run on Customer Azure systems. This service is a single-agent solution for applications and tenant environments, designed to run in the background without human intervention.

Microsoft indicates that this service has the following core features:

- **Real-time protection** - monitors activity in cloud services and on virtual machines to detect and

block malware execution.

- **Scheduled scanning** - periodically performs targeted scanning to detect malware, including actively running programs.
- **Malware remediation** - automatically acts on detected malware, such as deleting or quarantining malicious files and cleaning up malicious registry entries.
- **Signature updates** - automatically installs the latest protection signatures (virus definitions) to ensure protection is up to date on a pre-determined frequency.
- **Antimalware Engine updates** – automatically updates the Microsoft Antimalware engine.
- **Antimalware Platform updates** – automatically updates the Microsoft Antimalware platform.
- **Active protection** - reports telemetry metadata about detected threats and suspicious resources to Microsoft Azure to ensure rapid responses to an evolving threat landscape and enables real-time synchronous signature delivery through the Microsoft Active Protection System.
- **Samples reporting** - provides and reports samples to the Microsoft Antimalware service to help refine that service and enable troubleshooting.
- **Exclusions** – allows application and service administrators to configure certain files, processes, and drives to exclude them from protection and scanning for performance and/or other reasons.
- **Antimalware event collection** - records the antimalware service health, suspicious activities, and remediation actions taken in the operating system event log and collects them into the customer's Azure Storage account.

The solution is built on the same anti-malware platform as Microsoft Security Essentials, Microsoft Forefront Endpoint Protection, Microsoft System Center Endpoint Protection, Windows Intune, and Windows Defender for Windows 8.0 and higher.

For Azure services generally, the following malware tools are installed:

1. Microsoft servers
 - a. Microsoft End Point Protection
 - b. System Center EP
 - c. Symantec EP
2. Linux servers
 - a. CLAM AV

Auditors have noted that signature updates are made at least every 8 hours.

Patch Management. Microsoft also indicates that it has robust patch management systems that are audited and tracked regularly by management. Any issues or requested exceptions require management approval to address. The Microsoft Security Response Center releases security bulletins on the second Tuesday of every month ("Patch Tuesday"), or as appropriate to mitigate zero-day exploits. In the event that "proof-of-concept" code is publicly available regarding a possible exploit, or if a new critical security patch is released, patches to affected Azure systems will be applied to remediate the vulnerability.

Data Deletion. In Azure, data destruction techniques vary depending on the type of data object being destroyed – whether whole subscriptions, storage, virtual machines, or databases. In a multi-tenant environment, such as Microsoft Azure, attention must be paid to ensure that one customer's data does not "leak" into another customer's data, or when a customer deletes data, no other customer (including, in most cases, the customer who once owned the data) can gain access to that deleted data. This highly virtualized storage system ensures, because of tenant isolation, that no tenant has access to an area of storage to which they have not previously written.

Azure Storage. In Azure Storage, all disk writes are sequential, and one cannot ensure it is overwritten with other data. The original data will remain on the disk, and the new value will be written sequentially. Pointers are updated such that it is impossible to find the deleted data anymore.

Once the disk is full, the system must write new logs onto disk space that has been freed up by the deletion of old data. Log files are created in a file system running New Technology File System ("NTFS").

A background thread running on Azure Storage nodes frees up space by going through the oldest log file, copying blocks that are still referenced from that oldest log file to the current log file (and updating all pointers as it goes). It then deletes the oldest log file.

As a result, there are two categories of free space on the disk: space that NTFS knows is free, where it allocates new log files from this pool; and space within those log files that Azure Storage knows is free since there are no current pointers to it.

Azure Virtual Machines. Virtual machines are stored in Microsoft Azure Storage as blobs, so the deletion rules apply as indicated above. The virtualization mechanism, however, is designed to ensure that those spots on the disk cannot be read by another customer (or even the same customer) until data is written again, thus mitigating the threat of data leakage. When a new virtual disk is created for a virtual machine, it will appear to that virtual machine to be “zeroed”, however, the explicit zeroing of the data buffers occurs when a portion of the virtual disk is read before it is written. If a virtual machine instance is reinitialized in place, it is as if it had been moved to new hardware.

Azure SQL Database. With Azure SQL Database, deleted data is marked for deletion. If an entire database is deleted, it is the equivalent of deleting the database’s entire contents. The SQL Database implementation is designed to ensure user data is never leaked by disallowing all access to the underlying storage except via the SQL Database API. That API allows users to read, write, and delete data, but does not have a way to express the reading of data that the user has not previously written.

Encryption.¹⁷⁷ Each Azure storage account has its own unique credentials per access type (read, write, enumerate, and delete). Each set of credentials is held in the secure Key Store and is regularly refreshed. There are three different types of stores, each with a distinct function:

- Content is stored as encrypted blobs in Azure storage. The key to each chunk of content is encrypted and stored separately in the Content Database. The content itself holds no clue as to how it can be decrypted.
- The Content Database is a SQL Server database. It holds the map required to locate and reassemble all the content blobs held in Azure storage as well as the keys needed to encrypt those blobs. However, the set of keys is itself encrypted. The master key is held in a separate Key Store.
- The Key Store is physically separate from the Content Database and Azure storage. It holds the credentials for each Azure storage container and the master key to the set of encrypted keys held in the Content Database.

These three storage components – the Azure blob store, the Content Database, and the Key Store –are physically separate. The information held in any one of the components is unusable on its own. Without access to all three, it is impossible to retrieve the keys to the chunks, decrypt the keys to make them usable, associate the keys with their corresponding chunks, decrypt each chunk, or reconstruct a document from its constituent chunks.

Storage Encryption. Storage Service Encryption (“SSE”) provides customers with the capability to encrypt data at rest, handling encryption, decryption, and key management. All data is encrypted using 256-bit Advanced Encryption Standard (“AES”) encryption. SSE encrypts data when it is written to Azure Storage, and can be used for “block” blobs, “page” blobs and “append” blobs. It works for the following:

- General purpose storage accounts and Blob storage accounts.
- Standard storage and Premium storage.

¹⁷⁷ An overview of the encryption measures taken by Microsoft and available to customers can be found at: <https://docs.microsoft.com/en-us/azure/security/fundamentals/encryption-overview>.

- All redundancy levels (LRS, ZRS, GRS, RA-GRS).¹⁷⁸
- Azure Resource Manager storage accounts.
- All regions.

A customer's Azure portal, using the Settings blade, is used to enable or disable Storage Service Encryption for a storage account.

SSE permits customers to:

- Encrypt block blobs, append blobs, and page blobs.
- Encrypt archived VHDs and templates brought to Azure from on-premises.
- Encrypt underlying OS and data disks for IaaS VMs created using VHDs.

SSE only encrypts newly created data after the encryption is enabled. Data uploaded prior to encryption-enablement will not be encrypted unless they are rewritten or copied. Table, Queues, and Files data will not be encrypted. When the customer needs to access data, data is automatically decrypted before returning to the user.

Disk Encryption. Azure Disk Encryption permits Customers to encrypt Windows and Linux IaaS virtual machine disks by leveraging the BitLocker feature of Windows and the DM-Crypt feature of Linux to provide volume encryption for the OS and the data disks. Microsoft indicates that the solution is integrated with Azure Key Vault to allow control and management of encryption keys and secrets.

The Azure Disk Encryption allows customers to:

- Enable encryption on new IaaS virtual machines created from pre-encrypted VHD and encryption keys.
- Enable encryption on new IaaS virtual machines created from the Azure Gallery images.
- Enable encryption on existing IaaS virtual machines running in Azure.
- Disable encryption on Windows IaaS virtual machines.

Azure Disk Encryption for Windows and Linux IaaS machines are available in all Azure public regions for Standard virtual machines and virtual machines with premium storage.

Virtual Machine Encryption. The Azure Security Center will alert customers if they have unencrypted virtual machines. If using Windows 10 to encrypt such machines, customers are to (i) install and configure Azure PowerShell to enable the running of PowerShell commands to set up the prerequisites required to encrypt Azure Virtual Machines; and (ii) obtain and run the Azure Disk Encryption Prerequisites Azure PowerShell script.

BitLocker. BitLocker can be used to encrypt Customer Content Data at rest at the volume-level. BitLocker key management involves the management of recovery keys that are used to unlock/recover encrypted disks. BitLocker-managed keys are tied to the lifetime of an operating system installed on a server or a given encrypted disk. These keys are generally deleted and reset during server reinstallation or disk formatting.

BitLocker uses recovery keys where an operating system is reinstalled and encrypted data disks already exist. FIPS-compliant algorithms are used to ensure that encryption keys are never stored or sent "in the clear". The recovery keys are managed outside of BitLocker but used for disk decryption.

Data in Motion. Where customers interact with Azure Storage through the Azure Portal, all transactions occur via HTTPS. Storage REST API over HTTPS can also be used to interact with Azure Storage and Azure SQL Database. Within Azure, data can be secured in transit between an application and Azure by

¹⁷⁸ The acronyms represent the replication options available to Customers, specifically: locally redundant storage, zone-redundant storage, geo-redundant storage, and read-access geo-redundant storage.

using customer-side Encryption, HTTPs, or SMB 3.0.

As for traffic between datacenters, all such traffic between Microsoft datacenters is encrypted. Microsoft deploys applications so that the Customer Content Data is encrypted using TLS or IPSec. This includes both application-layer encryption for the Customer Content Data itself, and network transport layer encryption for the communication of the Customer Content Data.

For data in motion, Customers are recommended to use SSL/TLS protocols to exchange data across different locations or to isolate the entire communication channel between their on-premises and cloud infrastructure by using a virtual private network ("VPN").

Microsoft recommends that organizations which need to secure access from one workstation located on-premises to Azure should use Point-to-Site VPN. For secure access from multiple workstations located on-premises to Azure, Microsoft recommends Azure site-to-site VPN.

Larger data sets can be moved over a dedicated high-speed WAN link such as ExpressRoute. If customers choose to use ExpressRoute, they may also encrypt the data at the application-level using SSL/TLS or other protocols for added protection.

Customer-Side Encryption. Customers may also encrypt data as well as apply policies on the data to limit or allow actions by the recipient of the data through Azure Rights Management.

Azure Rights Management System ("RMS") is integrated with Azure Information Protection and uses a 2048-bit RSA asymmetric key with SHA- 256 hash algorithm to encrypt the content.

In a default Azure RMS implementation, Microsoft generates and manages the root key that is unique for each tenant. Access to the root key is always limited to applications and is not provided to any personnel. Customers can access a near "real-time" log showing all access to the root key at any time.

Incident Detection and Response. Microsoft states that it has a global, 24/7 incident response service to mitigate the effects of any attacks or malicious activity. Microsoft indicates that its Cyber Defense Operations Center brings together security response experts from across Microsoft to detect and respond to cyber-threats in "real-time". Threat intelligence is built into the products and services to help customers more quickly identify and detect issues early and accurately. Microsoft Azure has developed robust processes to facilitate a coordinated response to incidents if one was to occur.

[Remainder of page left intentionally blank.]

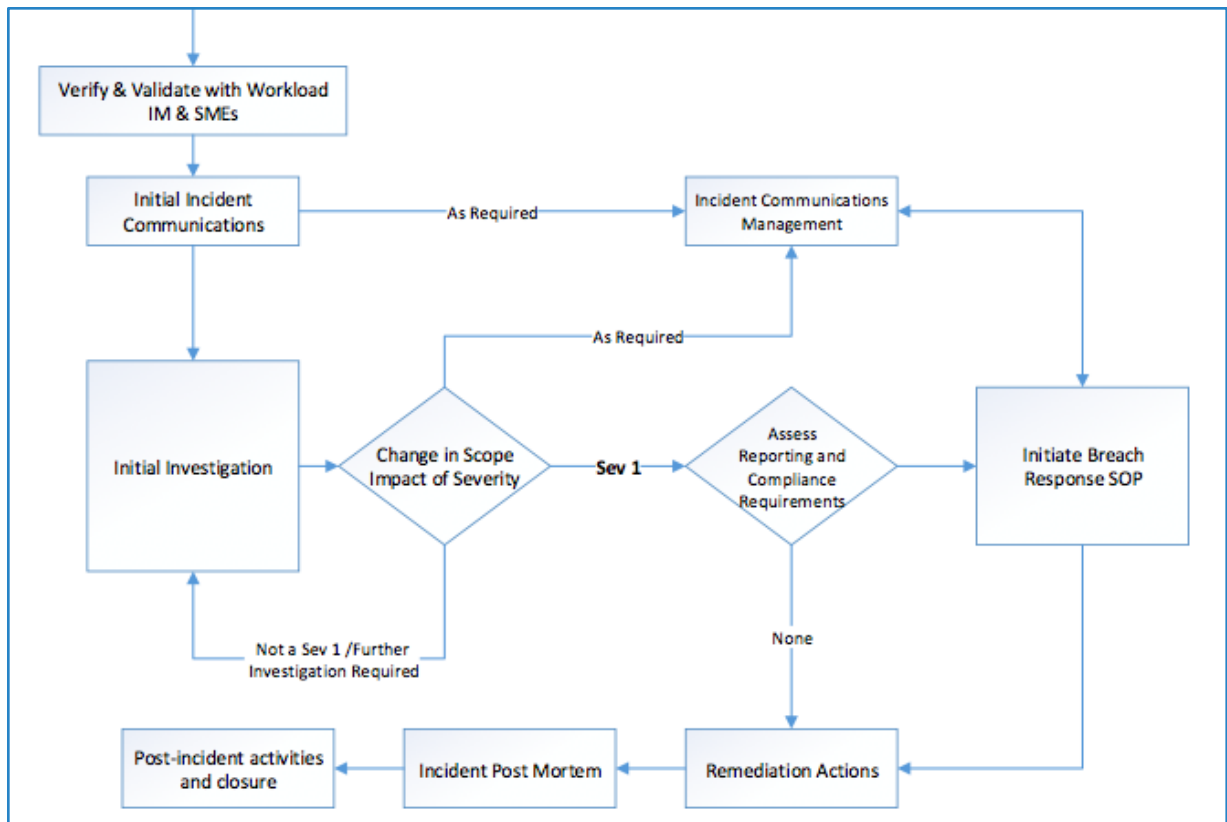


Image 13: Incident Investigation and Response Flow

Depending on the nature of the incident, the Microsoft's Security Incident Response team may engage one or more subject matter experts from various groups within Microsoft, such as the Online Services Security and Compliance team, Microsoft Threat Intelligence Center, Microsoft Security Response Center, Microsoft Corporate, External & Legal Affairs, and Azure Security.

In the event of a security incident¹⁷⁹, Microsoft's policy is to promptly (i) notify Customer of the incident; (ii) investigate the incident and provide the Customer with detailed information about the incident; and (iii) take reasonable steps to mitigate the effects and to minimize any damage resulting from the incident. Notification(s) are to be delivered to one or more of a customer's administrators by any means Microsoft selects, including email.

Microsoft has adopted an "assume breach" strategy. In doing so, it deploys a dedicated "red team" of software security experts that simulates real-world attacks at the network, platform, and application layers. The objective is to test Azure's ability to detect, protect against and recover from, breaches. Microsoft's policy in simulating attacks is that red teams do not target Customer Data but rather the Azure infrastructure and platforms.

Microsoft indicates that staff are required to report suspected security incidents. Upon identification, incidents are immediately brought to the attention of the Microsoft Online Services Investigation and Response team. Tickets for the incidents are entered into the tracking system and escalated as necessary.

Customers are required to notify Microsoft promptly about any possible misuse of accounts or authentication credentials or any security incident related to an Azure service.

¹⁷⁹ "Security incident" is defined as any unlawful access to any Customer Data stored on Microsoft's equipment or in Microsoft's facilities, or unauthorized access to such equipment or facilities resulting in loss, disclosure, or alteration of Customer Content Data.

Contractual obligations in Microsoft's Data Protection Addendum require Microsoft to notify affected customers promptly in the event of an incident affecting their data. The means of notifications will vary depending upon the facts of any specific incident.

Audit. Azure has several auditing and logging capabilities that permit Customers to create an audit trail for applications deployed in Azure and virtual machines created from the Azure Virtual Machines Gallery. Microsoft indicates that audit policies can be customized.

Azure permits Customers to generate and collect security events from Azure IaaS and PaaS roles in their subscriptions. Customers can then use HDInsight to aggregate and analyze the collected events. In addition, these events can be exported to on-premises security information and event management systems for ongoing monitoring.

Customers may monitor access and usage using Azure's logging of administrative operations, including system access, to create an audit trail in case of unauthorized or accidental changes. Customers can also retrieve audit logs for their Microsoft Entra ID Directory (formerly Azure Active Directory tenant, and view access and usage reports.

The Azure Management Portal can be used to view usage and asset reports that include anomalous sign-in events, user-specific reports, and activity logs. The Azure Security Center¹⁸⁰ allows for monitoring and policy management purposes across Azure subscriptions for security purposes. Customers can enable data collection for (i) daily scanning of all supported virtual machines for security monitoring and recommendations and (ii) security events for analysis and threat detection.

Customers can also use Azure Diagnostics -- configured to collect Windows security event logs and other security-specific logs -- to export security alerts to an on-premises Security Incident Event Management tool.

Third-Party Assessment. Several independent assessments of Azure have been conducted, and these documents are assessable to authorized users via Azure Compliance Offerings¹⁸¹. These include:

ISO/IEC 27001:2022. Certification under this ISO/IEC 27001:2022 indicates that Microsoft has implemented the security controls defined in this standard. Audits against this standard are performed for Microsoft by BSI Group and address all 14 ISO domains:

- General Information.
- Information Security.
- Organization of Information Security.
- Asset Management.
- Human Resources Security.
- Physical and Environmental Security.
- Communications and Operations Management.
- Access Control.
- Information Systems Acquisition, Development, and Maintenance.
- Information Security Incident Management.
- Business Continuity Management.
- Risk Management.
- Compliance.
- Privacy.

The certification is valid for a 12-month period at which time re-certification occurs.

¹⁸⁰ Further information about the Azure Security Center can be found at <https://learn.microsoft.com/en-us/azure/security/>.

¹⁸¹ Available at: <https://azure.microsoft.com/en-us/overview/trusted-cloud/compliance/>.

ISO/IEC 27018:2020. Azure services also meet the requirements of *ISO/IEC 27018:2020 — Information technology — Security techniques — Code of practice for protection of Personally Identifiable Information (PII) in public clouds acting as PII processors*. The certification is valid for a 12-month period at which time re-certification occurs.

SOC 1 Type 2. Azure has also been audited against the Service Organization Control (“SOC”) reporting framework for SOC 1 Type 2. The audit report covers the following Azure features/services, including infrastructure, development, operations, and support for Cloud Services as well as infrastructure for Microsoft Online Services.

The SOC 1 Type 2 audit report attests to the design and operating effectiveness of controls. Audits are conducted in accordance with (i) the Statement on Standards for Attestation Engagements No. 16 issued by the Auditing Standards Board of the American Institute of Certified Public Accountants and (ii) International Standard on Assurance Engagements 3402 issued by the International Auditing and Assurance Standards Board.

Similarly, with a SOC 2 Type 1 and/or Type 2 Attestation (AT Section 101), a report is created with respect to the controls relevant to security, availability, processing integrity, confidentiality, and privacy trust principles. While some trust principles may not be applicable depending on the nature of the cloud service (IaaS vs. PaaS vs. SaaS), cloud-based service providers must follow the control requirements specified in AT 101. Microsoft has indicated that the SOC 2 audit report can be shared with Customers who have signed a non-disclosure agreement.

SOC 3. Microsoft has also obtained a SOC 3 audit report, which, like a SOC 2 report, is based upon the Trust Service Principles and performed under AT101. The significant difference between the two is that a SOC 3 Report can be generally distributed since it contains less detail and only reports that Microsoft has achieved the Trust Services criteria or not. No description of tests and results or opinion on description of the system is provided.

A SOC 3 report can be provided as a Type II, unlike SOC 1 and SOC 2 where there is a Type I option. SOC 3 reports can be issued on one or multiple Trust Services principles (security, availability, processing integrity, confidentiality, and privacy).

FedRAMP. Azure’s Public Cloud Solution has been granted a Provisional Authority to Operate (from the U.S. Federal Risk and Authorization Management Program (“FedRAMP”) Joint Authorization Board at a Moderate impact level based upon the FIPS 199 classification. FedRAMP is a US government program that provides a standard approach to security assessment, authorization, and monitoring for cloud services used by federal agencies.

Canadian Centre for Cybersecurity. The Canadian Centre for Cybersecurity has assessed the security of Microsoft Azure, Dynamics and Power Platform for 2025, using an independent review conducted by Kratos Defense & Security Solutions, Inc.¹⁸²

[Remainder of page left intentionally blank.]

¹⁸² The Canadian Centre for Cybersecurity assessment can be found at:
<https://servicetrust.microsoft.com/DocumentPage/88ea41f3-30ad-4ccf-a1ef-d3734dcde472>.

ANNEX D – MICROSOFT ENTRA DATA ATTRIBUTES

The following are the attributes that may be used in Microsoft Entra ID Directory (formerly Active Directory) and associated with an individual.

Synced Object Attribute	User	Group	Contact (Src)	Description
assistant	Read	-	Read	The name of the assistant for an account.
authOrig	Read	Read	Read	Relationship that indicates that the mailbox for the target object is authorized to send mail to the source object.
C	-	-	Read	Two-letter ISO 3166 [ISO3166] country code.
cn	Read	Read	Read	The common name of the object.
co	Read	-	Read	The country/region in which the person (user or contact) or company is located.
company	Read	-	Read	The person's (user or contact) company name.
countryCode	Read	-	Read	The country code for person's (user or contact) language of choice.
department	Read	-	Read	The name of the person's (user or contact) department.
description	Read	Read	Read	Human-readable descriptive phrases about the object.
displayName	Read	Read	Read	The display name for an object, usually the combination of the person's first name, middle initial, and last name.
dLMemRejectPerms	Read	Read	Read	Relationship that indicates that members of the target object are not authorized to send mail to the source object.
dLMemSubmitPerms	Read	Read	Read	Relationship that indicates that members of the target object are

				authorized to send mail to the source object.
ExtensionAttribute1	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute10	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute11	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute12	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute13	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute14	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute15	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute2	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute3	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute4	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute5	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute6	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute7	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute8	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
ExtensionAttribute9	Read	Read	Read	Custom attribute that is defined in the customer on-premises directory.
facsimiletelephonenumber	Read	-	Read	Telephone numbers (and, optionally, the parameters) for facsimile terminals.

givenName	Read	-	Read	Name strings that are the part of a person's (user or contact) name that is not their surname.
GroupType	-	Read	-	Flag attribute indicating the type of group (security, global, etc.)
hideDLMembership	-	Read	-	Hide the membership list on a distribution list from senders.
homephone	Read	-	Read	The person's (user or contact) main home telephone number.
info	Read	Read	Read	"Notes" field on "Telephone" tab of ADUC.
Initials	Read	-	Read	Strings of initials of some or all of an individual's names, except the surname(s).
ipPhone	Read	-	Read	The TCP/IP address for the telephone.
l	Read	-	Read	Names of a locality or place, such as a city, county, or other geographic region.
legacyExchangeDN	Read	Read	Read	
mail	Read	Read	Read	The list of email addresses for a person (user or contact).
mailnickname	Read	Read	Read	
managedBy	-	Read	-	Resource/owner relationship, where the source object (a group) is the resource, and the target object is the owner.
manager	Read	-	Read	Manager/direct report relationship between two individuals, where the source object is the direct report, and the target object is the manager.
member	-	Read	-	Membership of the target object (of class User, Contact, or Group) in the group that is identified as the source object.
middleName	Read	-	Read	Additional names for a person (user or contact),

for example, middle name, patronymic, matronymic, or other names.

mobile	Read	-	Read	The primary mobile phone number for a person (user or contact).
msDS-HABSeniorityIndex	Read	Read	Read	
msDS-PhoneticDisplayName	Read	Read	Read	
MsExchArchiveGUID	Read	-	-	
MsExchArchiveName	Read	-	-	
msExchArchiveStatus	Read/Write	-	-	Created in the Exchange cloud for "write back" to on-premises when the customer has a cloud archive.
msExchAssistantName	Read	-	Read	The name of the assistant for an account.
msExchAuditAdmin	Read	-	-	
msExchAuditDelegate	Read	-	-	
msExchAuditDelegateAdmin	Read	-	-	
msExchAuditOwner	Read	-	-	
MsExchBlockedSendersHash	Read/Write	-	Read	Populated through an upgrade from Business Productivity Online Standard Suite. Not synced from on-premises.
msExchBypassAudit	Read	-	-	
MsExchBypassModerationFromDLMembersLink	Read	Read	Read	
MsExchBypassModerationLink	Read	Read	Read	
msExchCoManagedByLink	-	Read	-	
msExchDelegateListLink	Read	-	-	
msExchELCEpirySuspensionEnd	Read	-	-	
msExchELCEpirySuspensionStart	Read	-	-	
msExchELCMailboxFlags	Read	-	-	
MsExchEnableModeration	Read	Read	-	
msExchExtensionCustomAttribute1	Read	Read	Read	
msExchExtensionCustomAttribute2	Read	Read	Read	
msExchExtensionCustomAttribute3	Read	Read	Read	
msExchExtensionCustomAttribute4	Read	Read	Read	
msExchExtensionCustomAttribute5	Read	Read	Read	
MsExchGroupDepartRestriction	-	Read	-	
MsExchGroupJoinRestriction	-	Read	-	
msExchHideFromAddressLists	Read	Read	Read	Indicator to control the visibility of a mail

				recipient for name resolution.
MsExchImmutableID	Read	-	-	
msExchLitigationHoldDate	Read	Read	Read	
msExchLitigationHoldOwner	Read	Read	Read	
MsExchMailboxGuid	Read	-	-	The GUID of the user's mailbox.
msExchMailboxAuditEnable	Read	-	-	
msExchMailboxAuditLogAgeLimit	Read	-	-	
MsExchModeratedByLink	Read	Read	Read	
MsExchModerationFlags	Read	Read	Read	
MsExchRecipientDisplayType	Read	Read	Read	
msExchRecipientTypeDetails	Read	Read	Read	
MsExchRemoteRecipientType	Read	-	-	
msExchRequireAuthToSendTo	Read	Read	Read	When enabled for a distribution list (DL), unauthenticated users are rejected.
MsExchResourceCapacity	Read	-	-	
MsExchResourceDisplay	Read	-	-	
MsExchResourceMetaData	Read	-	-	
MsExchResourceSearchProperties	Read	-	-	
msExchRetentionComment	Read	Read	Read	
msExchRetentionURL	Read	Read	Read	
MsExchSafeRecipientsHash	Read/Write	-	Read	Populated through an upgrade from Business Productivity Online Standard Suite. Not synced from on-premises.
MsExchSafeSendersHash	Read/Write	-	Read	Populated through an upgrade from Business Productivity Online Standard Suite. Not synced from on-premises.
MsExchSenderHintTranslations	Read	Read	Read	
msExchTeamMailboxExpiration	Read	-	-	
msExchTeamMailboxOwners	Read	-	-	
msExchTeamMailboxSharePointLinkedBy	Read	-	-	
msExchTeamMailboxSharePointUrl	Read	-	-	
msExchUCVoiceMailSettings	Read/Write	-	-	
msExchUsageLocation	Read	-	-	
msExchUserHoldPolicies	Read/Write	-	-	Litigation Hold allows cloud services to

				determine which users are under Litigation Hold
msOrg-IsOrganizational	-	Read	-	
msRTCSIP-ApplicationOptions	Read	-	-	
msRTCSIP-DeploymentLocator	Read	-	Read	Fully qualified DNS name of the Microsoft Lync Server 2010 deployment, as specified in the authoritative (customer, on-premises) directory.
msRTCSIP-Line	Read	-	Read	The device ID (either the Session Initiation Protocol (SIP) uniform resource identifier (URI) or the TEL URI) of the telephone that the user controls.
msRTCSIP-OwnerUrn	Read	-	-	
msRTCSIP-PrimaryUserAddress	Read	-	Read	SIP URI for instant messaging, as specified in the authoritative (customer, on-premise) directory.
msRTCSIP-UserEnabled	Read	-	Read	Indicates whether the user is currently enabled for SIP instant messaging, as specified in the authoritative (customer, on-premises) directory.
msRTCSIP-OptionFlags	Read	-	Read	
objectGUID	Read	Read	Read	Key for the object: this key is immutable, even if the object moves from one context to another, for example, as a result of a company merge or split.
oOFReplyToOriginator	-	Read	-	Governs whether out-of-office notifications should be sent to a sender of a message to this distribution list (DL).
otherFacsimileTelephone	Read	-	Read	A list of alternative facsimile numbers.
otherHomePhone	Read	-	Read	A list of alternative home telephone numbers.
otherIpPhone	Read	-	Read	A list of alternative TCP/IP addresses for the telephone.

otherMobile	Read	-	Read	A list of alternative mobile phone numbers.
otherPager	Read	-	Read	A list of alternative pager numbers.
otherTelephone	Read	-	Read	A list of alternative office telephone numbers.
pager	Read	-	Read	The primary pager number.
photo	Read	-	-	
physicalDeliveryOfficeName	Read	-	Read	Names that a postal service uses to identify a post office.
postalCode	Read	-	Read	Codes that a postal service uses to identify postal service zones.
postOfficeBox	Read	-	Read	Postal box identifiers that a postal service uses when a customer arranges to receive mail at a box on the premises of the postal service.
PreferredLanguage	Read	-	-	The preferred written or spoken language for a user.
proxyAddresses	Read/Write	Read/Write	Read/Write	The address by which a Microsoft Exchange Server recipient object is recognized in a foreign mail system.
PublicDelegates	Read/Write	Read	Read	Cross-premises public delegation: allows users to specify delegates for their mailbox.
pwdLastSet	Read	-	-	The date and time that the password for this account was last changed
reportToOriginator	-	Read	-	Governs whether to send delivery reports to the message originator when a message that is sent to a group is not delivered. The delivery report lets the group owner know that the message was not delivered.
ReportToOwner	-	Read	-	
samAccountName	Read	-	-	
sn	Read	-	Read	Name strings for the family names of a person (user or contact).

sourceAnchor	Read	Read	Read	Mechanical property. Immutable identifier to maintain relationship between ADDS and Azure AD.
st	Read	-	Read	The full names of states or provinces.
streetAddress	Read	-	Read	The person's (user or contact) address.
targetAddress	Read	-	Read	The destination address for the person (user or contact).
TelephoneAssistant	Read	-	Read	
telephoneNumber	Read	-	Read	Telephone numbers that comply with the ITU Recommendation E.123.
thumbnailphoto	Read	-	Read	Persons Photo - 10kb maximum size limit
title	Read	-	Read	The title of a person (user or contact) in the person's organizational context.
unauthOrig	Read	Read	Read	Relationship that indicates that the mailbox for the target object is not authorized to send mail to the source object.
url	Read	-	Read	The list of alternative web pages.
userAccountControl	Read	-	-	Flag attribute to indicate settings.
userCertificate	Read	Read	-	Contains certificates used as part of the Exchange S/MIME feature set.
UserPrincipalName	Read	-	-	The user principal name (UPN) that is an Internet-style logon name for a user, as specified in RFC 822.
userSMIMECertificate	Read	Read	-	Contains certificates used as part of the Exchange S/MIME feature set.
wwwHomePage	Read	-	Read	The primary web page.

ANNEX E – DPA MAPPING

When considering what an organization should seek in terms of contractual obligations to protect personal information held by a service provider, Ontario's IPC has provided a useful list. This Annex maps the list of IPC requirements to Microsoft's Data Protection Addendum.

Information Ownership. The DPA states Microsoft's position on data ownership:

"Microsoft will use and otherwise process Customer Data, Professional Services Data, and Personal Data only as described and subject to the limitations provided below (a) to provide Customer the Products and Services in accordance with Customer's documented instructions and (b) for business operations incident to providing the Products and Services to Customer. As between the parties, Customer retains all right, title and interest in and to Customer Data and Professional Services Data. Microsoft acquires no rights in Customer Data or Professional Services Data, other than the rights Customer grants to Microsoft in this section. This paragraph does not affect Microsoft's rights in software or services Microsoft licenses to Customer."

Information Processing (Collection, use and disclosure). The DPA describes the nature and extent of processing of information, including personal information by Microsoft:

"Processing to Provide Customer the Products and Services"

For purposes of this DPA, "to provide" a Product consists of:

- Delivering functional capabilities as licensed, configured, and used by Customer and its users, including providing personalized user experiences;
- Troubleshooting (preventing, detecting, and repairing problems); and
- Keeping Products up to date and performant, and enhancing user productivity, reliability, efficacy, quality, and security.

For purposes of this DPA, "to provide" Professional Services consists of:

- Delivering the Professional Services, including providing technical support, professional planning, advice, guidance, data migration, deployment, and solution/software development services.
- Troubleshooting (preventing, detecting, investigating, mitigating, and repairing problems, including Security Incidents and problems identified in the Professional Services or relevant Product(s) during delivery of Professional Services); and
- Enhancing delivery, efficacy, quality, and security of Professional Services and the underlying Product(s) based on issues identified while providing Professional Services, including fixing software defects and otherwise keeping Products and Services up to date and performant.
- In each case, providing the Products and Services is conducted in view of security obligations under Data Protection Requirements.

When providing Products and Services, Microsoft will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) market research aimed at creating new functionalities, services, or products or any other purpose, unless such use or processing is in accordance with Customer's documented instructions.

Processing for Business Operations Incident to Providing the Products and Services to Customer

For purposes of this DPA, "business operations" means the processing operations authorized by customer in this section.

Customer authorizes Microsoft:

- *to create aggregated statistical, non-personal data from data containing pseudonymized identifiers (such as usage logs containing unique, pseudonymized identifiers); and*
 - *to calculate statistics related to Customer Data or Professional Services Data*
- in each case without accessing or analyzing the content of Customer Data or Professional Services Data and limited to achieving the purposes below, each as incident to providing the Products and Services to Customer.*

Those purposes are:

- *billing and account management;*
- *compensation such as calculating employee commissions and partner incentives;*
- *internal reporting and business modeling, such as forecasting, revenue, capacity planning, and product strategy; and*
- *financial reporting.*

When processing for these business operations, Microsoft will apply principles of data minimization and will not use or otherwise process Customer Data, Professional Services Data, or Personal Data for: (a) user profiling, (b) advertising or similar commercial purposes, or (c) any other purpose, other than for the purposes set out in this section. In addition, as with all processing under this DPA, processing for business operations remains subject to Microsoft's confidentiality obligations and commitments under Disclosure of Processed Data.

Disclosure of Processed Data

Microsoft will not disclose or provide access to any Processed Data except: (1) as Customer directs; (2) as described in this DPA; or (3) as required by law. For purposes of this section, "Processed Data" means: (a) Customer Data; (b) Professional Services Data; (c) Personal Data; and (d) any other data processed by Microsoft in connection with the Products and Services that is Customer's confidential information under Customer's agreement. All processing of Processed Data is subject to Microsoft's obligation of confidentiality under Customer's agreement.

Microsoft will not disclose or provide access to any Processed Data to law enforcement unless required by law. If law enforcement contacts Microsoft with a demand for Processed Data, Microsoft will attempt to redirect the law enforcement agency to request that data directly from Customer. If compelled to disclose or provide access to any Processed Data to law enforcement, Microsoft will promptly notify Customer and provide a copy of the demand unless legally prohibited from doing so.

Upon receipt of any other third-party request for Processed Data, Microsoft will promptly notify Customer unless prohibited by law. Microsoft will reject the request unless required by law to comply. If the request is valid, Microsoft will attempt to redirect the third party to request the data directly from Customer.

Microsoft will only disclose or provide access to any Processed Data as required by law provided that the laws and practices respect the essence of the fundamental rights and freedoms and do not exceed what is necessary and proportionate in a democratic society and, as applicable, to safeguard one of the objectives listed in Article 23(1) of GDPR.

Microsoft will not provide any third party: (a) direct, indirect, blanket, or unfettered access to Processed Data; (b) platform encryption keys used to secure Processed Data or the ability to break such encryption; or (c) access to Processed Data if Microsoft is aware that the data is to be used for purposes other than those stated in the third party's request.

In support of the above, Microsoft may provide Customer's basic contact information to the third party."

Limits on Jurisdiction of Storage. With respect to data residency, the DPA states:

"Data Transfers and Location

Data Transfers

Customer Data, Professional Services Data, and Personal Data that Microsoft processes on Customer's behalf may not be transferred to, or stored and processed in a geographic location except in accordance with the DPA Terms and the safeguards provided below in this section. Taking into account such safeguards, Customer appoints Microsoft to transfer Customer Data, Professional Services Data, and Personal Data to the United States or any other country in which Microsoft or its Subprocessors operate and to store and process Customer Data, and Personal Data to provide the Products, except as described elsewhere in the DPA Terms.

All transfers of Customer Data, Professional Services Data, and Personal Data out of the European Union, European Economic Area, United Kingdom, and Switzerland to provide the Products and Services are subject to the terms of the 2021 Standard Contractual Clauses implemented by Microsoft. In addition, transfers from the United Kingdom are subject to the terms of the IDTA implemented by Microsoft. For purposes of this DPA, the "IDTA" means the International data transfer addendum to the European Commission's standard contractual clauses for international data transfers issued by the UK Information Commissioner's Office under S119A(1) of the UK Data Protection Act 2018. Microsoft will abide by the requirements of European Economic Area, United Kingdom, and Swiss data protection law regarding the collection, use, transfer, retention, and other processing of Personal Data from the European Economic Area, United Kingdom, and Switzerland. All transfers of Personal Data to a third country or an international organization will be subject to appropriate safeguards as described in Article 46 of the GDPR and such transfers and safeguards will be documented according to Article 30(2) of the GDPR.

In addition, Microsoft is certified to the EU-U.S. and Swiss-U.S. Data Privacy Frameworks, the UK Extension to the EU-U.S. Data Privacy Framework and the commitments they entail. Microsoft agrees to notify Customer if it makes a determination that it can no longer meet its obligation to provide the same level of protection as is required by the principles of the Data Privacy Frameworks.

Location of Customer Data

For the Core Online Services, Microsoft will store Customer Data at rest within certain major geographic areas (each, a Geo) as set forth in the Product Terms.

For EU Data Boundary Services, Microsoft will store and process Customer Data, Personal Data, and store Professional Services Data at rest within the European Union and the European Free Trade Association (EFTA) as set forth in the Product Terms.

Microsoft does not control or limit the regions from which Customer or Customer's end users may access or move Customer Data."

Treatment of Confidential Information (including personal information). Microsoft makes a specific commitment vis-à-vis confidential information:

“Processor Confidentiality Commitment

Microsoft will ensure that its personnel engaged in the processing of Customer Data, Professional Services Data, and Personal Data (i) will process such data only on instructions from Customer or as described in this DPA, and (ii) will be obligated to maintain the confidentiality and security of such data even after their engagement ends...”

Employee Awareness and Training. The DPA states:

“Processor Confidentiality Commitment

...Microsoft shall provide periodic and mandatory data privacy and security training and awareness to its employees with access to Customer Data, Professional Services Data, and Personal Data in accordance with applicable Data Protection Requirements and industry standards.”

Limits on Subcontracting. The DPA states:

“Notice and Controls on use of Subprocessors

Microsoft may hire Subprocessors to provide certain limited or ancillary services on its behalf. Customer consents to this engagement and to Microsoft Affiliates as Subprocessors. The above authorizations will constitute Customer’s prior written consent to the subcontracting by Microsoft of the processing of Customer Data, Professional Services Data, and Personal Data if such consent is required under the Standard Contractual Clauses or the GDPR Terms.

Microsoft is responsible for its Subprocessors’ compliance with Microsoft’s obligations in this DPA. Microsoft makes available information about Subprocessors on a Microsoft website. When engaging any Subprocessor, Microsoft will ensure via a written contract that the Subprocessor may access and use Customer Data, Professional Services Data, or Personal Data only to deliver the services Microsoft has retained them to provide and is prohibited from using Customer Data, Professional Services Data, or Personal Data for any other purpose. Microsoft will ensure that Subprocessors are bound by written agreements that require them to provide at least the level of data protection required of Microsoft by the DPA, including the limitations on disclosure of Processed Data. Microsoft agrees to oversee the Subprocessors to ensure that these contractual obligations are met.

From time to time, Microsoft may engage new Subprocessors. Microsoft will give Customer notice and, as applicable, update the website and provide Customer with a mechanism to obtain notice of that update of any new Subprocessor at least 6 months in advance of providing that Subprocessor with access to Customer Data. Additionally, Microsoft will give Customer notice and, as applicable, update the website and provide Customer with a mechanism to obtain notice of that update of any new Subprocessor at least 30 days in advance of providing that Subprocessor with access to Professional Services Data or Personal Data other than that which is contained in Customer Data. If Microsoft engages a new Subprocessor for a new Product or Professional Service that processes Customer Data, Professional Services Data, or Personal Data, Microsoft will give Customer notice prior to availability of that Product or Professional Service.

If Customer does not approve of a new Subprocessor for an Online Service or Professional Services, then Customer may terminate any subscription for the affected Online Service or the applicable Statements of Service for the applicable Professional Service, respectively, without penalty or termination fee by providing, before the end of the relevant notice period, written notice of termination. If Customer does not approve of a new Subprocessor for Software, and Customer cannot reasonably avoid use of the Subprocessor by restricting Microsoft from processing data as set forth in the documentation or this DPA, then Customer may terminate any license for the affected software product without penalty by providing, before the end of the relevant notice period, written notice of termination.

Customer may also include an explanation of the grounds for non-approval together with the termination notice, in order to permit Microsoft to re-evaluate any such new Subprocessor based on the applicable concerns. If the affected Product is part of a suite (or similar single purchase of services), then any termination will apply to the entire suite. After termination, Microsoft will remove payment obligations for any subscriptions or other applicable unpaid work for the terminated Products or Services from subsequent invoices to Customer or its reseller.”

Security Provisions. One aspect to take particular note of is Appendix A of the DPA contains a table of security provisions put in place by Microsoft. Microsoft expressly states:

“Microsoft will implement and maintain appropriate technical and organizational measures to protect Customer Data, Professional Services Data, and Personal Data against accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored or otherwise processed. Those measures shall be set forth in a Microsoft Security Policy. Microsoft will make that policy available to Customer, along with other information reasonably requested by Customer regarding Microsoft security practices and policies.

In addition, those measures shall comply with the requirements set forth in ISO 27001, ISO 27002, and ISO 27018. A description of the security controls for these requirements is available to Customers.

Each Core Online Service also complies with the control standards and frameworks shown in the table in the Product Terms. Each Core Online Service and Professional Service implements and maintains the security measures set forth in Appendix A for the protection of Customer Data and Professional Services Data.

Microsoft implements and maintains the security measures set forth in Annex II of the 2021 Standard Contractual Clauses for the protection of Personal Data within the scope of the GDPR. Microsoft may add industry or government standards at any time. Microsoft will not eliminate ISO 27001, ISO 27002, ISO 27018 or any standard or framework in the table for Core Online Services in the Product Terms, unless it is no longer used in the industry and it is replaced with a successor (if any).”

Appendix A states:

Domain	Practices
Organization of Information Security	Security Ownership. Microsoft has appointed one or more security officers responsible for coordinating and monitoring the security rules and procedures. Security Roles and Responsibilities. Microsoft personnel with access to Customer Data or Professional Services Data are subject to confidentiality obligations. Risk Management Program. Microsoft performed a risk assessment before processing the Customer Data or launching the Online Services service and before processing Professional Service Data or launching the Professional Services. Microsoft retains its security documents pursuant to its retention requirements after they are no longer in effect.
Asset Management	Asset Inventory. Microsoft maintains an inventory of all media on which Customer Data or Professional Services Data is stored. Access to the inventories of such media is restricted to Microsoft personnel authorized in writing to have such access. Asset Handling

Domain	Practices
	• Microsoft classifies Customer Data and Professional Services Data to help identify it and to allow for access to it to be appropriately restricted. • Microsoft imposes restrictions on printing Customer Data and Professional Services Data and has procedures for disposing of printed materials that contain such data. • Microsoft personnel must obtain Microsoft authorization prior to storing Customer Data or Professional Services Data on portable devices, remotely accessing such data, or processing such data outside Microsoft's facilities.
Human Resources Security	Security Training. Microsoft informs its personnel about relevant security procedures and their respective roles. Microsoft also informs its personnel of possible consequences of breaching the security rules and procedures. Microsoft will only use anonymous data in training.
Physical and Environmental Security	Physical Access to Facilities. Microsoft limits access to facilities where information systems that process Customer Data or Professional Services Data are located to identified authorized individuals. Physical Access to Components. Microsoft maintains records of the incoming and outgoing media containing Customer Data or Professional Services Data, including the kind of media, the authorized sender/recipients, date and time, the number of media and the types of such data they contain. Protection from Disruptions. Microsoft uses a variety of industry standard systems to protect against loss of data due to power supply failure or line interference. Component Disposal. Microsoft uses industry standard processes to delete Customer Data and Professional Services Data when it is no longer needed.
Communications and Operations Management	Operational Policy. Microsoft maintains security documents describing its security measures and the relevant procedures and responsibilities of its personnel who have access to Customer Data or Professional Services Data. Data Recovery Procedures • On an ongoing basis, but in no case less frequently than once a week (unless no updates have occurred during that period), Microsoft maintains multiple copies of Customer Data and Professional Services Data from which such data can be recovered. • Microsoft stores copies of Customer Data and Professional Services Data and data recovery procedures in a different place from where the primary computer equipment processing the Customer Data and Professional Services Data are located. • Microsoft has specific procedures in place governing access to copies of Customer Data and Professional Services Data. • Microsoft reviews data recovery procedures at least every six months, except for data recovery procedures for Professional Services and for Azure Government Services, which are reviewed every twelve months. • Microsoft logs data restoration efforts, including the person responsible, the description of the restored data and where applicable, the person responsible and which data (if any) had to be input manually in the data recovery process. • Malicious Software. Microsoft has anti-malware controls to help avoid malicious software gaining unauthorized access to Customer Data and

Domain	Practices
	Professional Services Data, including malicious software originating from public networks. Data Beyond Boundaries • Microsoft encrypts, or enables Customer to encrypt, Customer Data and Professional Services Data that is transmitted over public networks. • Microsoft restricts access to Customer Data and Professional Services Data in media leaving its facilities. Event Logging. Microsoft logs, or enables Customer to log, access and use of information systems containing Customer Data or Professional Services Data, registering the access ID, time, authorization granted or denied, and relevant activity.
Access Control	Access Policy. Microsoft maintains a record of security privileges of individuals having access to Customer Data or Professional Services Data. Access Authorization • Microsoft maintains and updates a record of personnel authorized to access Microsoft systems that contain Customer Data or Professional Services Data. • Microsoft deactivates authentication credentials that have not been used for a period of time not to exceed six months. • Microsoft identifies those personnel who may grant, alter or cancel authorized access to data and resources. • Microsoft ensures that where more than one individual has access to systems containing Customer Data or Professional Services Data, the individuals have separate identifiers/log-ins. Least Privilege • Technical support personnel are only permitted to have access to Customer Data and Professional Services Data when needed. • Microsoft restricts access to Customer Data and Professional Services Data to only those individuals who require such access to perform their job function. Integrity and Confidentiality • Microsoft instructs Microsoft personnel to disable administrative sessions when leaving premises Microsoft controls or when computers are otherwise left unattended. • Microsoft stores passwords in a way that makes them unintelligible while they are in force. Authentication • Microsoft uses industry standard practices to identify and authenticate users who attempt to access information systems. • Where authentication mechanisms are based on passwords, Microsoft requires that the passwords are renewed regularly. • Where authentication mechanisms are based on passwords, Microsoft requires the password to be at least eight characters long. • Microsoft ensures that de-activated or expired identifiers are not granted to other individuals. • Microsoft monitors, or enables Customer to monitor, repeated attempts to gain access to the information system using an invalid password. • Microsoft maintains industry standard procedures to deactivate passwords that have been corrupted or inadvertently disclosed. • Microsoft uses industry standard password protection practices, including practices designed to maintain the confidentiality and integrity of passwords when they are assigned and distributed, and during storage.

Domain	Practices
	Network Design. Microsoft has controls to avoid individuals assuming access rights they have not been assigned to gain access to Customer Data or Professional Services Data they are not authorized to access.
Information Security Incident Management	Incident Response Process • Microsoft maintains a record of security breaches with a description of the breach, the time period, the consequences of the breach, the name of the reporter, and to whom the breach was reported, and the procedure for recovering data. • For each security breach that is a Security Incident, notification by Microsoft (as described in the “Security Incident Notification” section above) will be made without undue delay and, in any event, within 72 hours. • Microsoft tracks, or enables Customer to track, disclosures of Customer Data and Professional Services Data, including what data has been disclosed, to whom, and at what time. Service Monitoring. Microsoft security personnel verify logs at least every six months to propose remediation efforts if necessary.
Business Continuity Management	• Microsoft maintains emergency and contingency plans for the facilities in which Microsoft information systems that process Customer Data or Professional Services Data are located. • Microsoft’s redundant storage and its procedures for recovering data are designed to attempt to reconstruct Customer Data and Professional Services Data in its original or last-replicated state from before the time it was lost or destroyed.

Table 4: Microsoft Terms Concerning Security Measures

Security Incident Notification. The DPA contains an express provision concerning security incident notification:

“If Microsoft becomes aware of a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to Customer Data, Professional Services Data, or Personal Data while processed by Microsoft (each a “Security Incident”), Microsoft will promptly and without undue delay (1) notify Customer of the Security Incident; (2) investigate the Security Incident and provide Customer with detailed information about the Security Incident; (3) take reasonable steps to mitigate the effects and to minimize any damage resulting from the Security Incident.

Notification(s) of Security Incidents will be delivered to Customer by any means Microsoft selects, including via email. It is Customer’s sole responsibility to ensure Customer maintains accurate contact information with Microsoft for each applicable Product and Professional Service. Customer is solely responsible for complying with its obligations under incident notification laws applicable to Customer and fulfilling any third-party notification obligations related to any Security Incident.

Microsoft shall make reasonable efforts to assist Customer in fulfilling Customer’s obligation under GDPR Article 33 or other applicable law or regulation to notify the relevant supervisory authority and data subjects about such Security Incident.

Microsoft’s notification of or response to a Security Incident under this section is not an acknowledgement by Microsoft of any fault or liability with respect to the Security Incident.

Customer must notify Microsoft promptly about any possible misuse of its accounts or authentication credentials or any security incident related to the Products and Services.”

While not a contractual obligation, Microsoft has also adopted a policy to notify customers if they believe that a customer account has been targeted or compromised by an individual or group working on behalf of a nation state. This policy has been adopted because a “state-sponsored” attack could be more sophisticated or more sustained than attacks from cybercriminals and others. These notifications do not mean that Microsoft’s own systems have been compromised. If customers receive such a notification, this means that there is evidence the customer account has been targeted. This will allow customers to take additional measures to keep their account secure.

Information retention and destruction. The DPA states:

“Data Retention and Deletion

At all times during the term of Customer’s subscription or the applicable Professional Services engagement, Customer will have the ability to access, extract and delete Customer Data stored in each Online Service and Professional Services Data.

Except for free trials and LinkedIn services, Microsoft will retain Customer Data that remains stored in Online Services in a limited function account for 90 days after expiration or termination of Customer’s subscription so that Customer may extract the data. After the 90-day retention period ends, Microsoft will disable Customer’s account and delete the Customer Data and Personal Data stored in Online Services within an additional 90 days, unless authorized under this DPA to retain such data.

For Personal Data in connection with the Software and for Professional Services Data, Microsoft will delete all copies after the business purposes for which the data was collected or transferred have been fulfilled or earlier upon Customer’s request, unless authorized under this DPA to retain such data.

The Online Service may not support retention or extraction of software provided by Customer. Microsoft has no liability for the deletion of Customer Data, Professional Services Data, or Personal Data as described in this section.”

Periodic vulnerability assessments. See provision pertaining to security provisions.

The availability of audit results. The DPA states:

“Auditing Compliance

Microsoft will conduct audits of the security of the computers, computing environment, and physical data centers that it uses in processing Customer Data, Professional Service Data, and Personal Data, as follows:

Where a standard or framework provides for audits, an audit of such control standard or framework will be initiated at least annually.

Each audit will be performed according to the standards and rules of the regulatory or accreditation body for each applicable control standard or framework.

Each audit will be performed by qualified, independent, third party security auditors at Microsoft’s selection and expense.

Each audit will result in the generation of an audit report (“Microsoft Audit Report”), which Microsoft will make available at <https://servicetrust.microsoft.com/> or another location identified by Microsoft. The Microsoft Audit Report will be Microsoft’s Confidential Information and will clearly disclose any material findings by the auditor. Microsoft will promptly remediate issues raised in any Microsoft Audit Report to the satisfaction of the auditor. If Customer requests, Microsoft will

provide Customer with each Microsoft Audit Report. The Microsoft Audit Report will be subject to non-disclosure and distribution limitations of Microsoft and the auditor.

To the extent Customer's audit requirements under the Data Protection Requirements cannot reasonably be satisfied through audit reports, documentation or compliance information Microsoft makes generally available to its customers, Microsoft will promptly respond to Customer's additional audit instructions. Before the commencement of an audit, Customer and Microsoft will mutually agree upon the scope, timing, duration, control and evidence requirements, and fees for the audit, provided that this requirement to agree will not permit Microsoft to unreasonably delay performance of the audit. To the extent needed to perform the audit, Microsoft will make the processing systems, facilities and supporting documentation relevant to the processing of Customer Data, Professional Services Data, and Personal Data by Microsoft, its Affiliates, and its Subprocessors available. Such an audit will be conducted by an independent, accredited third-party audit firm, during regular business hours, with reasonable advance notice to Microsoft, and subject to reasonable confidentiality procedures. Neither Customer nor the auditor shall have access to any data from Microsoft's other customers or to Microsoft systems or facilities not involved in providing the applicable Products and Services. Customer is responsible for all costs and fees related to such audit, including all reasonable costs and fees for any and all time Microsoft expends for any such audit, in addition to the rates for services performed by Microsoft. If the audit report generated as a result of Customer's audit includes any finding of material non-compliance, Customer shall share such audit report with Microsoft and Microsoft shall promptly cure any material non-compliance..."